

**PENGEMBANGAN KONTROL AKSES
GRANULAR DAN DELEGASI AKSES
ANTARTENAGA KESEHATAN PADA SISTEM
REKAM MEDIS ELEKTRONIK DECMED
MENGUNAKAN MACAROONS**

Laporan Tugas Akhir

Disusun sebagai syarat kelulusan tingkat sarjana

Oleh

Tazkia Nizami

NIM: 13522032



**PROGRAM STUDI TEKNIK INFORMATIKA
SEKOLAH TEKNIK ELEKTRO & INFORMATIKA
INSTITUT TEKNOLOGI BANDUNG**

Juli 2026

**PENGEMBANGAN KONTROL AKSES
GRANULAR DAN DELEGASI AKSES
ANTARTENAGA KESEHATAN PADA SISTEM
REKAM MEDIS ELEKTRONIK DECMED
MENGUNAKAN MACAROONS**

Oleh

Tazkia Nizami

NIM: 13522032

Program Studi Teknik Informatika

Sekolah Teknik Elektro dan Informatika

Institut Teknologi Bandung

Telah disetujui dan disahkan sebagai Laporan Tugas Akhir
di Bandung, pada tanggal 2 Juli 2026

Pembimbing,

Dr. Phil. Eng. Hari Purnama, S.Si., M.Si.

NIP. 118110072

LEMBAR PERNYATAAN

Dengan ini saya menyatakan bahwa:

1. Pengerjaan dan penulisan Laporan Tugas Akhir ini dilakukan tanpa menggunakan bantuan yang tidak dibenarkan.
2. Segala bentuk kutipan dan acuan terhadap tulisan orang lain yang digunakan di dalam penyusunan laporan tugas akhir ini telah dituliskan dengan baik dan benar.
3. Laporan Tugas Akhir ini belum pernah diajukan pada program pendidikan di perguruan tinggi mana pun.

Jika terbukti melanggar hal-hal di atas, saya bersedia dikenakan sanksi sesuai dengan Peraturan Akademik dan Kemahasiswaan Institut Teknologi Bandung bagian Penegakan Norma Akademik dan Kemahasiswaan khususnya Pasal 2.1 dan Pasal 2.2.

Bandung, 2 Juli 2026



Tazkia Nizami

NIM: 13522032

SURAT PERNYATAAN PENGGUNAAN AI

Dengan ini, saya:

Nama/NIM : Tazkia Nizami / 13522032
Fakultas/Sekolah : Sekolah Teknik Elektro dan Informatika
Judul : Pengembangan Kontrol Akses Granular dan Delegasi
Akses Antartena Kesehatan pada Sistem Rekam Medis
Elektronik DecMed Menggunakan Macaroon

Menyatakan bahwa saya menggunakan AI dalam pengerjaan maupun penyusunan
luaran tugas akhir yang tertulis di atas. Alat AI/kecerdasan buatan yang digunakan
adalah:

Lingkup Pekerjaan	Digunakan?	Tingkat Penggunaan
Pemeriksaan Ejaan: ChatGPT	Ya	10%
Pembuatan Teks: ChatGPT	Ya	40%
Bantuan Diskusi dalam Penyusunan Konten: ChatGPT	Ya	70%
Pembuatan Gambar, Video, dan/atau Grafik: ChatGPT	Ya	40%
Pencarian Referensi: Perplexity dan ChatGPT	Ya	60%

Saya juga menyatakan bahwa setiap penggunaan AI/kecerdasan buatan yang
dilakukan pada tugas akhir tersebut telah dinyatakan di dalam surat ini.

Bandung, 2 Juli 2026



Tazkia Nizami

13522032

ABSTRAK

PENGEMBANGAN KONTROL AKSES GRANULAR DAN DELEGASI AKSES ANTARTENAGA KESEHATAN PADA SISTEM REKAM MEDIS ELEKTRONIK DEC MED MENGUNAKAN MACAROONS

Oleh:

Tazkia Nizami
NIM: 13522032

Rekam Medis Elektronik (RME) menuntut kontrol akses yang menjaga kendali pasien sekaligus mendukung pelayanan kesehatan kolaboratif. DecMed sebagai kerangka kerja RME terdesentralisasi telah memanfaatkan IOTA, IPFS, dan Proxy Re-Encryption (PRE), tetapi masih memiliki tiga keterbatasan utama: pemberian akses bergantung pada penerbitan ulang oleh pasien, *policy* akses bersifat *coarse-grained* berbasis *role* dan *purpose*, serta data RME tersimpan sebagai objek besar yang sulit ditegakkan sesuai prinsip *need-to-know*. Tugas Akhir ini merancang dan mengimplementasikan perluasan kontrol akses granular pada DecMed melalui tiga kontribusi. Pertama, model *Policy-Based Access Control* (PBAC) digunakan untuk mendefinisikan hubungan aktor, objek RME, hak akses, dan kondisi akses, lalu direpresentasikan sebagai token Macaroon dengan *caveats*. Kedua, data RME *off-chain* disegmentasi berdasarkan *dataset category* dan *function category* agar *policy* dapat ditegakkan pada unit data klinis. Ketiga, atenuasi token mendukung delegasi akses antartenant kesehatan tanpa intervensi langsung pasien; pembentukan token turunan dimediasi *Server PRE* agar cakupan turunan tidak melebihi token induk. PRE berperan sebagai mekanisme kriptografis pendukung distribusi kemampuan dekripsi dan sebagai titik penegakan sebelum data terenkripsi diproses. Prototipe mencakup segmentasi RME, token Macaroon, penegakan pada *Server PRE*, *smart contract IOTA Move*, serta penyesuaian *Patient Client* dan *Hospital Client* untuk alur rawat jalan dan rawat inap melibatkan petugas rekam medis, perawat, dokter, petugas laboratorium, dan apoteker. Pengujian dilakukan melalui skenario fungsional P-KF-01 sampai P-KF-12 dan pengujian nonfungsional P-KNF-01 sampai P-KNF-16. Pada cakupan skenario uji dan batasan prototipe, kebutuhan fungsional dan nonfungsional yang diuji dinyatakan terpenuhi.

Kata kunci: *Rekam Medis Elektronik, Policy-Based Access Control, Macaroons, Proxy Re-Encryption, IOTA*

KATA PENGANTAR

Puji dan syukur penulis panjatkan kepada Tuhan Yang Maha Esa atas berkat dan rahmatnya, laporan tugas akhir yang berjudul "Pengembangan Kontrol Akses Granular dan Delegasi Akses Antartena Kesehatan pada Sistem Rekam Medis Elektronik DecMed Menggunakan Macaroon" dapat diselesaikan dalam rangka memenuhi syarat kelulusan tingkat sarjana. Perlu diakui pengerjaan tugas akhir ini didukung oleh banyak pihak. Khususnya, penulis ingin mengucapkan terima kasih kepada:

1. Ani Rochani Rochmawati dan Widodo selaku orang tua penulis atas dukungan materi dan emosi selama ini hingga penulis berhasil menyelesaikan pengerjaan tugas akhir.
2. Fathiya Alisa Zahrandika selaku kakak penulis atas dukungan emosi dan materi selama masa perkuliahan hingga bisa menjalani perkuliahan dengan baik.
3. Bapak Dr. Phil. Eng. Hari Purnama, S.Si., M.Si., selaku dosen pembimbing atas segala bentuk dukungan yang telah diberikan, kesabarannya dalam membimbing penulis, serta memberikan saran dalam pengerjaan tugas akhir.
4. Daffa Ramadhan Elengi selaku teman dekat penulis yang selalu menjadi teman berpetualang dan mencari pengalaman baru selama dari awal masa perkuliahan hingga saat ini.
5. Grup DecMed loh dek, yaitu Bagas dan Rafa, sebagai teman perjuangan selama pengerjaan tugas akhir.
6. Grup Mamang Boneng, yaitu Dhidit dan Naufal yang sebagai teman perkuliahan selama masa perkuliahan di jurusan Teknik Informatika.
7. Grup Orang Orangan Dapur, yaitu Dapur, Yusuf, Ihsan, Dabbir, Gonza,

Fairuz, dan Saad yang telah menjadi teman bermain Mobile Legends setiap malam hingga mencapai *rank* Immortal.

8. Grup Paguyuban Bacin yang berisi teman-teman yang telah menjadi teman bermain bulu tangkis dan agenda lainnya selama masa perkuliahan.
9. Teman-teman Teknik Informatika angkatan 2022, angkatan BYTE, yang telah menjalani perkuliahan bersama penulis selama ini.
10. Seluruh pihak lain yang tidak disebutkan disini yang telah membantu dan mendukung dalam proses pengerjaan tugas akhir.

Akhir kata, penulis mengucapkan terima kasih kepada semua pihak yang telah terlibat dalam pengerjaan tugas akhir ini. Penulis juga ingin menyampaikan mohon maaf apabila terdapat kesalahan maupun kekurangan dalam laporan tugas akhir ini. Penulis berharap semoga tugas akhir ini dapat bermanfaat bagi pembaca dan riset-riset kedepannya.

Bandung, 2 Juli 2026



Tazkia Nizami

DAFTAR ISI

ABSTRAK	v
KATA PENGANTAR	vi
DAFTAR ISI	viii
DAFTAR LAMPIRAN	xiv
DAFTAR GAMBAR	xv
DAFTAR TABEL	xvii
DAFTAR KODE PROGRAM	xix
BAB I PENDAHULUAN	1
I.1 Latar Belakang	1
I.2 Rumusan Masalah	3
I.3 Tujuan	3
I.4 Batasan Masalah	4
I.5 Metodologi	4
I.6 Sistematika Pembahasan	5
BAB II STUDI LITERATUR	7
II.1 Rekam Medis Elektronik	7
II.1.1 Definisi RME	7
II.1.2 Isi RME	7
II.1.3 RME dalam Alur Pelayanan Kesehatan Kolaboratif	8
II.1.4 Hak Akses RME	8
II.2 IOTA	9
II.2.1 Distributed Ledger Technology	9
II.2.2 IOTA	9
II.3 InterPlanetary File System (IPFS)	10
II.4 <i>Proxy Re-Encryption</i> (PRE)	10
II.4.1 Umbral PRE	11
II.5 Kontrol Akses	12
II.5.1 Definisi Kontrol Akses	12
II.5.2 Kontrol Akses Granular	12
II.5.3 Model CapBAC	13

II.5.4	Policy-Based Access Control	13
II.6	Token Otorisasi	15
II.6.1	JSON Web Token	15
II.6.2	PASETO	15
II.6.3	Macaroons	16
II.6.4	Biscuit Token	17
II.7	DecMed	17
II.7.1	Arsitektur DecMed	18
II.7.2	Alur Pengelolaan dan Akses RME pada DecMed	18
II.8	Pemodelan Ancaman STRIDE	19
II.9	Penelitian Terkait	20
II.9.1	Hybrid RBAC dan ABAC pada Sistem RME Berbasis Blockchain.....	20
II.9.2	Model Kontrol Akses Empat Lapis untuk RME Berbasis Blockchain.....	21
II.9.3	Kontrol Akses Granular Menggunakan <i>Composable NFT</i>	21
II.9.4	Implementasi Macaroons untuk Delegasi Akses pada Sistem Nyata	22
BAB III	ANALISIS DAN RANCANGAN SOLUSI	23
III.1	Analisis Masalah	23
III.1.1	Analisis Sistem DecMed.....	23
III.1.1.1	Keterbatasan Token Kapabilitas DecMed	24
III.1.1.2	Keterbatasan Segmentasi Data pada DecMed	25
III.1.1.3	Analisis Skenario Layanan Kesehatan Kolaboratif	27
III.1.1.4	Analisis STRIDE pada Sistem DecMed	29
III.1.1.5	Analisis Mekanisme Penggunaan dan Revokasi Token	30
III.1.2	Identifikasi Masalah.....	31
III.1.3	Kebutuhan Sistem	33
III.1.3.1	Kebutuhan Fungsional	34
III.1.3.2	Kebutuhan Nonfungsional.....	36
III.1.3.3	Pemetaan Masalah terhadap Kebutuhan Sistem	37
III.2	Analisis Solusi	37
III.2.1	Analisis Pendekatan PBAC	38

III.2.2	Analisis Segmentasi Data RME	40
III.2.3	Analisis Pemilihan Token Otorisasi	42
III.2.4	Analisis Delegasi Akses Antartena Kesehatan	44
III.2.5	Analisis Penegakan Otoritas pada <i>Server</i> PRE	45
III.2.5.1	Analisis Verifikasi Aktor dan Operasi Tulis	46
III.2.5.2	Analisis Verifikasi Bukti Identitas Aktor pada Rantai Delegasi	46
III.2.5.3	Analisis Revokasi dan Audit Delegasi	47
III.2.6	Pemetaan Masalah terhadap Solusi	47
III.3	Rancangan Solusi	47
III.3.1	Rancangan Arsitektur Solusi	48
III.3.2	Rancangan Segmentasi Data RME	49
III.3.3	Rancangan Model PBAC pada DecMed	51
III.3.3.1	Pengguna dan Atribut Pengguna	52
III.3.3.2	Objek dan Atribut Objek	53
III.3.3.3	Hak Akses dan Asosiasi	54
III.3.3.4	Kondisi <i>Policy</i> Akses	56
III.3.3.5	Rancangan <i>Policy</i> Delegasi	57
III.3.3.6	Fungsi Keputusan Akses	58
III.3.3.7	Pemetaan Model <i>Policy</i> ke Komponen DecMed ...	59
III.3.4	Rancangan Representasi <i>Policy</i> pada Token Macaroons	60
III.3.4.1	Rancangan Subjek Rantai Delegasi	62
III.3.4.2	Penerbitan Token Awal	62
III.3.4.3	Atenuasi Token sebagai Realisasi Delegasi	63
III.3.4.4	<i>Caveat</i> Kedalaman Delegasi dan Hubungan Token	64
III.3.4.5	Penerapan Whitelisting dan Least Privilege	64
III.3.4.6	Hubungan dengan Proses Verifikasi	64
III.3.5	Rancangan Penegakan Otoritas	65
III.3.5.1	Penegakan <i>Policy</i>	66
III.3.5.2	Verifikasi <i>Role</i> dan <i>Subrole</i> untuk Akses <i>Dataset</i> ..	67
III.3.5.3	Verifikasi <i>Wallet</i> Aktor pada Rantai Delegasi	67
III.3.5.4	Pencabutan Hak Akses Macaroon Delegasi	68
III.3.6	Rancangan Alur Akses dan Delegasi Macaroon	70

III.3.6.1	Penerbitan Token Awal oleh Pasien kepada Petugas Rekam Medis	71
III.3.6.2	Delegasi dari Petugas Rekam Medis kepada Perawat dan Dokter	73
III.3.6.3	Delegasi dari Dokter kepada Laboratorium dan Apoteker	74
III.3.6.4	Proses Pemberian dan Penggunaan Token Macaroon Delegasi	74
III.3.7	Pemetaan Rancangan terhadap Solusi.....	78
BAB IV	IMPLEMENTASI DAN PENGUJIAN.....	79
IV.1	Lingkungan Implementasi	79
IV.2	Implementasi Sistem.....	80
IV.2.1	Batasan Implementasi.....	80
IV.2.2	Implementasi Arsitektur Sistem	81
IV.2.3	Implementasi Segmentasi Data RME	82
IV.2.3.1	Implementasi Segmentasi Metadata RME pada Penyimpanan <i>On-Chain</i>	83
IV.2.3.2	Implementasi Segmentasi Data RME pada Penyimpanan <i>Off-Chain</i>	84
IV.2.4	Implementasi Token Otorisasi Berbasis Macaroons.....	85
IV.2.4.1	Komponen Implementasi Macaroons	85
IV.2.4.2	Struktur <i>Caveats</i> Macaroons	86
IV.2.4.3	Penerbitan Token Macaroon	86
IV.2.4.4	Atenuasi Token Macaroon	87
IV.2.4.5	Revokasi Token Macaroon	87
IV.2.5	Delegasi Akses dan Atenuasi Token	87
IV.2.5.1	Delegasi Akses dari Pasien kepada Petugas Rekam Medis	87
IV.2.5.2	Delegasi Akses Antartena Kesehatan	88
IV.2.6	Implementasi Penegakan Otoritas	90
IV.2.6.1	Autentikasi Token Macaroon.....	90
IV.2.6.2	Pemeriksaan Status Revokasi Token.....	92
IV.2.6.3	Verifikasi Bukti Kepemilikan <i>Wallet</i>	92

IV.2.6.4	Verifikasi <i>Role</i> dan <i>Subrole</i> melalui <i>Move Smart Contract</i>	92
IV.2.6.5	Verifikasi Konteks Segmen	93
IV.2.6.6	Eksekusi Operasi <i>Re-encryption</i> , IPFS, dan IOTA .	93
IV.2.7	Implementasi <i>Smart Contract</i> IOTA Move	93
IV.2.8	Implementasi <i>Patient Client</i>	94
IV.2.8.1	Halaman <i>Home</i> (<i>List RME</i>)	94
IV.2.8.2	Halaman Detail RME	94
IV.2.8.3	Halaman Audit Delegasi	95
IV.2.8.4	Halaman Detail <i>Scan QR</i>	96
IV.2.9	Implementasi <i>Hospital Client</i>	96
IV.2.9.1	Halaman <i>Dashboard</i> (<i>List RME</i>)	96
IV.2.9.2	Halaman Delegasi Akses	97
IV.2.9.3	Halaman Daftar RME Pasien	97
IV.2.9.4	Halaman Baca Detail RME	97
IV.2.9.5	Halaman Tulis Segmen RME	97
IV.3	Pengujian Sistem	97
IV.3.1	Strategi Pengujian	97
IV.3.2	Pengujian Kebutuhan Fungsional	98
IV.3.3	Pengujian Kebutuhan Nonfungsional	98
IV.3.3.1	Pengujian KNF-TA-01	99
IV.3.3.2	Pengujian KNF-TA-02	100
IV.3.3.3	Pengujian KNF-TA-03	102
IV.3.3.4	Pengujian KNF-TA-04	104
IV.3.3.5	Pengujian KNF-TA-05	105
IV.3.3.6	Pengujian KNF-TA-06	106
IV.3.3.7	Pengujian KNF-TA-07	107
IV.3.3.8	Pengujian KNF-TA-08	109
IV.4	Evaluasi	110
IV.4.1	Evaluasi terhadap Kebutuhan Sistem	111
IV.4.2	Keterbatasan Implementasi	111
BAB V	PENUTUP	113
V.1	Kesimpulan	113
V.2	Saran	113

DAFTAR REFERENSI	119
-------------------------------	------------

DAFTAR LAMPIRAN

Lampiran A.	Metadata Rekam Medis Elektronik	120
Lampiran B.	Alur Pemberian Akses Medis pada DecMed	123
Lampiran C.	Kebutuhan Fungsional DecMed	124
Lampiran D.	DFD DecMed	126
Lampiran E.	Analisis STRIDE pada Sistem DecMed	130
Lampiran F.	Legenda Diagram Arsitektur Solusi	132
Lampiran G.	Skema Penyimpanan Data RME	133
Lampiran H.	Contoh <i>Caveat</i> Token Macaroon untuk Setiap Tahapan	136
Lampiran I.	Pengujian dan Evaluasi Kebutuhan Sistem	140
I.1	Pengujian Kebutuhan Fungsional	140
I.2	Evaluasi Kebutuhan Sistem.....	141
Lampiran J.	Daftar Dependensi DecMed	143
Lampiran K.	Legenda Package Diagram	146
Lampiran L.	Modul dan Implementasi <i>Crate</i> decmed-rme-segment	147
Lampiran M.	Modul dan Implementasi <i>Crate</i> decmed-macaroon-auth	148
Lampiran N.	Alur Implementasi Penegakan Otoritas pada Server PRE	150
Lampiran O.	Implementasi REST API Server PRE	153
Lampiran P.	Implementasi Smart Contract Sistem DecMed	154
Lampiran Q.	Tangkapan Layar Implementasi <i>Patient Client</i>	158
Lampiran R.	Tangkapan Layar Implementasi <i>Hospital Client</i>	161

DAFTAR GAMBAR

Gambar II.1. Gambaran simulasi dari PRE (Nuñez, 2017).....	11
Gambar II.2. <i>Sequence diagram</i> dari model CapBAC. (Dokumentasi penulis).....	13
Gambar II.3. Contoh delegasi dan atenuasi kewenangan pada Macaroon. C memegang Macaroon yang diturunkan dari <i>service</i> FS untuk mengakses data pada <i>service</i> TS dengan batasan waktu, lokasi IP, dan target data yang spesifik. (Birgisson dkk., 2014).....	17
Gambar II.4. Arsitektur DecMed (Sadewa, 2025).....	18
Gambar II.5. Ilustrasi struktur data DMR menggunakan composable NFT. (Amaracitra & Alamsyah, 2025).....	22
Gambar III.1. <i>Use Case Diagram</i> Kebutuhan Fungsional Tambahan DecMed.....	34
Gambar III.2. Arsitektur Solusi (Dokumentasi Penulis).....	49
Gambar III.3. Alur penegakan otoritas pada <i>Server</i> PRE.....	66
Gambar III.4. <i>Sequence Diagram</i> Rancangan Validasi <i>subrole</i> Tenaga Medis terhadap <i>Dataset Category</i>	68
Gambar III.5. <i>Sequence Diagram</i> Rancangan Alur Pencabutan Hak Akses Macaroon Delegasi.....	69
Gambar III.6. <i>Flow Diagram</i> Alur Akses dan Delegasi pada Proses Pelayanan Pasien.....	71
Gambar III.7. <i>Sequence diagram</i> pembentukan dan pencatatan token Macaroon delegasi	75
Gambar III.8. <i>Sequence diagram</i> pengambilan dan penggunaan token Macaroon delegasi	77
Gambar IV.1. Package Diagram Implementasi	82
Gambar IV.2. Proses enkripsi dan penyimpanan RME	94
Gambar IV.3. Proses dekripsi RME oleh pasien.....	95
Gambar IV.4. Proses pembentukan akses PRE saat pemberian akses	95
Gambar IV.5. Proses <i>re-encryption</i> dan dekripsi oleh <i>Hospital Client</i>	96

Gambar B.1. <i>Sequence Diagram</i> Alur Pemberian Akses Medis dari Pasien kepada Tenaga Medis (Sadewa, 2025)	123
Gambar D.1. Legenda <i>Data Flow Diagram</i> (Dokumentasi Penulis)	126
Gambar D.2. DFD DecMed Level 0 (Dokumentasi Penulis).....	126
Gambar D.3. DFD DecMed Level 1 (Dokumentasi Penulis).....	127
Gambar F.1. Legenda Diagram Arsitektur Solusi (Dokumentasi Penulis)	132
Gambar K.1. Legenda Package Diagram (Dokumentasi Penulis)	146
Gambar N.1. Legenda bentuk pada <i>Flow Diagram</i>	150
Gambar N.2. Alur implementasi penegakan otoritas pada <i>Server PRE</i> bagian autentikasi token, <i>effective capability</i> , <i>delegation chain</i> , dan revokasi...	151
Gambar N.3. Alur implementasi penegakan otoritas pada <i>Server PRE</i> bagian <i>wallet proof</i> , validasi <i>role</i> dan <i>subrole</i> , validasi segmen, serta eksekusi PRE, IPFS, dan IOTA.....	152
Gambar Q.1. Halaman <i>Home</i> daftar RME.	158
Gambar Q.2. Halaman detail RME.	159
Gambar Q.3. Halaman audit delegasi RME.....	159
Gambar Q.4. Halaman <i>scan QR</i>	160
Gambar Q.5. Halaman konfirmasi pemberian akses awal.	160
Gambar R.1. Halaman <i>dashboard MedicalPersonnel</i>	161
Gambar R.2. Halaman delegasi akses bagian 1.....	161
Gambar R.3. Halaman delegasi akses bagian 2.....	162
Gambar R.4. Halaman daftar RME pasien pada <i>Hospital Client</i>	162
Gambar R.5. Halaman detail RME pada <i>Hospital Client</i>	163
Gambar R.6. Halaman alur akses tulis pada <i>Hospital Client</i>	163

DAFTAR TABEL

Tabel II.1.	Komponen, aktor, dan fungsi dalam arsitektur DecMed	19
Tabel II.2.	Kategori ancaman pada STRIDE.....	20
Tabel III.1.	Pemetaan Aktor dan Kebutuhan Akses pada Skenario Layanan Kesehatan Kolaboratif	28
Tabel III.2.	Identifikasi Masalah DecMed	33
Tabel III.3.	Kebutuhan Fungsional Tambahan DecMed	35
Tabel III.4.	Kebutuhan Nonfungsional Tambahan DecMed	36
Tabel III.5.	Pemetaan Masalah terhadap Kebutuhan Sistem.....	37
Tabel III.6.	Analisis Pendekatan Pemodelan <i>Policy</i> Akses	38
Tabel III.7.	Perbandingan Pendekatan Token Otorisasi.....	43
Tabel III.8.	Daftar Solusi yang Diusulkan Berdasarkan Hasil Analisis.....	48
Tabel III.9.	Tabel Pemetaan <i>Dataset Category</i>	50
Tabel III.10.	Tabel Pemetaan <i>Function Category</i>	50
Tabel III.11.	Kondisi <i>Policy</i> Akses DecMed.....	56
Tabel III.12.	Pemetaan Model <i>Policy</i> terhadap Komponen DecMed	60
Tabel III.13.	Penempatan <i>Caveat</i> menurut Jenis Token.....	61
Tabel III.14.	Pemetaan Hak Akses Update Berdasarkan subrole Tenaga Medis.....	67
Tabel III.15.	Pemetaan Delegasi Token dari Petugas Rekam Medis.....	73
Tabel III.16.	Pemetaan Delegasi Lanjutan dari Dokter	74
Tabel III.17.	Pemetaan Rancangan terhadap Solusi.....	78
Tabel IV.1.	Daftar Implementasi Sistem	81
Tabel IV.2.	<i>Caveats</i> yang Diimplementasikan pada Token Macaroon.....	86
Tabel IV.3.	Status Implementasi Penegakan Otoritas pada <i>Server</i> PRE	90
Tabel A.1.	Metadata Variabel RME Rawat Jalan.....	120
Tabel A.2.	Metadata Variabel RME Rawat Inap.....	121
Tabel A.3.	Metadata Variabel RME Laboratorium.....	122
Tabel A.4.	Metadata Variabel RME Apotek	122

Tabel C.1.	Kebutuhan Fungsional DecMed (Sadewa, 2025)	124
Tabel D.1.	Daftar <i>External Entities</i> pada DFD DecMed.....	128
Tabel D.2.	Daftar <i>Process</i> DFD DecMed	128
Tabel D.3.	Daftar <i>Data Store</i> pada DFD DecMed.....	128
Tabel D.4.	Daftar Data Flow pada DFD DecMed (Level 0).....	129
Tabel D.5.	Daftar Data Flow pada DFD DecMed (Level 1).....	129
Tabel E.1.	Analisis STRIDE pada Sistem DecMed	130
Tabel G.1.	Skema Metadata Segmen RME <i>On-Chain</i>	133
Tabel G.2.	Skema Segmen Data RME <i>Off-Chain</i>	134
Tabel I.1.	Pengujian Kebutuhan Fungsional pada Alur Rawat Jalan dan Rawat Inap.....	140
Tabel I.2.	Evaluasi Kebutuhan Sistem terhadap Implementasi dan Pengujian .	141
Tabel J.1.	Dependensi Umum yang Digunakan pada Beberapa Komponen ...	143
Tabel J.2.	Dependensi PRE.....	144
Tabel J.3.	Dependensi <i>Client</i>	144
Tabel J.4.	Dependensi decmed-rme-segment	145
Tabel J.5.	Dependensi decmed-macaroon-auth	145
Tabel L.1.	Daftar Modul dan Implementasi <i>Crate</i> decmed-rme-segment	147
Tabel M.1.	Daftar Modul dan Implementasi <i>Crate</i> decmed-macaroon-auth	148
Tabel O.1.	Daftar Endpoint REST API pada Server PRE	153
Tabel P.1.	Daftar Module Smart Contract Sistem DecMed.....	154
Tabel P.2.	Daftar Method pada Module decmed::admin	154
Tabel P.3.	Daftar Method pada Module decmed::hospital_personnel.....	155
Tabel P.4.	Daftar Method pada Module decmed::patient	156
Tabel P.5.	Daftar Method pada Module decmed::proxy	157

DAFTAR KODE PROGRAM

III.1 Struktur klaim JWT pada DecMed.....	24
III.2 Struktur metadata medis pasien pada DecMed	25
III.3 Struktur serialisasi metadata medis DecMed	26
III.4 Potongan struktur data medis <i>off-chain</i> pada DecMed	26
IV.1 Implementasi DatasetCategory pada <i>crate</i> decmed-rme-segment	82
IV.2 Implementasi FunctionCategory pada <i>crate</i> decmed-rme-segment	82
IV.3 Implementasi struktur RmeSegmentMetadata pada <i>crate</i> decmed-rme-segment	83
IV.4 Implementasi struktur RmeSegmentData pada <i>crate</i> decmed-rme-segment	84
IV.5 Definisi DelegationProofContext	89
IV.6 Definisi EffectiveCapability	91
IV.7 Definisi DelegationStep dan DelegationChain.....	91
IV.8 Struktur WalletProofContext sebagai konteks verifikasi <i>wallet</i> <i>signature</i>	92
IV.9 Pengujian P-KNF-01 untuk KNF-TA-01	99
IV.10 Pengujian P-KNF-03 untuk KNF-TA-02	100
IV.11 Pengujian P-KNF-04 untuk KNF-TA-02	101
IV.12 Pengujian P-KNF-05 untuk KNF-TA-02	101
IV.13 Pengujian P-KNF-07 untuk KNF-TA-03	102
IV.14 Pengujian P-KNF-08 untuk KNF-TA-03	103
IV.15 Pengujian P-KNF-09 untuk KNF-TA-03 dan KNF-TA-06	104
IV.16 Pengujian P-KNF-11 untuk KNF-TA-05	105
IV.17 Pengujian P-KNF-13 untuk KNF-TA-06	106
IV.18 Pengujian P-KNF-14 untuk KNF-TA-07	108
IV.19 Pengujian P-KNF-15 untuk KNF-TA-07	108
IV.20 Pengujian P-KNF-16 untuk KNF-TA-08	109
H.1 Contoh <i>Caveat</i> Token Read Awal untuk Petugas Rekam Medis	136
H.2 Contoh <i>Caveat</i> Token Update Awal untuk Petugas Rekam Medis....	136
H.3 Contoh <i>Caveat</i> Delegasi Petugas Rekam Medis → Dokter.....	137

H.4	Contoh <i>Caveat</i> Delegasi Petugas Rekam Medis → Perawat	138
H.5	Contoh <i>Caveat</i> Delegasi Dokter → Petugas Laboratorium	138
H.6	Contoh <i>Caveat</i> Delegasi Dokter → Apoteker	139

BAB I

PENDAHULUAN

I.1 Latar Belakang

Transformasi sistem rekam medis di Indonesia semakin didorong oleh regulasi pemerintah. Peraturan Menteri Kesehatan Republik Indonesia (Permenkes) Nomor 24 Tahun 2022 mewajibkan fasilitas pelayanan kesehatan (fasyankes) untuk mengimplementasikan Rekam Medis Elektronik (RME) yang terintegrasi (Kementerian Kesehatan Republik Indonesia, 2022b). Integrasi RME diperlukan untuk mendukung interoperabilitas data antarfasyankes, sesuai amanat Undang-Undang Nomor 29 Tahun 2004 (Republik Indonesia, 2004). Namun, integrasi tersebut juga menimbulkan kebutuhan perlindungan data yang lebih kuat karena RME merupakan data pribadi spesifik yang memerlukan perlindungan lebih kuat (UU 27/2022 tentang PDP, 2022).

Salah satu tantangan penting dalam pengembangan sistem RME adalah aspek kepemilikan data (Liu & Chen, 2025). Kepemilikan data berkaitan dengan kendali pasien terhadap informasi kesehatan miliknya, termasuk siapa yang dapat mengakses data tersebut dan dalam kondisi apa akses dapat diberikan. Sejumlah penelitian menekankan pentingnya pergeseran paradigma kontrol akses menuju sistem yang bersifat *patient-centric*, yaitu sistem yang memberikan kendali lebih besar kepada pasien sebagai pemilik data kesehatan (Patil, 2024; Peng dkk., 2023).

Meskipun kontrol pasien merupakan aspek penting, perawatan pasien di rumah sakit bersifat kolaboratif dan melibatkan banyak tenaga kesehatan lintas unit, seperti dokter, perawat, petugas laboratorium, apoteker, dan tenaga kesehatan lain yang bekerja sesuai kewenangannya (Kementerian Kesehatan Republik Indonesia, 2022a; Srinivas dkk., 2023). Dalam konteks tersebut, informasi klinis yang relevan perlu tersedia bagi tenaga kesehatan yang terlibat agar proses pelayanan dapat berjalan efektif (Srinivas dkk., 2023). NHS England menyatakan bahwa informasi yang relevan dapat dibagikan antartenant kesehatan yang terlibat dalam perawatan pasien berdasarkan *implied consent*, dengan tetap memperhatikan prinsip

need-to-know (NHS England, 2023, Maret 28/2025). Prinsip serupa juga tercermin pada konsep *minimum necessary* dalam HIPAA, yaitu bahwa penggunaan dan pengungkapan informasi kesehatan perlu dibatasi pada informasi minimum yang diperlukan untuk tujuan tertentu (of Health & Services, 2009).

Kondisi tersebut menunjukkan adanya kebutuhan untuk menyeimbangkan kendali pasien dengan kebutuhan operasional klinis. Studi terkait juga menunjukkan bahwa pasien pada umumnya mendukung pembagian data klinis untuk tujuan perawatan langsung tanpa persetujuan eksplisit pada setiap akses, selama pasien memperoleh informasi yang jelas dan tetap memiliki pilihan untuk *opt-out* (L. A. Jones dkk., 2022).

Kebutuhan tersebut sejalan dengan ISO 22600 yang menempatkan pengelolaan *privilege* dan kontrol akses yang granular sebagai bagian penting dalam pertukaran informasi kesehatan, khususnya pada lingkungan yang melibatkan banyak aktor, banyak sistem, dan beberapa domain *policy* (for Standardization, 2014). Standar tersebut menunjukkan bahwa akses pada sistem kesehatan perlu dikelola berbasis *policy*, sejalan dengan prinsip *privilege management* pada sistem informasi kesehatan (for Standardization, 2014).

Salah satu solusi sistem RME terdesentralisasi adalah DecMed (Sadewa, 2025). Sistem ini memanfaatkan DLT IOTA, *InterPlanetary File System* (IPFS), dan *Proxy Re-Encryption* (PRE) dengan menerapkan *capability-based access control*. Namun, mekanisme pemberian akses pada DecMed masih bertumpu pada pasien sebagai *resource owner* untuk menerbitkan token hak akses baru. Dalam konteks layanan klinis yang kolaboratif, asumsi tersebut dapat menjadi hambatan karena kebutuhan akses sering kali muncul secara dinamis sesuai peran tenaga kesehatan dalam episode perawatan. Selain itu, kontrol akses DecMed masih bersifat *coarse-grained* karena keputusan akses terutama ditentukan oleh *role* dan *purpose* pada token, sehingga belum mencakup hubungan eksplisit antarunsur *policy*: aktor, objek RME, hak akses, dan kondisi akses. Data RME yang dilindungi juga masih disimpan sebagai satu *entry* besar dan perlu dipisahkan ke dalam unit yang lebih kecil agar data dapat diakses sesuai dengan kebutuhan layanan. Terdapat tiga keterbatasan utama yang perlu diperbaiki: (1) mekanisme pemberian akses yang masih bergantung pada keterlibatan langsung pasien untuk setiap penerima; (2) *policy* akses yang masih *coarse-grained*; dan (3) struktur data RME yang belum

mendukung pemisahan informasi medis sesuai prinsip *need-to-know*.

Untuk menjawab keterbatasan tersebut, kontrol akses pada DecMed diperluas melalui penerapan *Policy-Based Access Control* (PBAC), segmentasi data RME, dan atenuasi token Macaroon untuk delegasi terbatas. PBAC digunakan agar *policy* akses tidak lagi terbatas pada *role* dan *purpose*, melainkan mencakup hubungan antara aktor, objek RME, hak akses, dan kondisi akses. Segmentasi data RME digunakan untuk mendukung penegakan *policy* tersebut pada unit data yang relevan dengan prinsip *need-to-know*. Macaroons secara konseptual mendukung atenuasi tanpa penerbitan ulang token oleh penerbit awal. Pada implementasi DecMed, pasien menerbitkan token awal pada proses administrasi, sedangkan pembentukan token turunan untuk delegasi antartanaga kesehatan dilakukan melalui *Server PRE* agar token induk, identitas *delegator*, cakupan akses, dan rantai delegasi diverifikasi sebelum token turunan diterbitkan. Macaroon berperan sebagai media pembawa kapabilitas hasil *policy*, bukan sebagai pengganti model *policy* itu sendiri.

I.2 Rumusan Masalah

Berdasarkan latar belakang yang telah diuraikan pada subbab I.1, rumusan masalah yang dibahas dalam tugas akhir ini adalah sebagai berikut:

1. Bagaimana rancangan dan implementasi mekanisme kontrol akses granular pada kerangka kerja DecMed dengan memanfaatkan Macaroons?
2. Bagaimana rancangan dan implementasi segmentasi data RME yang mendukung penegakan kontrol akses granular pada DecMed?
3. Bagaimana rancangan dan implementasi mekanisme atenuasi token otorisasi untuk memfasilitasi pendelegasian hak akses antartanaga kesehatan yang terlibat dalam layanan klinis tanpa memerlukan intervensi langsung dari pasien?

I.3 Tujuan

Tujuan dari Tugas Akhir ini adalah:

1. Merancang dan menerapkan kontrol akses granular pada kerangka kerja

DecMed dengan memanfaatkan teknologi Macaroons.

2. Merancang dan menerapkan segmentasi data RME yang mendukung penegakan kontrol akses granular pada DecMed.
3. Merancang dan menerapkan mekanisme atenuasi token untuk memfasilitasi pendelegasian hak akses antartanaga kesehatan tanpa memerlukan intervensi langsung dari pasien.

I.4 Batasan Masalah

Batasan Tugas Akhir ini adalah sebagai berikut:

1. Kajian dan pengembangan hanya fokus pada kerangka kerja DecMed.
2. Masalah terkait *performance* dan *availability* tidak termasuk ke dalam kajian dan skenario uji.
3. Kasus skenario delegasi layanan klinis terbatas hanya pada aktor dokter, perawat, petugas laboratorium, dan apoteker pada alur Rawat Jalan dan Rawat Inap.
4. Data RME pada dataset Instalasi Gawat Darurat (IGD) tidak termasuk dalam kajian rancangan dan implementasi.
5. Segmentasi data RME hanya dilakukan untuk dokumentasi klinis. Dokumentasi administratif tidak termasuk ke dalam fokus Tugas Akhir ini dan hanya diimplementasikan sesuai dengan implementasi DecMed sebelumnya.
6. Manajemen kunci BIP39, termasuk ketika pengguna lupa kunci *mnemonic*, tidak menjadi fokus Tugas Akhir ini.

I.5 Metodologi

Tugas akhir ini dilaksanakan melalui beberapa tahap berikut:

1. Studi Literatur

Pada tahap awal, fondasi teoretis dan kontekstual dikumpulkan melalui studi

literatur.

2. Analisis Kebutuhan

Pada tahap ini, kekurangan pada kerangka kerja DecMed dianalisis. Kekurangan tersebut diinterpretasikan sebagai masalah dan didefinisikan menjadi kebutuhan. Tahap ini diakhiri dengan perumusan kebutuhan fungsional dan nonfungsional sistem.

3. Analisis dan Rancangan Solusi

Pada tahap ini, alternatif solusi dianalisis untuk mengatasi masalah pada kerangka kerja DecMed. Solusi yang terpilih kemudian dirancang menjadi rancangan solusi.

4. Implementasi Prototipe

Pada tahap ini, rancangan direalisasikan melalui pengembangan prototipe DecMed yang sudah ada.

5. Pengujian

Pada tahap ini, prototipe diuji untuk memastikan pemenuhan kebutuhan sistem sesuai dengan skenario pengujian yang ditentukan.

6. Evaluasi

Hasil pengujian dievaluasi terhadap kebutuhan sistem sebagai dasar kesimpulan dan saran pengembangan selanjutnya. Keterlacakan antara masalah, kebutuhan, solusi, rancangan, implementasi, dan pengujian disajikan pada Lampiran ??.

I.6 Sistematika Pembahasan

Berikut merupakan sistematika pembahasan dari Tugas Akhir ini:

Bab I - Pendahuluan Gagasan utama dari tugas akhir diuraikan pada bab ini, meliputi latar belakang, rumusan masalah, tujuan, batasan, metodologi, hingga sistematika pembahasan mengenai proses pengembangan solusi.

Bab II - Studi Literatur Studi literatur terkait sistem yang dikembangkan dipaparkan pada bab ini. Pembahasan difokuskan pada uraian teoritis

berbagai komponen yang digunakan, termasuk regulasi dan teknologi yang digunakan dalam sistem.

Bab III - Analisis dan Rancangan Solusi Pada bab ini, analisis terhadap masalah yang ditemukan serta berbagai alternatif solusi yang dapat digunakan untuk mengatasinya diuraikan. Selain itu, rancangan solusi yang dikembangkan juga dibahas, meliputi pendefinisian kebutuhan fungsional dan nonfungsional, serta rancangan setiap komponen sistem.

Bab IV - Implementasi dan Pengujian Sistem Hasil implementasi dari rancangan solusi yang telah dipaparkan pada Bab III dijelaskan pada bab ini. Selain itu, strategi pengujian serta hasil pengujian yang dilakukan terhadap solusi juga dibahas pada bab ini.

Bab V - Penutup Kesimpulan dari hasil penelitian serta saran untuk pengembangan lebih lanjut disajikan pada bab ini.

BAB II

STUDI LITERATUR

II.1 Rekam Medis Elektronik

II.1.1 Definisi RME

Di Indonesia, Rekam Medis dan Rekam Medis Elektronik didefinisikan dalam Peraturan Menteri Kesehatan Republik Indonesia Nomor 24 Tahun 2022 (Permenkes 24/2022). "Rekam Medis adalah dokumen yang berisikan identitas pasien, pemeriksaan, pengobatan, tindakan, dan pelayanan lain yang telah diberikan pada pasien" sedangkan "Rekam Medis Elektronik adalah Rekam Medis yang dibuat dengan menggunakan sistem elektronik yang diperuntukkan bagi penyelenggaraan Rekam Medis." (Kementerian Kesehatan Republik Indonesia, 2022b).

Rekam medis berperan penting dalam sistem kesehatan di Indonesia. Rekam medis bukanlah catatan yang dibuat sekali lalu disimpan, melainkan catatan yang terus diperbarui. Keberadaan rekam medis bertujuan untuk meningkatkan mutu pelayanan kesehatan dan memberikan kepastian hukum dalam peristiwa medis.

II.1.2 Isi RME

Berdasarkan Permenkes 24/2022 Pasal 27 Ayat 1 (Kementerian Kesehatan Republik Indonesia, 2022b), isi RME terbagi menjadi dokumentasi administratif dan dokumentasi klinis. Panduan lebih rinci diatur pada Keputusan Menteri Kesehatan (KMK) No. HK.01.07/MENKES/1423/2022 tentang Pedoman Variabel dan Metadata pada Penyelenggaraan Rekam Medis Elektronik (Menteri Kesehatan Republik Indonesia, 2022). KMK tersebut mengatur variabel dan metadata RME dalam dataset yang terdiri dari IGD (Instalasi Gawat Darurat), Rawat Jalan, Rawat Inap, Laboratorium, dan Apotek. Detail metadata untuk dataset Rawat Jalan, Rawat Inap, Laboratorium, dan Apotek dapat dilihat pada Lampiran A.

II.1.3 RME dalam Alur Pelayanan Kesehatan Kolaboratif

Penyelenggaraan layanan kesehatan pada praktiknya melibatkan beberapa tenaga kesehatan yang bekerja sesuai kewenangan masing-masing (World Health Organization, 2010). Pasien dapat berinteraksi dengan petugas rekam medis pada tahap pendaftaran, perawat pada pemeriksaan awal, dokter pada pemeriksaan dan pengambilan keputusan klinis, petugas laboratorium pada pemeriksaan penunjang, serta apoteker pada pelayanan resep dan obat. Pola ini sejalan dengan praktik kolaboratif antarprofesi (Srinivas dkk., 2023).

Standar Akreditasi Rumah Sakit menempatkan DPJP (Dokter Penanggung Jawab Pasien) sebagai *clinical leader*, sedangkan PPA (Profesional Pemberi Asuhan) bekerja sebagai tim interdisiplin (Kementerian Kesehatan Republik Indonesia, 2022a). Alur operasional diperjelas oleh panduan interoperabilitas SATUSEHAT untuk Rawat Jalan dan Rawat Inap, yang memuat tahapan dari pendaftaran hingga resume medis (SATUSEHAT Platform, nodate, 2023). Kombinasi alur pelayanan, keterlibatan aktor, dan struktur dataset pada Subbab II.1.2 menunjukkan bahwa kebutuhan akses terhadap RME berbeda menurut tahap layanan, peran aktor, dan jenis data yang digunakan.

II.1.4 Hak Akses RME

Karena RME memuat data pribadi spesifik, akses harus dibatasi berdasarkan kewenangan, tindakan, dan kebutuhan pelayanan. Tenaga kesehatan dapat menambahkan data baru, memperbaiki data, serta melihat atau membaca data (Kementerian Kesehatan Republik Indonesia, 2022b).

Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi (UU PDP) menjadi landasan yuridis utama. Pasal 4 ayat 2 huruf a mengklasifikasikan data dan informasi kesehatan sebagai data pribadi spesifik (UU 27/2022 tentang PDP, 2022). Pengendali data pribadi diwajibkan melindungi keamanan data yang diproses (Pasal 35), menyediakan *audit trail* (Pasal 32), melindungi data dari pemrosesan yang tidak sah (Pasal 38), dan mencegah akses yang tidak sah (Pasal 39) (UU 27/2022 tentang PDP, 2022).

Prinsip pembatasan akses tersebut tercermin pada kebutuhan aktor penunjang. Berdasarkan Permenkes No. 73 Tahun 2016, pelayanan farmasi klinik mencakup

pengkajian resep dan *dispensing*, sehingga apoteker memerlukan akses terhadap informasi yang relevan dengan terapi dan penggunaan obat (Indonesia, 2016). Demikian pula, pada metadata KMK 1423/2022, permintaan pemeriksaan laboratorium dicantumkan sebagai bagian data pemeriksaan penunjang; petugas laboratorium cukup memperoleh informasi yang relevan untuk memproses pemeriksaan tersebut, bukan seluruh data klinis pasien (Menteri Kesehatan Republik Indonesia, 2022).

II.2 IOTA

II.2.1 Distributed Ledger Technology

Distributed Ledger Technology (DLT) merupakan teknologi pencatatan data terdistribusi yang memungkinkan data direkam, disimpan, dan diverifikasi oleh banyak *node* tanpa bergantung pada satu otoritas terpusat. DLT mencakup berbagai bentuk implementasi, termasuk *blockchain* dan struktur alternatif seperti *Directed Acyclic Graph* (DAG), yang masing-masing memiliki pendekatan berbeda dalam mencapai konsensus, keamanan, dan skalabilitas pada jaringan terdesentralisasi (Savadatti dkk., 2025).

Karakteristik utama DLT meliputi replikasi data pada banyak *node*, ketahanan terhadap perubahan data melalui mekanisme kriptografi, serta kemampuan verifikasi oleh partisipan jaringan. Karakteristik tersebut membuat DLT banyak digunakan sebagai infrastruktur untuk pencatatan transaksi, penyimpanan referensi data, dan eksekusi aturan terprogram melalui *smart contract* (Savadatti dkk., 2025). Dalam konteks sistem rekam medis elektronik terdesentralisasi, DLT dapat digunakan untuk mendukung pencatatan data yang dapat diverifikasi tanpa menempatkan seluruh kendali pada satu pihak terpusat.

II.2.2 IOTA

IOTA merupakan salah satu implementasi DLT yang dirancang untuk mendukung transaksi pada lingkungan terdesentralisasi, khususnya pada skenario yang membutuhkan skalabilitas tinggi dan biaya transaksi rendah. Berbeda dari *blockchain* konvensional, IOTA menggunakan struktur DAG yang dikenal sebagai

Tangle sebagai dasar buku besar terdistribusinya (Sedi Nzakuna dkk., 2025). Pada perkembangannya, IOTA mengalami perubahan arsitektur melalui IOTA Rebased. Perubahan ini bertujuan meningkatkan skalabilitas, desentralisasi, dan kemampuan ekosistem IOTA untuk mendukung aplikasi terdesentralisasi, termasuk penggunaan *smart contract* (Sedi Nzakuna dkk., 2025). IOTA menggunakan *Move smart contract* untuk berinteraksi dengan data dan melakukan transaksi.

II.3 InterPlanetary File System (IPFS)

IPFS adalah protokol *peer-to-peer* dan sistem *file* terdistribusi untuk menyimpan serta membagikan data secara desentralisasi (Benet, 2014). Berbeda dari penyimpanan tradisional yang bergantung pada *server* pusat, IPFS mengidentifikasi setiap *file* berdasarkan hash kriptografi dari kontennya (*Content Identifier/CID*), bukan berdasarkan lokasi penyimpanan. Konten dicari melalui *Distributed Hash Table* (DHT), dibagi menjadi blok-blok yang tersebar di berbagai *node*, dan dapat diakses dari *node* terdekat yang menyimpannya. Pendekatan *content addressing* ini mengurangi ketergantungan pada satu titik kegagalan pusat dan relevan bagi DecMed sebagai penyimpanan *off-chain* untuk data RME terenkripsi.

II.4 Proxy Re-Encryption (PRE)

Proxy Re-Encryption adalah skema kriptografi yang memungkinkan pihak ketiga (disebut proxy) mengubah suatu *ciphertext* yang awalnya dienkripsi untuk satu pengguna menjadi *ciphertext* baru yang bisa didekripsi oleh pengguna lain, tanpa pernah membuka *plaintext* dan tanpa memegang kunci privat kedua pihak. Teknik ini dipakai untuk mendelegasikan hak dekripsi secara aman, misalnya pada skenario berbagi data terenkripsi di *cloud*. PRE pertama kali diperkenalkan oleh Blaze et al. (Blaze dkk., 1998) sebagai solusi untuk mendelegasikan hak dekripsi secara aman.

Gambaran simulasi dari PRE dapat dilihat pada Gambar II.1. Dalam PRE, pemilik data (misalnya Alice) mengenkripsi datanya dengan kunci publik miliknya dan menyimpannya di server atau cloud. Ketika Alice ingin memberi akses ke Bob, ia membuat *re-encryption key* dari kunci miliknya dan kunci Bob, lalu memberikannya ke proxy agar proxy bisa mengubah *ciphertext* milik Alice menjadi *ciphertext* yang

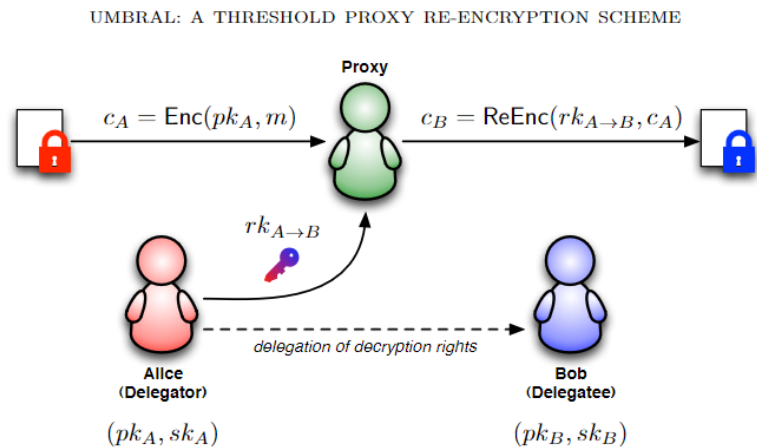
dapat didekripsi Bob, tanpa pernah melihat isi datanya.

II.4.1 Umbral PRE

Umbral adalah skema *threshold proxy re-encryption* yang memungkinkan pemilik data mendelegasikan hak dekripsi kepada penerima akses melalui satu atau beberapa proxy *semi-trusted* (Nuñez, 2017). Dalam Umbral, pihak yang memberikan akses disebut *delegator*, pihak yang menerima akses disebut *delegatee*, sedangkan proxy bertugas melakukan re-enkripsi tanpa mengetahui isi data. Berbeda dengan PRE sederhana yang dapat menggunakan satu *re-encryption key*, Umbral membagi kemampuan re-enkripsi ke dalam beberapa *key fragments* atau kfrag. Dengan pendekatan ini, proses re-enkripsi dapat dibuat berbasis ambang batas, misalnya minimal t dari total n fragmen harus digunakan agar akses dekripsi dapat berhasil.

Pada tahap awal, data dienkripsi menggunakan kunci publik milik *delegator*. Hasil enkripsi pada Umbral terdiri atas *ciphertext* dan *capsule*. *Ciphertext* berisi data terenripsi, sedangkan *capsule* memuat informasi kriptografis yang diperlukan untuk membuka kunci enkripsi data. Ketika *delegator* ingin memberi akses kepada *delegatee*, *delegator* membuat sejumlah kfrag berdasarkan kunci privat miliknya, kunci publik milik *delegatee*, dan parameter ambang batas yang ditentukan. Fragmen tersebut kemudian diberikan kepada proxy agar proxy dapat melakukan re-enkripsi terhadap *capsule*.

Ketika *delegatee* ingin mengakses data, *delegatee* mengambil *ciphertext* dan



Gambar II.1: Gambaran simulasi dari PRE (Nuñez, 2017)

capsule, lalu meminta proxy menghasilkan *capsule fragment* atau *cfrag* dari *kfrag* yang dimiliki proxy. Proxy hanya melakukan transformasi kriptografis terhadap *capsule*; proxy tidak mendekripsi *ciphertext*, tidak mengetahui *plaintext*, dan tidak membutuhkan kunci privat *delegator* maupun *delegatee*. Setelah *delegatee* memperoleh jumlah *cfrag* valid yang memenuhi ambang batas *t*, *delegatee* dapat membuka *capsule* menggunakan kunci privatnya, memperoleh kunci simetris, lalu mendekripsi *ciphertext*. Dengan demikian, Umbral memungkinkan delegasi hak dekripsi tanpa membagikan kunci privat dan tanpa memberikan akses langsung terhadap isi data kepada proxy.

II.5 Kontrol Akses

II.5.1 Definisi Kontrol Akses

Kontrol Akses adalah proses pengaturan akses ke sumber daya (data, sistem informasi, perangkat, atau area tertentu) (Li dkk., 2022; Sandhu & Samarati, 1994). Proses ini memutuskan apakah seorang subjek harus diberikan atau ditolak aksesnya berdasarkan aturan tertentu. Akses dapat berarti memakai, memasuki, atau menggunakan. Kontrol Akses bertujuan untuk mencegah aktivitas yang dapat menimbulkan pelanggaran keamanan seperti kebocoran data atau modifikasi tidak sah.

II.5.2 Kontrol Akses Granular

Kontrol akses granular atau *fine-grained access control* memungkinkan keputusan otorisasi pada cakupan yang lebih spesifik dibandingkan pemberian izin secara umum. Jika kontrol akses kasar (*coarse-grained*) hanya membedakan akses berdasarkan kategori besar seperti *role*, kontrol akses granular mempertimbangkan dimensi subjek, objek data, operasi, dan kondisi atau konteks akses (Hu dkk., 2014; Odugu & Rajesh, 2021). Pendekatan ini sejalan dengan prinsip *least privilege*, yaitu pemberian hak sebatas yang diperlukan untuk menjalankan tugas tertentu (Joint Task Force Transformation Initiative, 2020). Pada Tugas Akhir ini, perluasan kontrol akses dimaknai sebagai penerapan model *policy* yang memperluas batasan dari *role* dan *purpose* menjadi kombinasi subjek, objek data, jenis operasi, waktu berlaku, kondisi akses, dan batasan delegasi. Elemen keputusan akses diuraikan

lebih lanjut pada Subbab II.5.4.

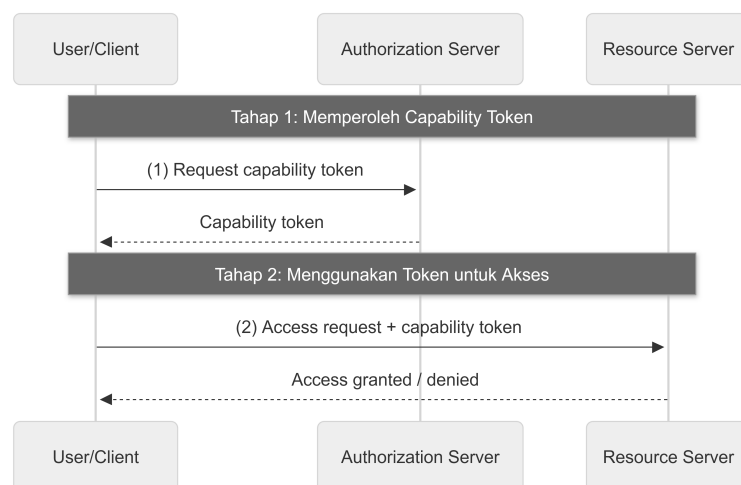
II.5.3 Model CapBAC

Capability-Based Access Control (CapBAC) adalah model kontrol akses yang hak aksesnya direpresentasikan sebagai "*capability token*" yang tidak dapat dipalsukan (Anagnostopoulou dkk., 2025; Li dkk., 2022). Token tersebut menyatakan otoritas untuk melakukan operasi tertentu terhadap objek atau sumber daya tertentu. Dalam implementasi tertentu, *capability token* juga dapat dibatasi dengan identitas subjek, waktu berlaku, cakupan operasi, atau kondisi tambahan lain untuk mempersempit hak akses yang diberikan.

Secara garis besar, model CapBAC bekerja dalam 2 tahapan, (1) Pengguna meminta *capability token* dari sebuah *Authorization Server*, kemudian (2) Pengguna menggunakan *capability token* yang diperoleh dari tahap pertama untuk melakukan akses ke *Resource Server* (Li dkk., 2022). *Sequence diagram* dari model CapBAC dapat dilihat pada Gambar II.2. CapBAC memungkinkan otorisasi terdesentralisasi karena mengandalkan token kapabilitas yang tidak dapat dipalsukan sebagai bukti.

II.5.4 Policy-Based Access Control

Policy-Based Access Control (PBAC) merupakan pendekatan kontrol akses yang menentukan keputusan otorisasi berdasarkan sekumpulan *policy* eksplisit (Ferraiolo dkk., 2015). PBAC tidak selalu diposisikan sebagai model yang



Gambar II.2: *Sequence diagram* dari model CapBAC. (Dokumentasi penulis)

sepenuhnya terpisah dari *Role-Based Access Control* (RBAC) atau *Attribute-Based Access Control* (ABAC). Peran dan atribut dapat digunakan sebagai bagian dari pertimbangan *policy*. Perbedaannya terletak pada cara keputusan akses dirumuskan: pada RBAC hak akses terutama diperoleh dari peran pengguna, sedangkan pada PBAC keputusan ditentukan melalui evaluasi aturan yang dapat menggabungkan peran, atribut, konteks, tujuan, dan batasan lainnya. Secara umum, suatu *policy* akses dalam PBAC melibatkan elemen-elemen berikut:

1. **Subjek** Subjek merupakan entitas yang mengajukan permintaan akses, seperti pengguna, aplikasi, atau layanan.
2. **Sumber daya**

Sumber daya merupakan objek yang akan diakses. Sumber daya dapat dikelompokkan berdasarkan kategori, pemilik, tingkat sensitivitas, atau fungsi data.

3. **Tindakan**

Tindakan menyatakan operasi yang akan dilakukan terhadap sumber daya, seperti *read* atau *write*.

4. **Konteks**

Konteks merupakan kondisi tambahan ketika permintaan akses dilakukan.

5. **Tujuan penggunaan**

Tujuan penggunaan menjelaskan alasan suatu data diakses. Dua *request* dari subjek yang sama terhadap sumber daya yang sama dapat menghasilkan keputusan berbeda apabila memiliki tujuan penggunaan yang berbeda.

6. **Keputusan dan kewajiban**

Hasil evaluasi *policy* umumnya berupa keputusan *permit* atau *deny*. *Policy* juga dapat menetapkan kewajiban yang harus dijalankan ketika akses diberikan.

Berdasarkan elemen-elemen tersebut, suatu permintaan akses dapat direpresentasikan sebagai:

$$q = \langle s, r, a, c, p \rangle, \quad (\text{II.1})$$

dengan s sebagai subjek, r sebagai *resource*, a sebagai *action*, c sebagai *context*, dan p sebagai *purpose*. Keputusan akses diberikan dengan mengevaluasi permintaan tersebut terhadap *policy*. Secara sederhana, keputusan akses dapat dinyatakan sebagai:

$$\text{Decision}(q) = \begin{cases} \text{Permit,} & \text{jika seluruh kondisi } \textit{policy} \text{ yang berlaku terpenuhi,} \\ \text{Deny,} & \text{jika terdapat kondisi wajib yang tidak terpenuhi.} \end{cases} \quad (\text{II.2})$$

Penerapan PBAC meliputi pendefinisian *policy*, pembentukan konteks permintaan, evaluasi terhadap *policy* yang berlaku, serta penegakan keputusan pada sumber daya yang dilindungi. *Policy Machine* merupakan kerangka formal untuk merepresentasikan *policy* melalui elemen *policy*, hubungan penugasan, dan asosiasi antareleman, termasuk pola berbasis peran, atribut, atau tujuan penggunaan (Ferraiolo dkk., 2015). Kerangka tersebut diadaptasi pada perancangan model kontrol akses DecMed di bab selanjutnya.

II.6 Token Otorisasi

II.6.1 JSON Web Token

JSON Web Token (JWT) adalah format token yang ringkas dan *URL-safe* untuk merepresentasikan klaim yang dipertukarkan antara dua pihak (M. B. Jones dkk., 2015). JWT terdiri dari *header*, *payload*, dan *signature* yang dikodekan Base64URL dan dipisahkan tanda titik. *Payload* membawa klaim seperti identitas, peran, cakupan akses, dan waktu kedaluwarsa, sedangkan *signature* menjamin integritas token. Dari sisi model otorisasi, JWT berperan sebagai pembawa klaim.

II.6.2 PASETO

PASETO atau *Platform-Agnostic Security Tokens* adalah alternatif JWT dengan pemilihan algoritma kriptografi yang lebih terarah berdasarkan versi dan tujuan

penggunaan token (Arciszewski & Haussmann, 2022). Token PASETO berbentuk `version.purpose.message[.footer]`, dengan `purpose` berupa `local` (enkripsi simetris) atau `public` (tanda tangan kunci publik). Desain yang lebih *opinionated* ini mengurangi risiko kesalahan konfigurasi algoritma.

II.6.3 Macaroons

Macaroon adalah *credential* otorisasi berbasis *bearer* yang mendukung delegasi terdesentralisasi dalam sistem terdistribusi (Birgisson dkk., 2014). Keunggulan utama Macaroon terletak pada penggunaan *chained-HMAC*, yang memungkinkan proses delegasi bersifat terdesentralisasi secara efisien serta mendukung penambahan syarat *caveat* yang sesuai dengan konteks penggunaan. Berbeda dari JWT dan PASETO, batasan akses tidak hanya ditetapkan saat penerbitan, tetapi dapat dipersempit kemudian oleh pemegang token.

Sebuah Macaroon M didefinisikan dengan struktur:

$$M = (id, location, \vec{c}, sig)$$

id adalah pengidentifikasi unik, $location$ adalah alamat layanan target, $\vec{c} = (c_1, c_2, \dots, c_n)$ adalah daftar *caveat*, dan sig adalah tanda tangan (Birgisson dkk., 2014). Tanda tangan (sig) dihitung secara rekursif untuk menjamin integritas setiap penambahan batasan (*caveat*):

$$sig_0 = \text{HMAC}(\text{RootKey}, id)$$

$$sig_n = \text{HMAC}(sig_{n-1}, c_n)$$

RootKey adalah kunci rahasia yang digunakan untuk membangkitkan token Macaroon awal. Struktur ini memungkinkan pemegang Macaroon menambahkan *caveat* baru c_{new} (misalnya: `time < 24h`) dan menghasilkan sig_{new} untuk diberikan ke pihak lain, tanpa mengetahui *RootKey* yang asli. Kemampuan untuk menambahkan batasan baru pada token secara lokal tanpa melibatkan penerbit awal ini disebut dengan *offline attenuation*. Gambaran mengenai delegasi dan atenuasi

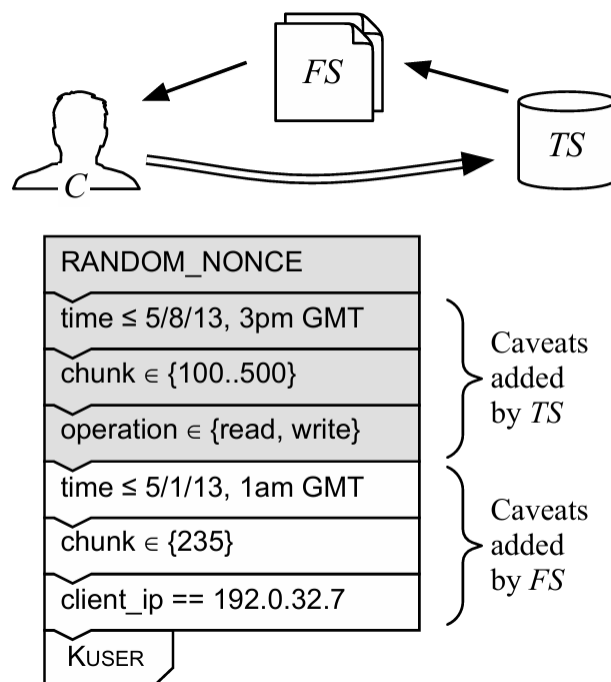
kewenangan melalui *caveats* dapat dilihat pada Gambar II.3. Pada pengembangan DecMed di bab selanjutnya, sifat konseptual tersebut dibedakan dari pembentukan token turunan yang dimediasi *Server PRE*.

II.6.4 Biscuit Token

Biscuit adalah token otorisasi berbasis *capability* yang mendukung verifikasi terdesentralisasi, atenuasi *offline*, dan penegakan *policy* berbasis *logic language* (Eclipse Biscuit Project, nodate). Token diverifikasi menggunakan kunci publik penerbit; pemegang dapat menambahkan blok batasan baru sebelum mendelegasikan akses. Karakteristik utamanya adalah ekspresi otorisasi sebagai *fact*, *rule*, dan *check* yang dievaluasi bersama *policy* lokal *verifier*. Biscuit lebih ekspresif untuk *policy* kompleks dibanding Macaroons.

II.7 DecMed

Sistem DecMed adalah sebuah kerangka kerja manajemen RME terdesentralisasi yang dibangun di atas DLT IOTA (Sadewa, 2025). Pengembangan sistem ini



Gambar II.3: Contoh delegasi dan atenuasi kewenangan pada Macaroon. C memegang Macaroon yang diturunkan dari *service* FS untuk mengakses data pada *service* TS dengan batasan waktu, lokasi IP, dan target data yang spesifik. (Birgisson dkk., 2014)

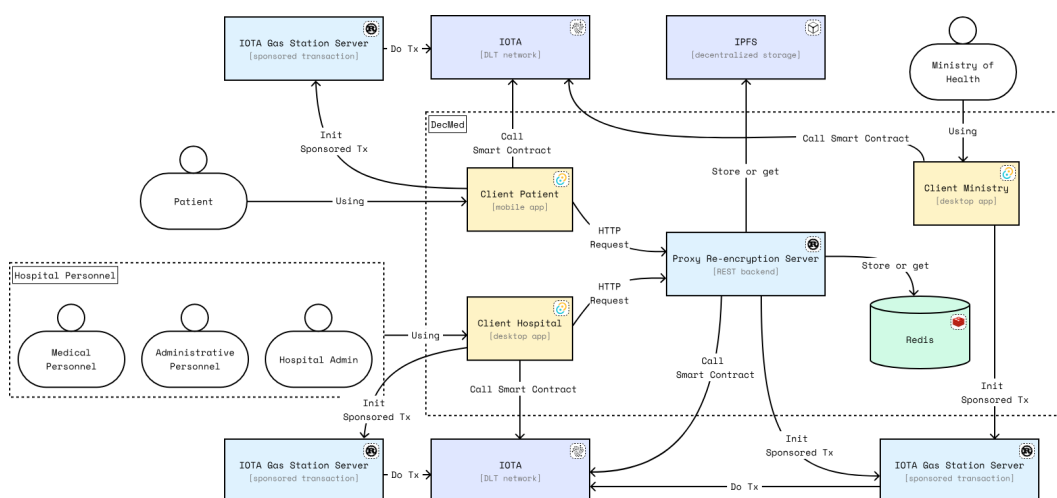
bertujuan untuk mengatasi tantangan fragmentasi data antarinstansi kesehatan dan risiko keamanan dari penyimpanan terpusat yang ada di Indonesia.

II.7.1 Arsitektur DecMed

Arsitektur DecMed membagi penyimpanan menjadi dua lapisan, yaitu penyimpanan *on-chain* dan *off-chain*. Penyimpanan *off-chain* memanfaatkan IPFS untuk menyimpan data klinis pasien yang terenkripsi. Sementara itu, penyimpanan *on-chain* memanfaatkan DLT IOTA untuk menyimpan data administratif dan metadata klinis, termasuk CID dari IPFS, guna menjamin integritas data. Untuk memastikan kedaulatan data pasien, DecMed mengimplementasikan CapBAC yang diintegrasikan dengan PRE. Skema PRE yang diterapkan pada DecMed adalah Umbral PRE yang dijelaskan pada Subbab II.4.1. Komponen utama pada arsitektur DecMed dan fungsinya dijelaskan pada Tabel II.1.

II.7.2 Alur Pengelolaan dan Akses RME pada DecMed

Alur pengelolaan RME pada DecMed dimulai ketika data medis dibuat melalui aplikasi *hospital client*. Data tersebut dienkripsi terlebih dahulu di sisi *client* sebelum disimpan pada IPFS. Setelah data terenkripsi berhasil diunggah, IPFS menghasilkan CID sebagai referensi lokasi data. CID, *capsule key*, dan metadata pendukung kemudian dicatat pada DLT IOTA. Dengan demikian, IOTA tidak menyimpan isi rekam medis secara langsung, melainkan menyimpan metadata yang diperlukan untuk menemukan, memverifikasi, dan membuka data terenkripsi



Gambar II.4: Arsitektur DecMed (Sadewa, 2025).

Tabel II.1: Komponen, aktor, dan fungsi dalam arsitektur DecMed

Komponen / Aktor	Fungsi
IOTA DLT	Menyimpan metadata, referensi data, dan status akses
IPFS	Menyimpan <i>encrypted blob</i> data RME
PRE	Melakukan verifikasi token akses dan <i>re-encryption</i> agar penerima akses dapat membuka data tanpa kunci privat pasien
Redis	Mengelola <i>cache ephemeral</i> (Nonce, Re-Encryption Key, dan Revoked Key)
<i>Patient Client</i>	Digunakan pasien untuk mengelola identitas, menyimpan atau memperbarui data, serta memberi akses
<i>Hospital Client</i>	Digunakan tenaga kesehatan / fasyankes untuk mengakses atau memperbarui RME sesuai hak akses
<i>Ministry Client</i>	Digunakan pemerintah untuk mengelola registrasi atau verifikasi fasyankes
<i>IOTA Gas Station</i>	Mensponsori transaksi <i>on-chain</i> agar pengguna tidak perlu membayar <i>gas</i> secara langsung; pada Tugas Akhir ini diasumsikan sebagai bagian dari IOTA

melalui mekanisme PRE.

Ketika pasien memberikan akses kepada tenaga kesehatan, PRE menerbitkan token kapabilitas yang digunakan sebagai bukti otorisasi. Penerima akses membawa token tersebut ketika meminta data melalui *Hospital Client*. *Server* PRE kemudian memverifikasi token, melakukan *re-encryption* terhadap *capsule key*, dan mengembalikan material kriptografis yang diperlukan agar *Hospital Client* dapat membuka data terenkripsi sesuai hak akses yang diberikan. *Sequence Diagram* yang menjelaskan alur pemberian akses dapat dilihat pada Lampiran B.

II.8 Pemodelan Ancaman STRIDE

STRIDE merupakan metode *threat modeling* yang dikembangkan oleh Microsoft untuk mengidentifikasi ancaman keamanan pada sistem perangkat lunak sejak tahap perancangan. Metode ini mengelompokkan ancaman ke dalam enam kategori utama dan biasanya digunakan bersama *Data Flow Diagram* (DFD) untuk memetakan ancaman terhadap komponen sistem, aliran data, penyimpanan data, dan batas kepercayaan (*trust boundary*) (Microsoft, 2006; Shostack, 2014). Tabel II.2 merangkum kategori tersebut beserta fokus keamanan yang terkait.

Tabel II.2: Kategori ancaman pada STRIDE

Kategori	Fokus Keamanan	Deskripsi Singkat
<i>Spoofing</i>	Otentikasi	Pemalsuan identitas entitas untuk memperoleh akses tidak sah.
<i>Tampering</i>	Integritas	Modifikasi data, pesan, atau kode secara tidak sah.
<i>Repudiation</i>	<i>Non-repudiation</i>	Penyangkalan terhadap tindakan atau transaksi karena kurangnya bukti audit.
<i>Information Disclosure</i>	Kerahasiaan	Kebocoran informasi sensitif kepada pihak yang tidak berhak.
<i>Denial of Service</i>	Ketersediaan	Gangguan terhadap ketersediaan layanan atau sumber daya sistem.
<i>Elevation of Privilege</i>	Otorisasi	Perolehan hak akses yang lebih tinggi dari yang seharusnya.

II.9 Penelitian Terkait

Bagian ini meninjau beberapa penelitian yang relevan dengan perancangan kontrol akses berbasis *policy* pada sistem RME berbasis DLT serta representasi kapabilitas menggunakan Macaroons.

II.9.1 Hybrid RBAC dan ABAC pada Sistem RME Berbasis Blockchain

Singh dkk. mengusulkan model kontrol akses hibrida untuk sistem RME berbasis Blockchain dengan menggabungkan RBAC dan ABAC (Singh dkk., 2025). Penelitian ini berangkat dari keterbatasan dua model tersebut ketika digunakan secara terpisah. RBAC dinilai terlalu kaku karena keputusan akses hanya bergantung pada peran pengguna dan berpotensi menimbulkan *role explosion*. ABAC lebih fleksibel karena mempertimbangkan atribut pengguna, objek, dan konteks, namun kompleksitas pengelolaan *policy*-nya meningkat.

Penelitian tersebut menunjukkan bahwa semakin banyak atribut yang digunakan dalam ABAC, semakin besar pula kemungkinan konflik *policy* dan beban evaluasi aturan (Singh dkk., 2025). Oleh karena itu, penulis mengusulkan pendekatan *hybrid*: RBAC sebagai lapisan awal penyaringan peran, sedangkan ABAC menambahkan batasan kontekstual yang lebih rinci. Hasil evaluasi pada *smart contract* menunjukkan pendekatan ini relatif efisien dari sisi konsumsi *gas* dibandingkan ABAC murni.

II.9.2 Model Kontrol Akses Empat Lapis untuk RME Berbasis Blockchain

Liu dan Chen meneliti model kontrol akses untuk RME berbasis Blockchain dengan menempatkan RME sebagai kasus *big data* (Liu & Chen, 2025). Penelitian ini mengusulkan model otorisasi empat lapis yang terdiri dari:

1. *Role Check* menggunakan RBAC,
2. *Identity Verification* menggunakan *Identity-Based Encryption* (IBE),
3. *Policy Execution* menggunakan *smart contract*, dan
4. *Data Volume Check* menggunakan pendekatan *entropy*.

Kontribusi utama penelitian ini bagi Tugas Akhir adalah justifikasi bahwa DLT dapat memperkuat integritas data, jejak audit, dan distribusi kendali pada pengelolaan RME, meskipun fokusnya belum pada mekanisme delegasi akses di lingkungan klinis kolaboratif.

II.9.3 Kontrol Akses Granular Menggunakan *Composable NFT*

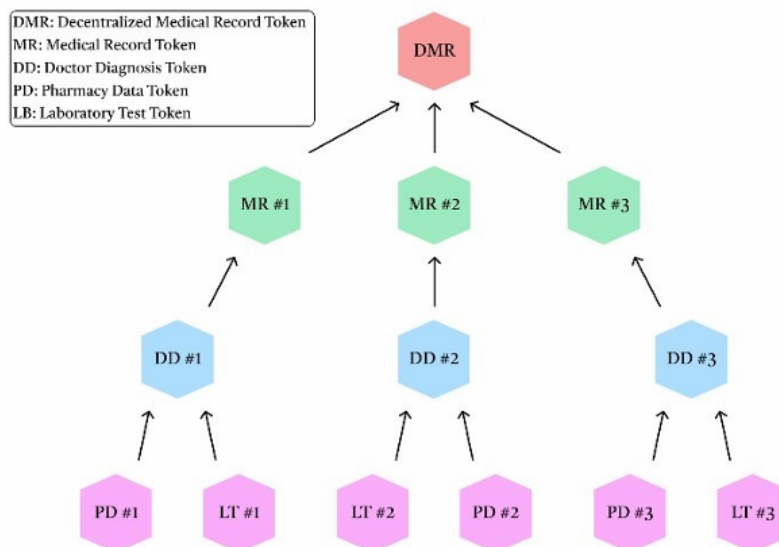
Amaracitra mengusulkan model *Decentralized Medical Record* (DMR) yang menggunakan *composable NFT* untuk mencapai keamanan data, interoperabilitas, dan privasi melalui akses data yang granular (Amaracitra & Alamsyah, 2025). Nilai utama penelitian ini terletak pada pemecahan data RME menjadi unit-unit yang lebih kecil, sehingga tidak seluruh data pasien harus dibuka dalam satu paket akses.

Dalam model tersebut, struktur data DMR disusun secara hierarkis ke dalam *DMR Token* sebagai token induk, *Medical Record Token*, *Doctor Diagnoses Token*, *Laboratory Test Token*, dan *Pharmacy Data Token*. Ilustrasi struktur tersebut dapat dilihat pada Gambar II.5.

Pemisahan ini menunjukkan bahwa granularitas akses tidak hanya bergantung pada mekanisme otorisasi, tetapi juga pada cara data medis dimodelkan sejak awal (Amaracitra & Alamsyah, 2025). Dengan struktur seperti ini, akses dapat diberikan hanya pada bagian data yang relevan dengan kebutuhan tenaga kesehatan tertentu.

II.9.4 Implementasi Macaroons untuk Delegasi Akses pada Sistem Nyata

Selain diperkenalkan secara teoretis, Macaroons juga telah digunakan pada sistem penyimpanan terdistribusi. Storj memakai Macaroons sebagai *API key* pada jaringan Tardigrade untuk membatasi operasi (*read*, *write*, *delete*, *list*) serta ruang lingkup berdasarkan *bucket*, *path*, dan jendela waktu akses (Leffew, 2019). dCache, sistem penyimpanan data ilmiah berskala besar, memakai Macaroons sebagai *bearer token* dengan *caveats* seperti *activity*, *before*, *ip*, *path*, dan *root*; beberapa *caveat* dapat dikombinasikan melalui irisan agar token turunan hanya mempersempit hak akses (dCache, nodate). Kedua kasus tersebut menunjukkan bahwa Macaroons praktis untuk membatasi dan mendelegasikan akses pada penyimpanan terdistribusi melalui atenuasi berbasis *caveats*.



Gambar II.5: Ilustrasi struktur data DMR menggunakan composable NFT. (Amaracitra & Alamsyah, 2025)

BAB III

ANALISIS DAN RANCANGAN SOLUSI

III.1 Analisis Masalah

Dalam mengembangkan mekanisme kontrol akses berbasis *policy* dan delegasi pada kerangka kerja DecMed, diperlukan analisis terhadap implementasi dan arsitektur sistem yang sudah ada. Hasil analisis tersebut digunakan sebagai dasar identifikasi permasalahan serta perumusan kebutuhan sistem yang diusulkan pada Tugas Akhir ini.

Analisis masalah pada Tugas Akhir ini diawali dengan analisis terhadap implementasi dan arsitektur DecMed pada Subbab III.1.1, termasuk analisis STRIDE dan skenario layanan kesehatan kolaboratif. Hasil analisis tersebut kemudian digunakan sebagai dasar identifikasi permasalahan pada Subbab III.1.2 dan perumusan kebutuhan sistem pada Subbab III.1.3.

III.1.1 Analisis Sistem DecMed

Sebagaimana dijelaskan pada Bab II.7, DecMed adalah kerangka kerja manajemen RME terdesentralisasi dengan menggunakan DLT IOTA sebagai penyimpanan *on-chain*, IPFS sebagai penyimpanan *off-chain*, serta PRE untuk mendukung distribusi akses data yang aman. Arsitektur ini sudah memberikan fondasi untuk menjaga integritas data dan mengurangi ketergantungan pada penyimpanan terpusat. Terdapat tiga aktor utama pada DecMed, yaitu:

1. Pasien
2. Staf fasyankes, terdiri dari tenaga kesehatan, petugas rekam medis, dan admin fasyankes
3. Pemerintah, yaitu Kementerian Kesehatan

Pada DecMed, masing-masing aktor memiliki kepentingan dan aplikasi *client* yang berbeda. *Patient Client* digunakan oleh pasien, *Hospital Client* digunakan

oleh tenaga kesehatan di sebuah fasyankes, dan *Ministry Client* digunakan oleh pemerintah. Detail kebutuhan fungsional DecMed untuk memenuhi kebutuhan masing-masing aktor dapat dilihat pada Lampiran C.

III.1.1.1 Keterbatasan Token Kapabilitas DecMed

Model kontrol akses yang digunakan pada sistem DecMed adalah model CapBAC. Token otorisasi berupa JWT digunakan sebagai media yang merepresentasikan kapabilitas akses. Pada kerangka kerja DecMed, ketika pasien memberikan akses terhadap RME mereka kepada seorang tenaga kesehatan, maka PRE akan menerbitkan token JWT sesuai dengan *request* dari pasien. Token yang diterbitkan oleh pasien membawa klaim seperti pada Kode III.1. Dalam implementasi DecMed sebelumnya, token JWT masih bersifat *coarse-grained*. Penentuan hak akses pengguna dilakukan hanya berdasarkan *role* dan *purpose* yang ada pada token yang disertakan saat melakukan *request* ke PRE. Token tersebut belum dirancang untuk membawa batasan kontekstual, misalnya jenis data yang boleh diakses. Padahal, pada praktik pelayanan kesehatan, setiap tenaga kesehatan tidak selalu membutuhkan keseluruhan isi RME pasien sesuai dengan prinsip *need-to-know*. Kondisi ini menunjukkan bahwa DecMed belum memiliki model *policy* akses yang cukup luas untuk menghubungkan aktor, objek RME, hak akses, dan kondisi akses secara terstruktur.

```
1  #[derive(Debug, Deserialize, Serialize)]
2  pub struct JwtClaims {
3      pub address: String, // address IOTA pemegang token
4      pub role: AuthRole, // AdministrativePersonnel
5      // atau MedicalPersonnel
6      pub purpose: ReencryptionPurposeType, // Read atau Update
7  }
```

Kode III.1: Struktur klaim JWT pada DecMed

Dengan struktur klaim tersebut, DecMed hanya mampu membedakan kategori umum pengguna dan jenis operasi, tanpa mendefinisikan *policy* akses yang menghubungkan aktor, objek RME, hak akses, dan kondisi secara lebih luas.

III.1.1.2 Keterbatasan Segmentasi Data pada DecMed

Pada kerangka kerja DecMed, data RME pasien disimpan dalam dua sistem penyimpanan yang berbeda, yaitu penyimpanan *on-chain* (IOTA) dan *off-chain* (IPFS). Penyimpanan *on-chain* digunakan untuk menyimpan metadata dan CID dari data yang disimpan di *off-chain*. Penyimpanan *off-chain* digunakan untuk menyimpan data administratif dan klinis yang terenkripsi. Pemisahan ini sesuai dengan kebutuhan yang dibahas pada II.1.2 terkait dokumentasi administratif dan klinis.

Pada penyimpanan *on-chain*, data RME pasien direpresentasikan sebagai metadata dalam sebuah *struct* `MedicalMetadata` untuk data klinis. Metadata tersebut menyimpan CID serta informasi kunci terenkripsi yang digunakan dalam proses dekripsi data medis terkait. Struktur penyimpanannya terikat dengan *struct* `PatientAccount` dan `PatientMedicalMetadata` pada Kode III.2.

```
1 public struct PatientAccount has store {
2     ...
3     medical_metadata: TableVec<PatientMedicalMetadata>,
4 }
5 public struct PatientMedicalMetadata has copy, drop, store {
6     index: u64,
7     metadata: String,
8 }
```

Kode III.2: Struktur metadata medis pasien pada DecMed

Karena *field* `medical_metadata` pada *struct* `PatientAccount` menyimpan daftar metadata klinis pasien, akses terhadap struktur ini memungkinkan sistem memperoleh referensi menuju objek data klinis terenkripsi, seperti CID dan *capsule* untuk PRE. CID dan *capsule* tidak secara langsung membuka isi RME karena data klinis tetap disimpan dalam bentuk terenkripsi. Namun, struktur metadata tersebut menunjukkan bahwa unit akses pada DecMed masih mengarah pada satu objek data klinis yang relatif besar, bukan pada segmen data yang spesifik.

Kondisi tersebut menyulitkan penegakan *policy* akses yang lebih rinci. Ketika proses *re-encryption* diberikan terhadap objek data klinis tersebut, penerima akses

berpotensi memperoleh cakupan *plaintext* yang lebih luas daripada kebutuhan aktualnya. Hal ini terjadi karena struktur metadata belum menyediakan atribut segmentasi yang cukup untuk membedakan cakupan akses sesuai kebutuhan pelayanan. Variabel metadata pada *struct* PatientMedicalMetadata merupakan serialisasi dari *struct* yang ditunjukkan pada Kode III.3.

```
1  #[derive(Debug, Deserialize, Serialize)]
2  pub struct MedicalMetadata {
3      pub capsule: String, // capsule untuk PRE re-encryption
4      pub cid: String, // pointer ke data di IPFS
5      pub created_at: String, // timestamp
6      pub enc_key_and_nonce: String, // kunci dan nonce yang
7      // terenkripsi
8  }
```

Kode III.3: Struktur serialisasi metadata medis DecMed

cid pada *struct* MedicalMetadata merupakan *pointer* ke data klinis yang sudah terenkripsi disimpan di penyimpanan *off-chain* sebagai sebuah *Encrypted Blob*. Potongan field relevan pada *struct* MedicalData dapat dilihat pada Kode III.4.

```
1  pub struct MedicalData {
2      pub anamnesis: String,
3      pub physical_check: String,
4      pub psychological_check: String,
5      pub diagnose: String,
6      pub therapy: String,
7  }
```

Kode III.4: Potongan struktur data medis *off-chain* pada DecMed

Penyimpanan data klinis pada DecMed hanya berfokus pada dataset rawat jalan. Pada *struct* MedicalData, data klinis masih disimpan dengan format yang sederhana, tanpa kategorisasi yang jelas. DecMed memang sudah memisahkan penyimpanan metadata di *on-chain* dan data klinis di *off-chain*, tetapi pendekatan tersebut belum secara eksplisit menunjukkan segmentasi data klinis yang cukup rinci untuk menegakkan *policy* akses yang lebih luas. Jika data klinis masih

dikelola sebagai objek terenkripsi yang terlalu besar, pemberian akses kepada tenaga kesehatan berisiko membuka data di luar kebutuhan klinisnya. Sebagai contoh, seorang perawat tidak membutuhkan akses tulis ke data therapy pada *struct MedicalData* karena yang berhak menentukan terapi adalah dokter.

III.1.1.3 Analisis Skenario Layanan Kesehatan Kolaboratif

Kebutuhan akan perluasan *policy* akses dan delegasi berantai menjadi lebih jelas ketika arsitektur DecMed ditempatkan pada skenario layanan kesehatan yang nyata. Dalam alur pelayanan rumah sakit, pasien tidak hanya berinteraksi dengan satu pihak, tetapi dengan beberapa aktor yang memiliki kebutuhan akses berbeda pada tahap yang berbeda pula sebagaimana dibahas pada Subbab II.1.3. Oleh karena itu, satu skenario layanan kesehatan kolaboratif dimodelkan untuk menunjukkan secara konkret mengapa mekanisme akses pada DecMed saat ini belum memadai.

Skenario yang dianalisis adalah pelayanan pasien rawat jalan dan rawat inap yang melibatkan petugas rekam medis, perawat, dokter penanggung jawab pasien, petugas laboratorium, dan apoteker. Alur tersebut dipilih karena mewakili pola kolaborasi yang umum terjadi di sebuah fasyankes.

1. **Tahap pendaftaran pasien.** Saat pasien datang ke rumah sakit, petugas rekam medis hanya membutuhkan akses terhadap data administratif pasien.
2. **Tahap pemeriksaan awal oleh perawat.** Setelah proses pendaftaran selesai, perawat memerlukan hak untuk menulis data klinis untuk anamnesis awal, pemeriksaan fisik, dan pemeriksaan psikologis.
3. **Tahap pemeriksaan oleh dokter.** Pada tahap ini, dokter penanggung jawab pasien memerlukan hak baca terhadap keseluruhan data RME pasien dan hak tulis untuk pelayanan saat ini.
4. **Tahap rujukan internal ke laboratorium.** Apabila dokter membutuhkan pemeriksaan laboratorium, maka pasien perlu diarahkan ke petugas laboratorium. Dalam tahap ini, petugas laboratorium hanya membutuhkan akses terhadap data administratif pasien dan permintaan pemeriksaan laboratorium.
5. **Tahap tindak lanjut hasil pemeriksaan.** Setelah hasil laboratorium

Tabel III.1: Pemetaan Aktor dan Kebutuhan Akses pada Skenario Layanan Kesehatan Kolaboratif

Aktor	Jenis Akses	Cakupan Data yang Dibutuhkan
Petugas Rekam Medis	Baca data administratif	Data administratif pasien.
Perawat	Baca dan tulis data klinis (hanya pemeriksaan awal)	Baca data administratif pasien. Tulis data anamnesis awal, pemeriksaan fisik, dan pemeriksaan psikologis.
Dokter	Baca dan tulis data klinis	Baca keseluruhan RME pasien. Tulis data sesuai konteks pelayanan saat ini.
Petugas Laboratorium	Baca dan tulis terbatas (hanya data laboratorium)	Baca data administratif pasien dan permintaan pemeriksaan penunjang. Tulis data laboratorium.
Apoteker	Baca dan tulis terbatas (hanya data apotek)	Baca data administratif pasien dan data terapi. Tulis data peresepan dan <i>dispensing</i> .

tersedia, dokter kembali menggunakan data tersebut sebagai bahan pengambilan keputusan klinis.

6. **Tahap pemberian resep oleh apotek.** Setelah dokter memberikan resep, apotek memerlukan hak untuk membaca data resep dan mengunggah data obat yang diresepkan.

Berdasarkan skenario tersebut, kebutuhan akses setiap aktor dapat diringkas pada Tabel III.1.

Tabel III.1 juga menunjukkan bahwa kelompok tenaga kesehatan tidak dapat diperlakukan sebagai satu kelompok akses tunggal. Dokter, perawat, petugas laboratorium, dan apoteker sama-sama terlibat dalam pelayanan klinis, tetapi memiliki kewenangan baca dan tulis yang berbeda. Oleh karena itu, penggunaan role umum seperti *MedicalPersonnel* yang digunakan pada DecMed saat ini belum cukup untuk menentukan hak akses tulis secara aman, karena sistem tetap perlu membedakan fungsi klinis masing-masing aktor.

Alur pemberian akses terhadap data RME pasien oleh pasien kepada tenaga kesehatan pada DecMed sebelumnya dapat dilihat pada Lampiran B. Pada alur tersebut, pasien harus memilih satu tenaga kesehatan lalu menerbitkan akses untuk penerima tersebut. Implementasi DecMed sebelumnya tidak memiliki mekanisme delegasi antart tenaga kesehatan. Sehingga ketika akses perlu diberikan kepada lebih dari satu tenaga kesehatan, proses yang sama perlu diulang dari awal untuk masing-masing penerima akses.

Dalam skenario tersebut, keterbatasan DecMed tampak secara operasional. Model token kapabilitas yang statis menyulitkan proses pembatasan akses secara bertahap sesuai perpindahan peran di lapangan. Selain itu, pemberian akses hanya dapat dilakukan secara individual dari pasien kepada satu tenaga kesehatan pada satu waktu, sehingga proses otorisasi menjadi tidak efektif ketika layanan melibatkan beberapa tenaga kesehatan sekaligus. Pasien perlu memberikan akses kepada dokter utama dan petugas laboratorium secara terpisah, padahal proses tersebut dapat dibuat lebih efisien apabila dokter utama dapat mendelegasikan sebagian hak aksesnya kepada petugas laboratorium tanpa perlu intervensi langsung dari pasien. Dokter perlu dapat mendelegasikan sebagian hak akses saja, misalnya akses terhadap permintaan pemeriksaan dan hak tulis hasil laboratorium tanpa ikut membuka seluruh riwayat klinis pasien.

Dengan demikian, skenario layanan kesehatan kolaboratif ini memperlihatkan bahwa tiga persoalan penelitian saling berkaitan: sistem memerlukan model *policy* akses yang lebih luas agar setiap aktor hanya memperoleh data yang relevan, segmentasi data *off-chain* agar *policy* tersebut dapat ditegakkan secara teknis, dan delegasi antartenant kesehatan agar perpindahan hak akses dapat berlangsung efisien tanpa intervensi ulang dari pasien dan tanpa penerbitan token baru.

III.1.1.4 Analisis STRIDE pada Sistem DecMed

Analisis STRIDE digunakan untuk mengevaluasi implikasi keamanan dari arsitektur DecMed saat ini ketika ditempatkan pada skenario layanan kesehatan kolaboratif yang menjadi fokus analisis. Berdasarkan pembahasan pada Subbab II.8, tahapan awal pemodelan ancaman menggunakan STRIDE adalah mengidentifikasi komponen dan alur kerja sistem yang menjadi target ancaman. Identifikasi tersebut dilakukan melalui penggambaran DFD yang menunjukkan aliran data dan komunikasi antarkomponen sistem. Pada analisis ini, DFD Level 0 dan Level 1 dimodelkan. Pemodelan ke level lebih lanjut tidak dilakukan karena pemodelan hingga level 1 sudah cukup untuk mengidentifikasi komponen dari DecMed dan alur data antarkomponen. Hasil pemodelan DFD dapat dilihat pada Lampiran D.

Berdasarkan arsitektur DecMed pada Gambar II.4 dan DFD pada Lampiran D, *attack surface* utama sistem mencakup *Patient Client*, *Hospital Client*, *Ministry*

Client, data pada lapisan *on-chain*, data terenkripsi pada lapisan *off-chain*, Redis PRE, jaringan IOTA, IOTA *Gas Station*, serta token kapabilitas yang mengatur otorisasi akses. Hasil identifikasi ancaman berdasarkan metode STRIDE terhadap komponen utama pada DecMed dapat dilihat pada Lampiran E.

Berdasarkan hasil analisis STRIDE pada Tabel E.1, ancaman yang paling relevan terhadap fokus analisis adalah *spoofing* (T01), *tampering* (T02 dan T03), *information disclosure* (T05 dan T06), dan *elevation of privilege* (T08). Ancaman-ancaman tersebut secara langsung berkaitan dengan kebutuhan akan model *policy* akses yang lebih luas, segmentasi data *off-chain*, dan mekanisme delegasi yang mampu membatasi hak akses secara bertahap. Ancaman *repudiation* (T04) tetap relevan terhadap kebutuhan audit delegasi, tetapi diposisikan sebagai implikasi pendukung karena fokus utama berada pada perluasan *policy* akses dan delegasi. Ancaman T03 dan T06 ditangani secara terbatas melalui kebutuhan nonfungsional KNF-TA-07 dan KNF-TA-08, yaitu deteksi modifikasi *ciphertext* *off-chain* dan ketiadaan *payload* klinis plaintext pada metadata *on-chain*. Ancaman *denial of service* (T07) tidak dijadikan masalah yang diselesaikan ataupun diuji, karena tidak termasuk dalam fokus terkait model *policy* akses, segmentasi data, dan mekanisme delegasi antartena kesehatan.

Dengan demikian, hasil analisis STRIDE memperkuat bahwa keterbatasan pada model kontrol akses dan delegasi DecMed tidak hanya merupakan persoalan fungsional, tetapi juga memiliki implikasi keamanan yang nyata. Oleh karena itu, diperlukan mekanisme otorisasi yang mampu mendukung pembatasan akses yang lebih rinci dan aman pada sistem rekam medis elektronik terdesentralisasi

III.1.1.5 Analisis Mekanisme Penggunaan dan Revokasi Token

Pada implementasi DecMed sebelumnya, kapabilitas akses ditentukan oleh kepemilikan token dan klaim yang dibawa oleh token tersebut. Setiap operasi pembacaan maupun penulisan data RME dilakukan melalui *request* yang menyertakan token akses. Komponen PRE kemudian memvalidasi token dengan mengacu pada hak akses yang tercatat pada penyimpanan *on-chain* IOTA. Validasi ini digunakan untuk memastikan bahwa *address* IOTA yang tercantum pada klaim token memiliki hak akses yang sesuai pada penyimpanan *on-chain* dan hak akses tersebut masih berlaku. Dengan demikian, identitas aktor pada DecMed

sebelumnya diperlakukan sebagai klaim *address* yang dicocokkan ke status hak akses *on-chain*, tanpa pembuktian kriptografis bahwa pengirim *request* menguasai *wallet* terkait kepada *Server PRE*. Struktur klaim token ditunjukkan pada Kode III.1.

Mekanisme tersebut masih memiliki keterbatasan karena validasi berfokus pada klaim yang dibawa token, bukan pada pembuktian bahwa pengirim *request* benar-benar merupakan pemilik *address* yang tercantum pada klaim. Jika token akses diperoleh oleh pihak lain, misalnya melalui kebocoran atau pencurian token, pihak tersebut dapat mengirimkan *request* dengan klaim *address* yang masih valid. Kondisi ini membuat token dapat digunakan oleh aktor yang tidak berwenang selama klaim di dalam token masih diterima oleh sistem. Oleh karena itu, diperlukan mekanisme tambahan agar penggunaan token diikat dengan bukti kepemilikan *wallet* yang diverifikasi oleh *Server PRE*, sementara penyimpanan *on-chain* tetap berperan sebagai sumber status hak akses dan atribut kelembagaan, bukan sebagai verifikator bukti *wallet*.

Selain verifikasi terhadap pengguna token, mekanisme pencabutan hak akses juga perlu diperhatikan. Pada DecMed, pasien dapat mencabut hak akses sebelum masa berlaku akses berakhir. Proses pencabutan dilakukan melalui *patient client* dengan mengirimkan *request* revokasi ke *PRE*. Setelah diterima, status revokasi dicatat pada Redis dan penyimpanan *on-chain* IOTA agar akses yang telah dicabut tidak lagi diterima oleh sistem.

Apabila mekanisme delegasi akses ditambahkan, sebagaimana dibutuhkan pada skenario layanan kesehatan kolaboratif di fasilitas pelayanan kesehatan pada Subbab III.1.1.3, mekanisme revokasi tidak cukup hanya menangani token awal. Token hasil delegasi juga perlu diperhitungkan, termasuk hubungan antara token induk dan token turunannya. Dengan demikian, pencabutan akses dapat diterapkan tidak hanya terhadap akses yang diberikan langsung oleh pasien, tetapi juga terhadap akses yang muncul melalui proses delegasi.

III.1.2 Identifikasi Masalah

Berdasarkan analisis terhadap arsitektur DecMed pada Subbab III.1.1, sejumlah masalah diidentifikasi agar DecMed dapat mendukung kontrol akses berbasis *policy*

yang lebih luas dan delegasi antartena kesehatan. Permasalahan utama terdiri atas tiga aspek. Pertama, kontrol akses DecMed masih bersifat *coarse-grained* karena keputusan akses terutama ditentukan oleh *role* dan *purpose*, sehingga belum mencakup hubungan *policy* yang lebih luas antara aktor, objek RME, hak akses, dan kondisi akses. Kedua, data RME pada penyimpanan *off-chain* belum direpresentasikan sebagai objek akses yang tersegmentasi sehingga pembatasan akses sulit ditegakkan pada unit data spesifik. Ketiga, alur pemberian akses DecMed masih bergantung pada keterlibatan langsung pasien sehingga belum mendukung delegasi antaraktor dalam proses layanan kesehatan yang kolaboratif.

Selain tiga masalah utama tersebut, terdapat beberapa masalah turunan yang perlu diperhatikan agar rancangan solusi dapat ditegakkan secara aman. Delegasi antaraktor harus dibatasi agar hak akses turunan tidak melebihi hak akses induknya. Perbedaan data klinis yang dapat diakses oleh masing-masing aktor juga perlu diperhitungkan karena *role* umum seperti *MedicalPersonnel* belum cukup untuk membedakan kewenangan dokter, perawat, petugas laboratorium, dan apoteker. Selain itu, karena delegasi dapat membentuk rantai akses, mekanisme pencabutan dan audit pada DecMed perlu diperluas agar dapat mencakup akses turunan. Penggunaan token akses juga perlu dikaitkan dengan pembuktian identitas aktor pada rantai delegasi agar token tidak hanya diperlakukan sebagai *bearer token* yang dapat digunakan oleh pihak yang tidak semestinya.

Agar keterhubungan antara analisis masalah, ancaman keamanan, kebutuhan sistem, rancangan, implementasi, dan pengujian dapat ditelusuri, permasalahan tersebut dirinci menggunakan ID M-TA pada Tabel III.2.

Berdasarkan Tabel III.2, keterbatasan DecMed tidak hanya dipandang sebagai persoalan format token, tetapi sebagai rangkaian masalah yang saling bergantung. M-TA-01, M-TA-02, dan M-TA-03 merupakan masalah inti yang masing-masing berkaitan dengan kebutuhan kontrol akses berbasis *policy* yang lebih luas, segmentasi objek data RME, dan delegasi antaraktor. Sementara itu, M-TA-04, M-TA-05, M-TA-06, dan M-TA-07 merupakan masalah turunan atau implikasi yang perlu diselesaikan agar ketiga masalah inti tersebut dapat ditangani secara aman. M-TA-04 menekankan perlunya pembatasan hak akses turunan, M-TA-05 menekankan perlunya pembedaan kewenangan berdasarkan aktor, M-TA-06 menekankan perlunya perluasan pencabutan dan audit terhadap rantai delegasi,

Tabel III.2: Identifikasi Masalah DecMed

ID	Masalah	Dasar Analisis
M-TA-01	Kontrol akses DecMed masih bersifat <i>coarse-grained</i> karena belum mendefinisikan <i>policy</i> yang menghubungkan aktor, objek RME, hak akses, dan kondisi secara lebih luas.	III.1.1.1, T02, T05
M-TA-02	Data RME belum direpresentasikan sebagai objek akses yang tersegmentasi.	III.1.1.2, T03, T05, T06
M-TA-03	Alur pemberian akses belum mendukung delegasi antaraktor dalam layanan kolaboratif.	III.1.1.3
M-TA-04	Delegasi antaraktor memerlukan mekanisme atenuasi.	III.1.1.3, T05, T08
M-TA-05	<i>Role</i> MedicalPersonnel terlalu umum untuk membedakan kewenangan antaraktor.	III.1.1.3, T02, T05
M-TA-06	Mekanisme revokasi dan audit akses perlu diperluas agar mencakup akses turunan pada rantai delegasi.	III.1.1.5, T04, T08
M-TA-07	Token akses belum secara eksplisit membuktikan kepemilikan identitas aktor pada rantai delegasi.	III.1.1.5, T01

sedangkan M-TA-07 menekankan perlunya pembuktian identitas aktor pada rantai delegasi. ID masalah tersebut kemudian digunakan sebagai dasar pemetaan kebutuhan, rancangan, implementasi, dan pengujian pada bagian selanjutnya.

III.1.3 Kebutuhan Sistem

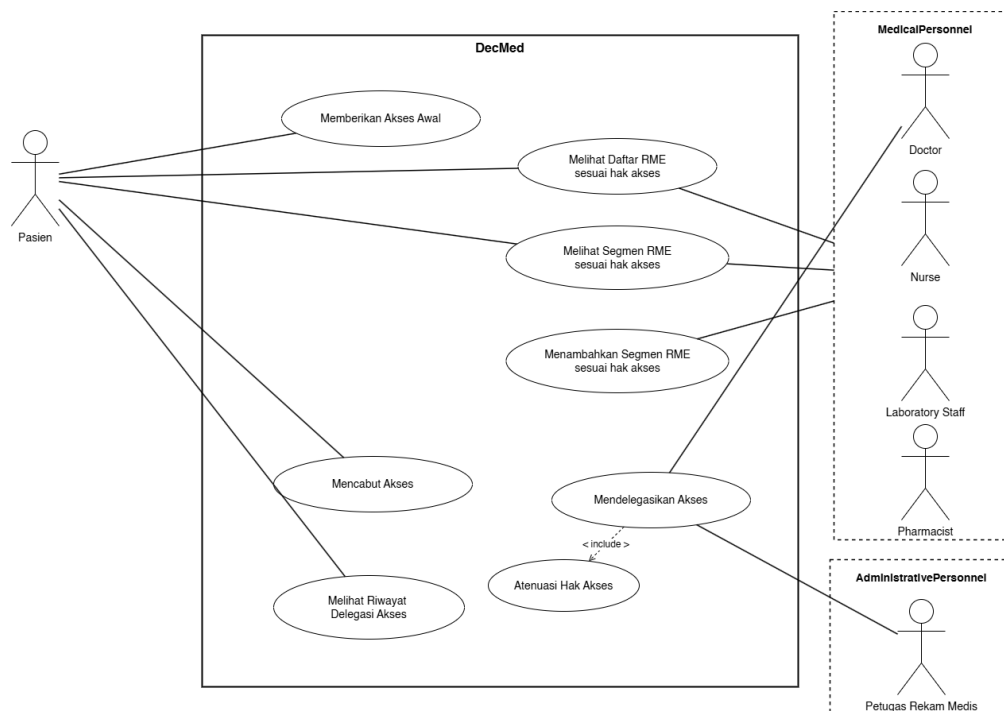
Berdasarkan masalah yang telah dipetakan pada Tabel III.2, kebutuhan sistem pada Tugas Akhir ini dirumuskan sebagai perluasan terhadap kebutuhan DecMed sebelumnya. Kebutuhan ini tidak dimaksudkan untuk menggantikan fungsi dasar DecMed, melainkan untuk memastikan bahwa sistem dapat mendukung kontrol akses berbasis *policy* yang lebih luas, segmentasi data RME, delegasi berantai, revokasi akses turunan, audit delegasi, dan pembuktian identitas aktor pada rantai delegasi.

Kebutuhan sistem dibagi menjadi kebutuhan fungsional dan kebutuhan nonfungsional. Kebutuhan fungsional menjelaskan kemampuan yang harus disediakan oleh sistem dari sudut pandang aktor dan proses bisnis layanan kesehatan. Sementara itu, kebutuhan nonfungsional menjelaskan batasan kualitas dan keamanan yang harus dipenuhi dalam penerapan mekanisme kontrol akses dan delegasi.

III.1.3.1 Kebutuhan Fungsional

Kebutuhan fungsional tambahan dirumuskan dari sudut pandang aktor, sama seperti pola pada kebutuhan fungsional DecMed pada Lampiran C. Perumusan berbasis aktor digunakan untuk memperjelas pihak yang dapat menerima akses, jenis data yang dapat diakses, operasi yang dapat dilakukan, serta batasan akses yang harus ditegakkan. Batasan tersebut mencakup pasien, episode RME, dataset, fungsi klinis, aksi akses, waktu berlaku, penerima delegasi, dan kedalaman delegasi.

Hubungan antara aktor dan kemampuan sistem tersebut dimodelkan melalui *Use Case Diagram* pada Gambar III.1. Diagram tersebut menjadi dasar pendefinisian kebutuhan fungsional tambahan pada Tugas Akhir ini. Aktor yang terlibat meliputi pasien, tenaga kesehatan (*Doctor, Nurse, Laboratory Staff, dan Pharmacist*), serta petugas rekam medis. *Use case* yang dimodelkan mencakup pemberian akses awal, pencabutan akses, peninjauan riwayat delegasi, pembacaan daftar dan segmen RME sesuai hak akses, penambahan segmen RME sesuai hak akses, serta delegasi akses yang mencakup atenuasi hak akses.



Gambar III.1: *Use Case Diagram* Kebutuhan Fungsional Tambahan DecMed

Tabel III.3: Kebutuhan Fungsional Tambahan DecMed

ID	Deskripsi
KF-TA-01	Pasien dapat memberikan akses awal kepada petugas rekam medis sesuai konteks layanan kesehatan.
KF-TA-02	Pasien dapat mencabut akses awal dan akses turunannya yang telah diberikan.
KF-TA-03	Pasien dapat melihat riwayat akses dan delegasi terhadap RME miliknya.
KF-TA-04	Petugas rekam medis dapat mendelegasikan akses terbatas kepada perawat dan dokter sesuai cakupan akses.
KF-TA-05	Dokter dapat membaca dan menulis segmen klinis sesuai cakupan akses dan konteks pelayanan.
KF-TA-06	Dokter dapat mendelegasikan akses terbatas kepada tenaga laboratorium dan apoteker sesuai cakupan akses.
KF-TA-07	Perawat dapat membaca data yang relevan dan menulis segmen klinis pemeriksaan awal sesuai cakupan akses.
KF-TA-08	Petugas laboratorium dapat membaca data yang relevan dan menulis segmen klinis terkait pemeriksaan laboratorium sesuai cakupan akses.
KF-TA-09	Apoteker dapat membaca data yang relevan dan menulis segmen klinis terkait pelayanan obat sesuai cakupan akses.

Berdasarkan Gambar III.1, setiap *use case* dipetakan menjadi kebutuhan fungsional dengan ID KF-TA. Rangkuman kebutuhan fungsional tambahan DecMed ditunjukkan pada Tabel III.3.

Pemetaan *use case* pada Gambar III.1 terhadap kebutuhan fungsional pada Tabel III.3 adalah sebagai berikut. *Use case* Memberikan Akses Awal dipetakan ke KF-TA-01, Mencabut Akses ke KF-TA-02, dan Melihat Riwayat Delegasi Akses ke KF-TA-03. *Use case* Mendelegasikan Akses yang dilakukan oleh petugas rekam medis dan dokter dipetakan ke KF-TA-04 dan KF-TA-06. Relasi <<include>> terhadap Atenuasi Hak Akses menunjukkan bahwa setiap delegasi wajib membatasi hak akses turunan agar tidak melebihi cakupan induknya. Sementara itu, *use case* pembacaan dan penambahan segmen RME sesuai hak akses dipetakan ke KF-TA-05 hingga KF-TA-09 berdasarkan kewenangan masing-masing aktor tenaga kesehatan.

Kebutuhan fungsional dengan ID KF-TA-01 merupakan penyesuaian dari F06 dan F07 pada Lampiran C. Penyesuaian ini diperlukan karena dalam skenario layanan kesehatan kolaboratif, akses awal terhadap RME hanya diberikan langsung oleh pasien kepada petugas rekam medis. Kemudian hak akses tersebut dapat didelegasikan secara terbatas kepada aktor tenaga kesehatan yang terlibat dalam

Tabel III.4: Kebutuhan Nonfungsional Tambahan DecMed

ID	Deskripsi
KNF-TA-01	Sistem harus menjaga kerahasiaan data RME dengan memastikan bahwa penerima akses hanya dapat memperoleh <i>plaintext</i> dari segmen yang sesuai dengan cakupan otorisasinya.
KNF-TA-02	Sistem harus memastikan integritas token otorisasi dan menolak perluasan batasan akses ketika delegasi.
KNF-TA-03	Sistem harus menolak permintaan akses jika token, rantai delegasi, atau bukti kepemilikan identitas aktor pemohon tidak valid.
KNF-TA-04	Sistem menyediakan keterlacakan delegasi dengan mencatat informasi delegasi.
KNF-TA-05	Sistem harus menolak akses untuk hak akses yang dicabut.
KNF-TA-06	Sistem harus memverifikasi keterikatan bukti kepemilikan identitas terhadap aktor pada rantai delegasi, token akses, dan konteks permintaan akses.
KNF-TA-07	Sistem harus memverifikasi integritas data RME terenkripsi <i>off-chain</i> dengan menolak <i>blob</i> yang hash integritasnya tidak cocok dengan metadata.
KNF-TA-08	Sistem harus memastikan metadata <i>on-chain</i> tidak menyimpan <i>payload</i> klinis dalam bentuk <i>plaintext</i> .

proses pelayanan, seperti dokter, perawat, petugas laboratorium, dan apoteker.

KNF-TA-02 juga merupakan penyesuaian dari F09 pada Lampiran C. Penyesuaian ini terkait dengan mekanisme revokasi akses pada skenario layanan kesehatan kolaboratif. Dalam skenario tersebut, pasien memerlukan kemampuan untuk mencabut akses awal dan akses turunannya yang telah didelegasikan.

III.1.3.2 Kebutuhan Nonfungsional

Selain kebutuhan fungsional, sistem juga memiliki kebutuhan nonfungsional untuk memastikan bahwa mekanisme kontrol akses berbasis *policy* dan delegasi berantai dapat diterapkan secara aman. Kebutuhan nonfungsional pada Tugas Akhir ini difokuskan pada aspek keamanan, keterlacakan, dan kompatibilitas dengan arsitektur DecMed.

KNF-TA-07 dan KNF-TA-08 dirumuskan secara terbatas dari ancaman STRIDE T03 dan T06 pada Tabel E.1. KNF-TA-07 menuntut deteksi modifikasi *ciphertext* melalui hash integritas, sedangkan KNF-TA-08 menuntut ketiadaan *payload* klinis *plaintext* pada metadata *on-chain*. KNF-TA-08 tidak dimaksudkan sebagai kebutuhan privasi menyeluruh terhadap keterbukaan identitas atau relasi pada metadata transaksi.

Tabel III.5: Pemetaan Masalah terhadap Kebutuhan Sistem

ID Masalah	Kebutuhan Fungsional	Kebutuhan Nonfungsional
M-TA-01	KF-TA-01, KF-TA-04–KF-TA-09	KNF-TA-01, KNF-TA-02, KNF-TA-03
M-TA-02	KF-TA-05, KF-TA-07, KF-TA-08, KF-TA-09	KNF-TA-01, KNF-TA-07, KNF-TA-08
M-TA-03	KF-TA-01, KF-TA-04, KF-TA-06	KNF-TA-04
M-TA-04	KF-TA-04, KF-TA-06	KNF-TA-02, KNF-TA-03
M-TA-05	KF-TA-05, KF-TA-07, KF-TA-08, KF-TA-09	KNF-TA-01, KNF-TA-03
M-TA-06	KF-TA-02, KF-TA-03	KNF-TA-04, KNF-TA-05
M-TA-07	<i>Tidak ada</i>	KNF-TA-03, KNF-TA-06

III.1.3.3 Pemetaan Masalah terhadap Kebutuhan Sistem

Setelah kebutuhan fungsional dan nonfungsional dirumuskan, masalah yang telah diidentifikasi dipetakan terhadap kebutuhan sistem yang diusulkan. Pemetaan ini digunakan untuk memastikan bahwa setiap masalah memiliki kebutuhan yang menanganinya. Hasil pemetaan masalah terhadap kebutuhan sistem ditunjukkan pada Tabel III.5.

Kebutuhan fungsional dan nonfungsional tambahan tersebut menjadi dasar bagi perancangan solusi pada tahap berikutnya.

III.2 Analisis Solusi

DecMed sudah memiliki fondasi untuk sistem RME terdesentralisasi melalui IOTA, IPFS, dan PRE. Solusi yang dianalisis pada bagian ini diarahkan untuk memperluas kontrol akses melalui *policy* yang lebih komprehensif dan memfasilitasi delegasi akses antartentaga kesehatan.

Berdasarkan kebutuhan sistem pada Subbab III.1.3, analisis disusun dalam urutan berikut. Pertama, model PBAC mendefinisikan bentuk *policy* akses. Kedua, segmentasi data RME menyediakan objek yang dapat diberi *policy* granular. Ketiga, token Macaroons merepresentasikan *policy* tersebut melalui *caveats*. Keempat, mekanisme delegasi menurunkan hak akses dengan cakupan yang lebih terbatas. Kelima, PRE mendukung distribusi kemampuan dekripsi kepada penerima akses yang sah, tanpa menggantikan keputusan otorisasi yang ditentukan oleh *policy* dan token. Analisis ini menjadi dasar pemilihan pendekatan sebelum rancangan teknis

Tabel III.6: Analisis Pendekatan Pemodelan *Policy* Akses

Pendekatan	Keunggulan	Keterbatasan
Kontrol akses berbasis <i>role</i>	Sederhana dan sesuai dengan struktur <i>role</i> pengguna yang telah terdapat pada DecMed.	Belum dapat membatasi akses berdasarkan pasien, episode RME, kategori dataset, kategori fungsi klinis, waktu berlaku, dan rantai delegasi.
Perancangan <i>caveat</i> secara langsung	Batasan akses dapat langsung direpresentasikan dalam token kapabilitas tanpa membentuk model <i>policy</i> tersendiri.	Hubungan antara aktor, objek, hak akses, dan kondisi akses tidak dimodelkan secara eksplisit sehingga ketertelusuran <i>policy</i> terhadap kebutuhan sistem menjadi lebih sulit.
PBAC dengan adaptasi elemen <i>Policy Machine</i>	Dapat memisahkan pengguna, atribut pengguna, objek, atribut objek, hak akses, relasi penugasan, dan asosiasi hak akses secara terstruktur.	Membutuhkan pemetaan tambahan dari model konseptual ke token otorisasi, metadata segmen, dan fungsi verifikasi pada titik penegakan akses.

dijelaskan pada Subbab III.3.

III.2.1 Analisis Pendekatan PBAC

Hasil analisis masalah menunjukkan bahwa kontrol akses pada DecMed tidak cukup ditentukan hanya berdasarkan *role* dan *purpose* yang terdapat pada token JWT. Klaim tersebut dapat membedakan kategori umum pengguna dan operasi yang dilakukan, tetapi belum merepresentasikan pasien yang datanya diakses, episode RME, kategori dataset, kategori fungsi klinis, masa berlaku akses, maupun batasan delegasi. Selain itu, *role* `MedicalPersonnel` pada DecMed masih terlalu umum untuk membedakan kewenangan dokter, perawat, petugas laboratorium, dan apoteker.

Terdapat tiga pendekatan yang dipertimbangkan untuk mendefinisikan *policy* akses pada pengembangan DecMed. Perbandingan pendekatan tersebut ditunjukkan pada Tabel III.6.

Pendekatan berbasis *role* saja tidak dipilih karena keputusan akses pada DecMed tidak hanya bergantung pada profesi atau kedudukan pengguna. Sebagai contoh, dua pengguna dengan *subrole* dokter tidak selalu memiliki akses terhadap pasien dan episode RME yang sama. Demikian pula, petugas laboratorium yang terlibat dalam satu episode pelayanan tidak memerlukan akses terhadap seluruh data klinis

pasien. Peran pengguna tetap diperlukan untuk merepresentasikan kewenangan kelembagaan, tetapi belum cukup untuk menjadi satu-satunya dasar keputusan akses.

Perancangan *caveat* secara langsung sebenarnya dapat digunakan untuk merepresentasikan kapabilitas pada token. Namun, pendekatan tersebut hanya menjelaskan bentuk token dan belum memberikan model konseptual yang menghubungkan kebutuhan aktor, objek RME, serta hak akses. Tanpa model *policy*, setiap *caveat* berisiko dipandang sebagai aturan yang berdiri sendiri dan hubungan antara token, segmentasi data, serta validasi *role* menjadi kurang jelas.

Berdasarkan pertimbangan tersebut, pendekatan *Policy-Based Access Control* digunakan dengan mengadaptasi elemen inti *Policy Machine*. *Policy Machine* menyediakan struktur untuk merepresentasikan pengguna, atribut pengguna, objek, atribut objek, kelas *policy*, hak akses, relasi penugasan, dan asosiasi hak akses sesuai dengan penjelasan pada II.5.4. Struktur tersebut sesuai dengan kebutuhan DecMed karena pengguna dapat dikelompokkan berdasarkan *role* atau *subrole*, sedangkan segmen RME dapat dikelompokkan secara hierarkis berdasarkan rumah sakit, pasien, episode RME, kategori dataset, dan kategori fungsi klinis.

Model *policy* yang dibutuhkan DecMed mencakup beberapa dimensi berikut.

1. **Aktor akses**, yaitu alamat *wallet* aktor pemohon beserta *role* atau *subrole* yang tercatat pada sistem.
2. **Pemilik dan konteks data**, yaitu pasien, rumah sakit, dan episode RME yang menjadi cakupan akses.
3. **Objek akses**, yaitu segmen RME yang diklasifikasikan menggunakan *dataset_category* dan *function_category*.
4. **Operasi akses**, yaitu operasi Read atau Update terhadap segmen RME.
5. **Kondisi akses**, yaitu masa berlaku token, validitas identitas aktor pada rantai delegasi, status revokasi, dan kesesuaian rantai delegasi.
6. **Batasan delegasi**, yaitu ketentuan bahwa token turunan tidak boleh memiliki cakupan data, operasi, masa berlaku, atau kemampuan delegasi yang melebihi token induknya.

Model PBAC menjawab keterbatasan kontrol *coarse-grained* melalui perluasan *policy* akses dari batasan *role* dan *purpose* menjadi hubungan antara aktor, objek, hak akses, dan kondisi.

III.2.2 Analisis Segmentasi Data RME

Setelah bentuk *policy* PBAC ditetapkan pada Subbab III.2.1, penegakan *policy* granular tetap bergantung pada struktur data yang dilindungi. Sesuai analisis pada Subbab III.1.1.2, jika data RME disimpan sebagai satu *encrypted blob*, pemberian akses terhadap blob tersebut dapat membuka seluruh isi data meskipun aktor hanya membutuhkan sebagian informasi. Pemrosesan data pada DecMed perlu disesuaikan agar objek *policy* tersedia pada unit yang lebih kecil.

Alternatif pertama yang dipertimbangkan adalah pemfilteran setelah data klinis diambil dari penyimpanan *off-chain*. Pada pendekatan ini, data tetap disimpan sebagai satu *encrypted blob*, kemudian sistem memilih bagian data yang boleh ditampilkan berdasarkan hak akses pengguna. Pendekatan ini kurang sesuai dengan karakteristik DecMed. IPFS tidak menyediakan mekanisme pencarian atau pemfilteran isi data secara langsung. Selain itu, DecMed menyimpan data dalam bentuk terenkripsi, sehingga isi data baru dapat diproses setelah didekripsi. Jika pemfilteran dilakukan di *client*, maka keseluruhan *plaintext* data klinis sudah terbuka terlebih dahulu sebelum batas akses diterapkan.

Alternatif yang dipilih adalah segmentasi data klinis sebelum data disimpan pada penyimpanan *off-chain*. Pada pendekatan ini, data klinis dipisahkan menjadi beberapa segmen. Setiap segmen memiliki metadata yang disimpan pada penyimpanan *on-chain*. Metadata tersebut digunakan oleh sistem untuk memilih segmen yang sesuai dengan cakupan akses sebelum data diambil dari IPFS. Dengan cara ini, proses pengambilan data menjadi lebih terarah karena sistem hanya mengambil segmen yang relevan dengan hak akses pengguna.

Penentuan kategori segmentasi tidak dilakukan secara arbitrer. Opsi pertama adalah mengikuti pembagian data pada penelitian terkait yang dibahas pada Subbab II.9.3. Namun, pembagian tersebut kurang sesuai dijadikan dasar segmentasi karena ditujukan untuk pembuktian konseptual, bukan untuk merepresentasikan struktur data pelayanan medis. Oleh karena itu, rancangan segmentasi mengacu pada KMK

1423/2022 tentang Pedoman Variabel dan Metadata pada Penyelenggaraan Rekam Medis Elektronik yang telah dibahas pada Subbab II.1.2.

Berdasarkan pedoman tersebut, data RME dapat dibedakan berdasarkan *dataset* pelayanan. Dalam cakupan yang dianalisis, *dataset category* yang digunakan meliputi: Rawat Jalan, Rawat Inap, Laboratorium, dan Apotek. Pembagian berdasarkan *dataset* pelayanan dipilih karena setiap layanan memiliki jenis data dan kebutuhan akses yang berbeda. Sebagai contoh, petugas laboratorium membutuhkan akses tulis terhadap *dataset* laboratorium, sedangkan apoteker membutuhkan akses tulis terhadap *dataset* apotek. Dengan pemisahan ini, sistem dapat membedakan konteks layanan sebelum menentukan segmen data yang dapat dibaca atau ditulis oleh aktor.

Selain berdasarkan *dataset*, data klinis juga disegmentasi berdasarkan kategori fungsi klinis. *Function category* digunakan untuk membedakan fungsi data di dalam suatu *dataset*, seperti anamnesis, pemeriksaan fisik, pemeriksaan penunjang, diagnosis, persetujuan tindakan, atau terapi. Metadata fungsi klinis digunakan untuk menentukan apakah suatu segmen data relevan dengan peran dan kebutuhan akses tenaga kesehatan.

Kombinasi *dataset category* dan *function category* dipilih agar segmentasi tidak terlalu kasar seperti pemisahan per dokumen penuh, tetapi juga tidak terlalu rinci hingga tingkat *field*. Segmentasi hingga tingkat *field* akan membuat kontrol akses bergantung pada setiap elemen data yang tersimpan. Pendekatan tersebut tidak dipilih karena kebutuhan akses pada rancangan ini cukup hingga bisa membedakan cakupan data yang diakses setiap aktornya, sesuai dengan prinsip *need to know*.

Sebagai contoh, Formulir Umum / Asesmen Awal Rawat Jalan dapat dipetakan ke fungsi klinis seperti anamnesis, pemeriksaan fisik, dan pemeriksaan psikologi. Sementara itu, Pemeriksaan Spesialistik dapat dipetakan ke fungsi klinis seperti riwayat penggunaan obat, rencana rawat, instruksi medik dan keperawatan, pemeriksaan penunjang, diagnosis, persetujuan tindakan, dan terapi. Pemetaan lengkap kategori fungsi klinis dapat dilihat pada Lampiran A.

Melalui pendekatan ini, data *off-chain* tidak lagi diperlakukan sebagai satu objek besar, tetapi sebagai kumpulan segmen klinis dengan metadata yang terdefinisi. Segmentasi tersebut menyediakan objek penegakan bagi *policy* PBAC.

III.2.3 Analisis Pemilihan Token Otorisasi

Berdasarkan model PBAC pada Subbab III.2.1 dan segmentasi data pada Subbab III.2.2, mekanisme otorisasi pada DecMed perlu mendukung representasi kapabilitas yang sesuai dengan *policy* akses serta memungkinkan atenuasi untuk delegasi terbatas. Perbandingan beberapa pendekatan token otorisasi dilakukan untuk menentukan teknologi yang paling sesuai sebagai media pembawa kapabilitas.

Alternatif token otorisasi yang dibandingkan adalah JWT, PASETO, Macaroons, dan Biscuit. JWT dipilih sebagai pembanding karena digunakan pada rancangan DecMed awal. PASETO dipilih karena memiliki tujuan penggunaan yang serupa dengan JWT, tetapi dengan kriptografi yang *opinionated*. Macaroons dianalisis sebagai kandidat utama karena menyediakan mekanisme *caveat* yang secara konseptual memungkinkan atenuasi tanpa penerbitan ulang oleh penerbit awal. Biscuit dianalisis sebagai pembanding karena mendukung verifikasi terdesentralisasi dan atenuasi serupa, tetapi menggunakan pendekatan yang lebih ekspresif melalui aturan berbasis *logic language*.

Kriteria evaluasi antartoken diturunkan dari kebutuhan sebagai berikut:

1. **Representasi kapabilitas dan batasan akses**

Menilai apakah token dapat membawa kapabilitas dan batasan yang telah ditetapkan oleh *policy* PBAC.

2. **Dukungan atenuasi untuk delegasi**

Menilai apakah batasan baru dapat ditambahkan tanpa melibatkan pasien sebagai penerbit awal, sesuai kebutuhan delegasi antartena kesehatan.

3. **Token turunan tidak memperluas hak akses**

Menganalisis jenis kunci kriptografi yang digunakan dan seberapa kuat mekanisme delegasi mencegah token turunan digunakan untuk mengakses cakupan yang lebih luas daripada token induk.

4. **Model verifikasi dan pengelolaan kunci**

Mengkaji bagaimana masing-masing token diverifikasi dan bagaimana pengelolaan kuncinya.

Tabel III.7: Perbandingan Pendekatan Token Otorisasi

Kriteria	JWT	PASETO	Macaroons	Biscuit
Representasi kapabilitas dan batasan akses	Melalui klaim	Melalui klaim	Melalui <i>caveats</i>	Melalui <i>fact</i> , <i>rule</i> , dan <i>check</i>
Atenuasi <i>offline</i>	Tidak didukung secara <i>native</i>	Tidak didukung secara <i>native</i>	Didukung melalui penambahan <i>caveat</i>	Didukung melalui penambahan <i>block logic</i>
Jaminan token turunan tidak memperluas hak akses	Bergantung pada implementasi	Bergantung pada implementasi	Ditegakkan melalui verifikasi <i>caveat</i>	Ditegakkan melalui <i>logic language</i>
Model verifikasi dan pengelolaan kunci	Kunci simetris atau asimetris	Mode lokal atau publik	Berbasis kunci simetris	Berbasis kunci asimetris
Kesesuaian ekspresivitas dengan kebutuhan DecMed	Sesuai	Sesuai	Sesuai	Lebih ekspresif
Kompleksitas integrasi	Rendah	Rendah	Sedang	Tinggi

5. Kesesuaian ekspresivitas dengan aturan akses DecMed

DecMed membutuhkan token yang dapat mengekspresikan batasan akses secara langsung sebagai atribut pada token itu sendiri.

6. Kompleksitas integrasi ke PRE

membahas tingkat kesulitan integrasi ke dalam sistem PRE sebagai penegak otoritas akses.

Tabel III.7 menunjukkan perbandingan antartoken otorisasi berdasarkan kriteria evaluasi.

JWT dan PASETO dapat digunakan untuk membawa informasi otorisasi dalam bentuk klaim, seperti identitas subjek, cakupan akses, dan waktu kedaluwarsa. Namun, keduanya tidak menyediakan mekanisme bawaan untuk menambahkan batasan baru pada token yang sudah diterbitkan. Akibatnya, delegasi hak akses yang lebih sempit tetap membutuhkan penerbitan token baru oleh pihak penerbit atau mekanisme tambahan di sisi *server*. Karakteristik tersebut kurang sesuai dengan kebutuhan delegasi antartena kesehatan yang dianalisis.

Macaroons dan Biscuit lebih dekat dengan kebutuhan karena keduanya mendukung atenuasi tanpa penerbitan ulang oleh penerbit awal. Perbedaan utama keduanya terletak pada model pembatasan dan model verifikasi. Macaroons menggunakan *caveats* pada token, sedangkan Biscuit menggunakan blok berisi *fact*, *rule*, dan *check*. Model Biscuit memberikan ekspresivitas yang lebih tinggi, tetapi kebutuhan pembatasan akses pada DecMed masih dapat direpresentasikan melalui klaim pada token, seperti identitas pasien, identitas aktor, cakupan data, aksi, dan masa berlaku. Penggunaan Biscuit dinilai menambah kompleksitas integrasi yang tidak diperlukan

untuk ruang lingkup yang dianalisis.

Dari sisi model verifikasi, Macaroons lebih sesuai karena verifikasi token pada DecMed tetap dipusatkan pada satu titik penegakan sebelum data terenkripsi diproses. Kunci verifikasi tidak perlu disebar ke banyak layanan. Biscuit lebih sesuai untuk arsitektur yang membutuhkan verifikasi oleh banyak komponen berbeda menggunakan kunci publik, sehingga tidak menjadi fokus pada DecMed.

Macaroons dipilih sebagai media pembawa kapabilitas karena menyeimbangkan representasi batasan *policy* sebagai *caveats*, dukungan atenuasi untuk delegasi terbatas, dan kompleksitas integrasi yang sesuai dengan ruang lingkup analisis.

III.2.4 Analisis Delegasi Akses Antartanaga Kesehatan

Delegasi akses antartanaga kesehatan diperlukan berdasarkan hasil analisis pada Subbab III.1.1.3 dan pemilihan Macaroons pada Subbab III.2.3. Dalam skenario DecMed sebelumnya, pasien memberikan akses kepada aktor tertentu secara langsung. Pola tersebut kurang sesuai untuk layanan klinis kolaboratif karena kebutuhan akses dapat berpindah antaraktor selama episode pelayanan berlangsung. Jika setiap perpindahan akses harus diterbitkan langsung oleh pasien, proses pelayanan menjadi bergantung pada ketersediaan pasien.

Inti fitur yang dianalisis adalah bahwa delegasi tidak melibatkan pasien kembali dan tidak memerlukan penerbitan ulang token oleh pasien. Setelah pasien memberikan akses awal, aktor yang sah dapat menurunkan hak akses yang sudah diterima kepada tenaga kesehatan lain melalui pembentukan token turunan dengan batasan yang mempersempit cakupan akses.

Macaroons secara konseptual mendukung atenuasi tanpa penerbitan ulang token oleh penerbit awal. Pada implementasi DecMed, pembentukan token turunan dilakukan melalui *Server PRE* agar token induk, identitas *delegator*, cakupan akses, dan rantai delegasi dapat diverifikasi sebelum token turunan diterbitkan. Mekanisme delegasi tidak memerlukan keterlibatan langsung pasien pada setiap pemberian akses antartanaga kesehatan, tetapi tetap memerlukan komunikasi dengan *Server PRE*.

Alternatif solusi pertama yang dipertimbangkan adalah delegasi melalui *client* dengan pencatatan hasil pada penyimpanan *on-chain*. Pada pendekatan ini,

aktor yang memiliki token induk membentuk token turunan secara lokal dengan menambahkan batasan baru, lalu membagikan token turunan melalui penyimpanan *on-chain*. Pendekatan ini mengurangi keterlibatan pasien, tetapi menjadikan *client* sebagai penentu hasil delegasi. *Client* dapat dimanipulasi sehingga sistem berpotensi mencatat delegasi yang tidak konsisten dengan hak akses induk, meskipun token turunan kemudian dapat ditolak saat digunakan.

Alternatif berikutnya melibatkan *Server PRE* sebagai komponen yang memverifikasi permintaan delegasi sebelum token turunan dibentuk. *Delegator* tetap menginisiasi delegasi melalui *client*. *Client* mengirimkan token induk, lalu token dan hak akses *delegator* diverifikasi oleh *Server PRE*. Jika permintaan dinyatakan sah, *Server PRE* membentuk token turunan dengan menambahkan batasan yang mempersempit hak akses, kemudian mengembalikannya kepada *client* untuk pencatatan pada penyimpanan *on-chain*.

Mekanisme delegasi yang dimediasi *Server PRE* dipilih. Hak akses turunan hanya dapat memiliki cakupan yang sama atau lebih sempit daripada hak akses induk. *Client* berperan sebagai inisiator dan pencatat delegasi. *Server PRE* berperan sebagai verifikator dan pembentuk token turunan. Penyimpanan *on-chain* mencatat riwayat delegasi dan bukti akses.

III.2.5 Analisis Penegakan Otoritas pada *Server PRE*

Pada DecMed, *PRE* digunakan untuk mengubah data terenkripsi dari pasien ke penerima akses tanpa membuka *plaintext*. *PRE* tidak menentukan sendiri apakah pengguna berhak mengakses data; keputusan otorisasi ditentukan oleh *policy* PBAC dan token Macaroon. *PRE* memungkinkan data atau kunci terenkripsi dibuka oleh penerima akses yang sah dan mendukung delegasi kemampuan dekripsi tanpa membagikan kunci privat pasien secara langsung.

Server PRE dipilih sebagai titik penegakan karena berada pada jalur kritis sebelum data terenkripsi diproses. Pengguna tidak memperoleh *plaintext* langsung dari penyimpanan *off-chain*, melainkan membutuhkan proses *re-encryption* yang dikendalikan oleh *PRE*. Pada jalur tersebut, *Server PRE* memverifikasi token dan atribut terkait, menolak permintaan yang tidak sah, lalu melanjutkan *re-encryption* hanya jika otorisasi valid.

III.2.5.1 Analisis Verifikasi Aktor dan Operasi Tulis

Pada DecMed sebelumnya, *role* *MedicalPersonnel* digunakan untuk merepresentasikan tenaga kesehatan klinis secara umum dan memberi hak mengakses data klinis pasien. *Role* tersebut belum cukup untuk membedakan dokter, perawat, petugas laboratorium, dan apoteker, padahal keempat aktor memiliki kewenangan tulis yang berbeda. Sebagai contoh, dokter dapat menulis diagnosis dan terapi, sedangkan petugas laboratorium hanya dapat menulis hasil laboratorium.

Diperlukan verifikasi tambahan terhadap *subrole*, terutama untuk operasi tulis. *Server* PRE memastikan bahwa aktor pemohon memiliki *subrole* yang sesuai dengan *dataset category* yang akan ditulis. Verifikasi ini menolak kondisi ketika aktor membawa token dengan izin tulis, tetapi secara kewenangan profesional tidak berhak memperbarui segmen data tertentu.

III.2.5.2 Analisis Verifikasi Bukti Identitas Aktor pada Rantai Delegasi

Pada DecMed sebelumnya, proses otorisasi berfokus pada pemeriksaan klaim yang terdapat pada token. Namun, mekanisme tersebut belum memastikan bahwa pengirim *request* merupakan aktor yang identitasnya tercantum pada token. Kondisi ini menimbulkan kebutuhan verifikasi tambahan, yaitu verifikasi bukti kepemilikan identitas aktor.

Identitas pengguna pada DecMed direpresentasikan melalui *wallet* yang dibuat saat pendaftaran akun. *Wallet address* menjadi identifikator unik yang dapat membedakan setiap pengguna pada sistem. Oleh karena itu, *wallet* digunakan sebagai dasar verifikasi identitas aktor yang menggunakan token.

Pada token hasil delegasi, himpunan aktor yang berwenang dibentuk dari *root_subject* dan seluruh *delegated_to* pada rantai delegasi. Verifikasi dilakukan dengan meminta pemohon membuktikan kepemilikan *wallet* yang cocok dengan salah satu aktor pada himpunan tersebut. Dengan mekanisme ini, setiap *request* membawa bukti bahwa pengirim *request* menguasai *wallet* dari aktor yang tercatat. Tanda tangan dari aktor di luar rantai ditolak. Pembuktian tersebut ditujukan kepada *Server* PRE sebagai penegak *policy* akses. Hasil verifikasi ini kemudian digunakan oleh *Server* PRE untuk menentukan apakah pemohon

berwenang melanjutkan operasi akses terhadap data RME.

III.2.5.3 Analisis Revokasi dan Audit Delegasi

Delegasi akses menyebabkan token tidak lagi berdiri sendiri, tetapi membentuk relasi antara token induk dan token turunan. Oleh karena itu, mekanisme revokasi pada DecMed perlu diperluas agar pencabutan token induk dapat berdampak pada token turunan yang berasal dari token tersebut. Tanpa pencabutan berantai, aktor yang memperoleh token turunan masih dapat menggunakan akses meskipun akses asalnya telah dicabut oleh pasien.

Revokasi berantai diperlukan untuk mempertahankan kendali pasien sebagai pemilik data. Ketika pasien mencabut akses awal, sistem harus dapat mengenali bahwa token-token turunan yang berada dalam rantai delegasi yang sama tidak lagi memiliki dasar kewenangan yang sah. Dengan demikian, pemeriksaan revokasi tidak cukup hanya dilakukan terhadap token yang dikirim pada saat permintaan akses, tetapi juga perlu mempertimbangkan hubungan token tersebut dengan token asalnya.

Selain revokasi, delegasi juga membutuhkan audit yang mencatat hubungan antaraktor. Audit tidak cukup hanya mencatat bahwa suatu segmen diakses, tetapi juga perlu mencatat sumber kewenangan akses tersebut. Informasi ini diperlukan agar pasien dan sistem dapat menelusuri bagaimana akses terhadap data RME terbentuk selama proses pelayanan.

III.2.6 Pemetaan Masalah terhadap Solusi

Setelah pendekatan solusi dianalisis, setiap solusi pada bagian ini diberi ID S-TA untuk menjaga ketertelusuran terhadap masalah yang telah diidentifikasi pada Tabel III.2. Daftar solusi utama ditunjukkan pada Tabel III.8.

III.3 Rancangan Solusi

Berdasarkan hasil analisis solusi pada Subbab III.2, rancangan solusi menjelaskan bentuk sistem yang dibangun. Fondasi DecMed, yaitu IOTA sebagai penyimpanan *on-chain*, IPFS sebagai penyimpanan *off-chain*, dan PRE sebagai mekanisme

Tabel III.8: Daftar Solusi yang Diusulkan Berdasarkan Hasil Analisis

ID	Nama Solusi	Masalah Terkait
S-TA-01	Model <i>policy</i> PBAC dengan adaptasi elemen <i>Policy Machine</i>	M-TA-01
S-TA-02	Segmentasi data RME berdasarkan <i>dataset_category</i> dan <i>function_category</i>	M-TA-02
S-TA-03	Token Macaroons dengan <i>caveats</i> dan atenuasi untuk delegasi (pembentukan token turunan dimediasi <i>Server PRE</i>)	M-TA-03, M-TA-04
S-TA-04	Penegakan akses pada <i>Server PRE</i> berbasis <i>policy</i> PBAC, kapabilitas efektif, <i>wallet proof</i> , dan metadata	M-TA-01, M-TA-02, M-TA-04, M-TA-05, M-TA-07
S-TA-05	Validasi <i>subrole</i> tenaga kesehatan terhadap dataset untuk operasi tulis	M-TA-05
S-TA-06	Pencabutan akses berantai dan audit log akses dan delegasi	M-TA-06

kriptografis pendukung distribusi akses, tetap dipertahankan.

III.3.1 Rancangan Arsitektur Solusi

Keseluruhan arsitektur kerangka kerja DecMed dipertahankan pada arsitektur solusi. Tiga *client* utama DecMed, yaitu *Patient Client*, *Hospital Client*, dan *Ministry Client* tetap ada namun disesuaikan dengan kebutuhan pada Tugas Akhir ini. *Patient Client* digunakan pasien untuk menerbitkan token akses awal dan melihat riwayat delegasi. *Hospital Client* digunakan oleh petugas rekam medis, dokter, perawat, apoteker dan petugas laboratorium untuk mengakses atau memperbarui data sesuai kewenangannya dan melakukan delegasi. *Ministry Client* tidak mengalami perubahan.

Perubahan utama berada pada penerapan model PBAC, *server PRE*, token otorisasi berbasis Macaroons, dan implementasi *Move smart contract*. Pada rancangan ini, *policy* akses diperluas agar mencakup aktor, objek RME, hak akses, dan kondisi akses. Sebagian batasan *policy* direpresentasikan sebagai *caveats* pada Macaroon. Setiap *request* akses data harus menyertakan Macaroon. *Server PRE* kemudian mengevaluasi permintaan terhadap *policy* akses. Implementasi *Move smart contract* disesuaikan untuk menyimpan metadata yang diperlukan oleh mekanisme segmentasi dan penegakan *policy*.

Pada rancangan ini, *server PRE* juga berperan sebagai komponen penerbit token

Skema penyimpanan *on-chain* dan *off-chain* disesuaikan agar penegakan *policy* akses dapat didukung sesuai hasil analisis solusi pada Subbab III.2.2. Penyimpanan data pada sistem yang diusulkan dibagi menjadi dua lapisan. Penyimpanan pada lapisan *on-chain* disesuaikan melalui perubahan implementasi *Move smart contract*. Sedangkan penyimpanan pada lapisan *off-chain* disesuaikan melalui mekanisme penyimpanan data yang diproses *hospital client*.

III.3.2 Rancangan Segmentasi Data RME

```

graph TD
    subgraph Hospital_Personnel [Hospital Personnel]
        Medical_Personnel((Medical Personnel))
        Administrative_Personnel((Administrative Personnel))
        Hospital_Admin((Hospital Admin))
    end

    Patient((Patient))
    subgraph IOTA_Network [IOTA]
        IOTA_DLT[IOTA DLT network]
        IOTA_GS1[IOTA Gas Station Server sponsored transaction]
        IOTA_GS2[IOTA Gas Station Server sponsored transaction]
        IOTA_GS3[IOTA Gas Station Server sponsored transaction]
    end
    subgraph IPFS [IPFS]
        IPFS[IPFS decentralized storage]
    end
    MoH((Ministry of Health))
    subgraph Client_Patient [Client Patient mobile app]
        CP[Client Patient mobile app]
    end
    subgraph Client_Ministry [Client Ministry desktop app]
        CM[Client Ministry desktop app]
    end
    subgraph Proxy_Server [Proxy Re-encryption Server REST backend]
        PRS[Proxy Re-encryption Server REST backend]
    end
    Redis[(Redis)]
    subgraph Client_Hospital [Client Hospital desktop app]
        CH[Client Hospital desktop app]
    end

    Patient -- Using --> CP
    Hospital_Admin -- Using --> CH
    CP -- HTTP Request --> PRS
    CH -- HTTP Request --> PRS
    PRS -- Store or get --> IPFS
    PRS -- Store or get --> Redis
    CP -- Call Smart Contract --> IOTA_DLT
    CH -- Call Smart Contract --> IOTA_DLT
    MoH -- Using --> CM
    CM -- Init Sponsored Tx --> IOTA_GS1
    CM -- Init Sponsored Tx --> IOTA_GS2
    CM -- Init Sponsored Tx --> IOTA_GS3
    IOTA_GS1 -- Do Tx --> IOTA_DLT
    IOTA_GS2 -- Do Tx --> IOTA_DLT
    IOTA_GS3 -- Do Tx --> IOTA_DLT
    IOTA_DLT -- Do Tx --> IOTA_GS1
    IOTA_DLT -- Do Tx --> IOTA_GS2
    IOTA_DLT -- Do Tx --> IOTA_GS3
    CP -- Init Sponsored Tx --> IOTA_GS1
    CH -- Init Sponsored Tx --> IOTA_GS1
    
```

49

Tabel III.9: Tabel Pemetaan *Dataset Category*

<i>Dataset Category</i>	<i>Enum Value</i>
Rawat Jalan	RAWAT_JALAN
Rawat Inap	RAWAT_INAP
Laboratorium	LABORATORIUM
Apotek	APOTEK

Tabel III.10: Tabel Pemetaan *Function Category*

<i>Function Category</i>	<i>Enum Value</i>
Dokumentasi Administratif	ADMINISTRATIVE_GENERAL
Anamnesis	ANAMNESIS
Pemeriksaan Fisik	PEMERIKSAAN_FISIK
Pemeriksaan Psikologis, Sosial Ekonomi, Spiritual	PEMERIKSAAN_PSIKOLOGIS
Riwayat Penggunaan Obat	RIWAYAT_PENGUNAAN_OBAT
Rencana Rawat	RENCANA_RAWAT
Perencanaan Pemulangan Pasien	PERENCANAAN_PEMULANGAN
Instruksi Medik dan Keperawatan	INSTRUKSI_MEDIK_DAN_KEPERAWATAN
Pemeriksaan Penunjang	PEMERIKSAAN_PENUNJANG
Diagnosis	DIAGNOSIS
<i>Informed Consent</i>	INFORMED_CONSENT
Terapi	TERAPI
Laboratorium	LABORATORIUM
Peresepan	PERESEPAN
<i>Dispensing</i>	DISPENSING

menjadi unit data terkecil yang digunakan dalam proses kontrol akses. Tabel III.9 menunjukkan *dataset category* pada rancangan ini.

Setiap *dataset category* dibagi lagi berdasarkan *function category*. Kategori fungsi klinis mengacu pada hasil klasifikasi metadata RME yang disajikan pada Lampiran A. Selain fungsi klinis, kategori untuk dokumentasi administratif tetap disediakan pada rancangan ini. Dokumentasi administratif tidak difokuskan pada Tugas Akhir ini, sehingga dokumen administratif dikelompokkan ke dalam satu kategori umum, yaitu ADMINISTRATIVE_GENERAL. Kategori ini tetap disediakan karena beberapa kebutuhan fungsional DecMed masih bergantung pada keberadaan data administratif, khususnya F01, F06, F07, F14, dan F21 pada Tabel di Lampiran C.1. Tabel III.10 menunjukkan rancangan *function category* pada rancangan ini.

Pada rancangan ini, *function category* tidak selalu dibentuk dari setiap subkelompok metadata secara langsung. Beberapa subkelompok metadata dapat digabung ke dalam satu *function category* selama masih memiliki fungsi pelayanan dan kebutuhan akses yang sama. Sebagai contoh, subkelompok pada *dataset*

Laboratorium, seperti permintaan pemeriksaan, spesimen klinis, hasil pemeriksaan, serta interpretasi dan validasi hasil, dikelompokkan ke dalam *function category* LABORATORIUM karena seluruhnya merepresentasikan satu rangkaian fungsi pemeriksaan laboratorium. Sementara itu, *dataset* Apotek dibedakan menjadi PERESEPAN dan DISPENSING karena keduanya merepresentasikan dua fungsi yang berbeda, yaitu pencatatan resep dan proses penyiapan serta penyerahan obat.

Secara penyimpanan, satu entri metadata *on-chain* menunjuk pada satu segmen data terenkripsi di penyimpanan *off-chain*. Rincian skema metadata *on-chain* disajikan pada Tabel G.1, sedangkan skema objek data segmen *off-chain* disajikan pada Tabel G.2.

Dengan rancangan ini, akses pada tingkat segmen dapat ditegakkan oleh *Server* PRE. Ketika aktor meminta akses terhadap data RME, *Server* PRE mencocokkan *caveats* pada token Macaroon dengan metadata segmen yang diminta. Sebagai contoh, token yang hanya mengizinkan akses tulis terhadap *dataset* Laboratorium tidak dapat digunakan untuk menulis segmen pada *dataset* Rawat Jalan.

III.3.3 Rancangan Model PBAC pada DecMed

Subbab ini merumuskan *policy* akses atas objek. Berdasarkan analisis pada Subbab III.2.1, elemen dan relasi *Policy Machine* diadaptasi untuk memodelkan hubungan antara pengguna, atribut pengguna, segmen RME, atribut segmen, dan hak akses. Definisi formal pada subbab ini menjadi sumber kanonik bagi representasi *caveat* Macaroon dan evaluasi pada *Server* PRE.

Elemen *policy* pada DecMed didefinisikan sebagai:

$$PE_{DecMed} = U \cup UA \cup O \cup OA \cup PC, \quad (III.1)$$

dengan $[U]$ himpunan pengguna, $[UA]$ himpunan atribut pengguna, $[O]$ himpunan objek yang dilindungi, $[OA]$ himpunan atribut objek, dan $[PC]$ himpunan kelas *policy*. Berdasarkan elemen tersebut, model *policy* pada DecMed dirumuskan sebagai:

$$PM_{DecMed} = \langle PE_{DecMed}, AR, ASSIGN, ASSOCIATION, \mathcal{C} \rangle, \quad (III.2)$$

dengan AR sebagai himpunan hak akses, $ASSIGN$ sebagai relasi penugasan, $ASSOCIATION$ sebagai relasi asosiasi hak akses, dan $\mathcal{C}$ sebagai himpunan kondisi akses DecMed.

Elemen $\mathcal{C}$ merupakan perluasan pada rancangan ini untuk merepresentasikan kondisi dinamis yang ditegakkan melalui Macaroon dan *Server* PRE, seperti masa berlaku, rantai delegasi, revokasi, dan bukti kepemilikan identitas aktor pada rantai delegasi.

III.3.3.1 Pengguna dan Atribut Pengguna

Himpunan pengguna U berisi pengguna DecMed yaitu:

$$U = u_{\text{pasien}}, u_{\text{petugas-rm}}, u_{\text{perawat}}, u_{\text{dokter}}, u_{\text{laboratorium}}, u_{\text{apoteker}}. \quad (\text{III.3})$$

Elemen pada himpunan tersebut merepresentasikan alamat dompet aktual, bukan hanya nama peran. Sebagai contoh, $u_{\text{dokter-A}}$ dan $u_{\text{dokter-B}}$ merupakan dua pengguna yang berbeda meskipun keduanya memiliki atribut *subrole* dokter. Atribut pengguna dibagi menjadi atribut kelembagaan dan atribut kapabilitas:

$$UA = UA_{\text{role}} \cup UA_{\text{capability}}. \quad (\text{III.4})$$

Atribut kelembagaan menyatakan *role* atau *subrole* pengguna yang tercatat pada penyimpanan *on-chain*:

$$UA_{\text{role}} = ua_{\text{patient}}, ua_{\text{administrative-personnel}}, ua_{\text{nurse}}, ua_{\text{doctor}}, ua_{\text{laboratory}}, ua_{\text{pharmacist}}. \quad (\text{III.5})$$

Relasi penugasan pengguna terhadap atribut perannya dinyatakan sebagai:

$$u; ASSIGN; ua_{\text{role}(u)} \quad (\text{III.6})$$

Atribut kapabilitas merupakan abstraksi terhadap kapabilitas efektif yang diperoleh dari suatu token Macaroon. Untuk token τ , atribut kapabilitasnya dinyatakan

sebagai:

$$ua_{\text{cap}(\tau)} \in UA_{\text{capability}} \quad (\text{III.7})$$

Atribut kapabilitas dibentuk secara konseptual ketika *Server* PRE mengevaluasi token dan membentuk himpunan subjek dari *root_subject* serta seluruh *delegated_to* pada rantai delegasi. Pengguna hanya dianggap memiliki atribut kapabilitas apabila pengguna tersebut termasuk dalam himpunan subjek token dan dapat membuktikan kepemilikan *wallet*:

$$u; \text{ASSIGN}; ua_{\text{cap}(\tau)} \iff \text{ContainsSubject}(\tau, u) \wedge \text{WalletProofValid}(u). \quad (\text{III.8})$$

Pemisahan atribut peran dan atribut kapabilitas diperlukan karena keduanya memiliki fungsi yang berbeda. Atribut kapabilitas menentukan cakupan data yang diberikan melalui token, sedangkan atribut peran menentukan apakah pengguna masih memiliki kewenangan kelembagaan yang sesuai. Dengan demikian, kepemilikan *subrole* dokter tidak secara otomatis memberikan akses terhadap seluruh RME pasien.

III.3.3.2 Objek dan Atribut Objek

Himpunan objek O terdiri atas segmen RME terenkripsi yang disimpan pada IPFS:

$$O = o_1, o_2, \dots, o_n. \quad (\text{III.9})$$

Setiap objek merepresentasikan satu segmen klinis. Informasi mengenai objek, seperti pasien, episode RME, kategori dataset, kategori fungsi, dan CID data terenkripsi, direpresentasikan melalui metadata pada IOTA.

Atribut objek OA digunakan untuk mengelompokkan segmen berdasarkan beberapa tingkat yaitu:

1. rumah sakit;
2. pasien;

3. episode RME;
4. kategori dataset; dan
5. kategori fungsi klinis.

Contoh relasi penugasan untuk satu segmen diagnosis adalah:

$$\begin{aligned}
& o_{\text{diagnosis-17}}; \text{ASSIGN}; oa_{\text{diagnosis-RME-17}} \\
& \quad ; \text{ASSIGN}; oa_{\text{rawat-jalan-RME-17}} \\
& \quad ; \text{ASSIGN}; oa_{\text{RME-17}} \\
& \quad ; \text{ASSIGN}; oa_{\text{pasien-P}} \\
& \quad ; \text{ASSIGN}; oa_{\text{rumah-sakit-H}} \\
& \quad ; \text{ASSIGN}; pc_{\text{DecMed}}.
\end{aligned} \tag{III.10}$$

Himpunan kategori dataset yang digunakan pada rancangan ini adalah RAWAT_JALAN, RAWAT_INAP, LABORATORIUM, dan APOTEK. Sementara itu, kategori fungsi mengikuti segmentasi data yang telah dijelaskan pada Subbab III.3.2.

III.3.3.3 Hak Akses dan Asosiasi

Himpunan hak akses yang digunakan adalah:

$$AR = \text{Read, Update.} \tag{III.11}$$

Hak Read menyatakan kemampuan membaca segmen RME, sedangkan hak Update menyatakan kemampuan menulis atau memperbarui segmen. Pada implementasi token, hak tersebut direpresentasikan melalui *caveat* purpose. Cakupan objeknya direpresentasikan melalui *read_dataset_in*, *write_dataset_in*, *read_function_in*, dan *write_function_in*.

Pada *Policy Machine*, asosiasi dinyatakan sebagai hubungan antara atribut pengguna, himpunan hak akses, dan atribut target:

$$(ua, ars, oa) \in ASSOCIATION. \tag{III.12}$$

Dalam rancangan DecMed, asosiasi dibentuk secara konseptual dari kapabilitas

efektif token:

$$(ua_{\text{cap}}(\tau), AR_{\text{eff}}(\tau), OA_{\text{scope}}(\tau)) \in ASSOCIATION. \quad (\text{III.13})$$

$AR_{\text{eff}}(\tau)$ merupakan hak akses efektif token, sedangkan $OA_{\text{scope}}(\tau)$ merupakan himpunan atribut objek yang termasuk dalam cakupan token. Cakupan objek token didefinisikan sebagai:

$$\begin{aligned} \text{Scope}(\tau) = \{o_s \in O \mid & p(s) = \text{Patient}(\tau) \\ & \wedge h(s) = \text{Hospital}(\tau) \\ & \wedge d(s) \in D_{\text{eff}}(\tau) \\ & \wedge f(s) \in F_{\text{eff}}(\tau) \\ & \wedge (\text{Purpose}(\tau) = \text{Update} \Rightarrow r(s) = \text{RME}(\tau))\}. \end{aligned} \quad (\text{III.14})$$

$D_{\text{eff}}(\tau)$ merupakan irisan seluruh *caveats dataset category* pada token, sedangkan $F_{\text{eff}}(\tau)$ merupakan irisan seluruh *caveats function category*:

$$D_{\text{eff}}(\tau) = \bigcap_{i=1}^n D_i, \quad (\text{III.15})$$

$$F_{\text{eff}}(\tau) = \bigcap_{i=1}^m F_i. \quad (\text{III.16})$$

Penggunaan operasi irisan memastikan bahwa penambahan *caveat* pada token turunan hanya dapat mempertahankan atau mempersempit cakupan akses. Penambahan *caveat* baru tidak dapat mengembalikan *dataset category* atau *function category* yang telah dikecualikan oleh token induk.

Untuk operasi Read, token dapat digunakan terhadap seluruh episode RME pasien yang termasuk dalam kategori dataset dan fungsi yang diizinkan. Untuk operasi Update, cakupan juga harus sesuai dengan `related_rme_id` sehingga perubahan hanya dapat dilakukan terhadap episode pelayanan yang sedang menjadi konteks token.

Tabel III.11: Kondisi *Policy* Akses DecMed

Kondisi	Representasi	Fungsi
Identitas pasien	<code>patient_address</code>	Membatasi token pada data milik pasien tertentu.
Rumah sakit	<code>hospital_cid</code>	Membatasi penggunaan token pada konteks rumah sakit tertentu.
Episode RME	<code>related_rme_id</code>	Membatasi operasi Update pada episode RME tertentu.
Subjek rantai delegasi	<code>root_subject</code> dan seluruh <code>delegated_to</code>	Menentukan himpunan alamat dompet yang berwenang menggunakan token.
Identitas aktor pemohon	<i>Wallet proof</i>	Membuktikan bahwa permintaan ditandatangani oleh salah satu subjek rantai.
Masa berlaku	<code>expires_before</code>	Membatasi waktu penggunaan token.
Kedalaman delegasi	<code>max_delegation_depth</code> dan rantai delegasi	Membatasi jumlah penurunan token.
Hubungan token	<code>parent_token_hash</code>	Menghubungkan token turunan dengan token induk untuk revokasi.
Otoritas kelembagaan	<i>Role</i> dan <i>subrole</i> pada IOTA	Membatasi operasi tulis sesuai kewenangan tenaga kesehatan.
Status revokasi	Catatan revokasi	Menolak token awal atau token turunan yang telah dicabut.

III.3.3.4 Kondisi *Policy* Akses

Selain asosiasi antara kapabilitas dan objek, keputusan akses juga dipengaruhi oleh himpunan kondisi $\mathcal{C}$. Kondisi yang digunakan pada DecMed ditunjukkan pada Tabel III.11.

Masa berlaku efektif token merupakan nilai paling awal dari seluruh *caveat* `expires_before`:

$$Expiry_{\text{eff}}(\tau) = \min Expiry_1, Expiry_2, \dots, Expiry_n. \quad (\text{III.17})$$

Himpunan subjek yang berwenang menggunakan token ditentukan berdasarkan rantai delegasi:

$$\text{Subjects}(\tau) = \{\text{root_subject}(\tau)\} \cup \{\text{delegated_to}_i(\tau) \mid 1 \leq i \leq n\}, \quad (\text{III.18})$$

dan permintaan dari aktor u hanya diterima apabila:

$$\text{ContainsSubject}(\tau, u) \iff u \in \text{Subjects}(\tau). \quad (\text{III.19})$$

Kedalaman delegasi dihitung berdasarkan jumlah perpindahan aktor pada rantai delegasi dan harus memenuhi:

$$\text{Depth}(\tau) \leq \text{MaxDepth}(\tau). \quad (\text{III.20})$$

III.3.3.5 Rancangan *Policy* Delegasi

Delegasi dimodelkan sebagai pembentukan kapabilitas turunan τ_c dari kapabilitas induk τ_p . Token turunan hanya valid apabila tidak memperluas hak akses token induk.

Hubungan cakupan token harus memenuhi:

$$\text{Scope}(\tau_c) \subseteq \text{Scope}(\tau_p). \quad (\text{III.21})$$

Hak akses token turunan juga harus memenuhi:

$$\text{AR}_{\text{eff}}(\tau_c) \subseteq \text{AR}_{\text{eff}}(\tau_p). \quad (\text{III.22})$$

Batas waktu token turunan tidak boleh melebihi batas waktu token induk:

$$\text{Expiry}_{\text{eff}}(\tau_c) \leq \text{Expiry}_{\text{eff}}(\tau_p). \quad (\text{III.23})$$

Selain itu, token turunan harus tetap berada dalam konteks pasien dan rumah sakit yang sama:

$$Patient(\tau_c) = Patient(\tau_p), \quad (III.24)$$

$$Hospital(\tau_c) = Hospital(\tau_p). \quad (III.25)$$

Untuk token dengan operasi Update, episode RME token turunan juga tidak boleh berbeda dari token induk:

$$RME(\tau_c) = RME(\tau_p). \quad (III.26)$$

Hubungan antara token turunan dan token induk disimpan melalui `parent_token_hash`. Sementara itu, perubahan aktor direpresentasikan dengan menambahkan `delegated_by` dan `delegated_to`. Karena seluruh *caveat* token induk tetap dipertahankan, proses delegasi hanya dapat menambahkan *caveats* baru dan tidak dapat menghapus *caveats* sebelumnya.

III.3.3.6 Fungsi Keputusan Akses

Suatu permintaan akses terhadap segmen RME direpresentasikan sebagai:

$$q = \langle u, h, p, r, d, f, a, t, \tau, \pi \rangle, \quad (III.27)$$

dengan $[u]$ alamat dompet pengguna yang melakukan permintaan, $[h]$ identitas rumah sakit, $[p]$ alamat pasien, $[r]$ identitas episode RME, $[d]$ kategori dataset, $[f]$ kategori fungsi, $[a]$ operasi yang diminta, $[t]$ waktu permintaan, $[\tau]$ token Macaroon, dan $[\pi]$ bukti kepemilikan *wallet*. Permintaan diberikan apabila seluruh kondisi *policy* terpenuhi yaitu:

$$\begin{aligned}
\text{Permit}(q) \iff & \text{TokenValid}(\tau) \\
& \wedge \text{PurposeMatch}(a, \tau) \\
& \wedge \text{ContainsSubject}(\tau, u) \\
& \wedge \text{WalletProofValid}(\pi, q, u) \\
& \wedge \text{PatientMatch}(p, \tau) \\
& \wedge \text{HospitalMatch}(h, \tau) \\
& \wedge \text{DatasetAllowed}(d, \tau) \\
& \wedge \text{FunctionAllowed}(f, \tau) \\
& \wedge \text{TimeValid}(t, \tau) \\
& \wedge \text{DelegationChainValid}(\tau) \\
& \wedge \neg \text{Revoked}(\tau)
\end{aligned} \tag{III.28}$$

Apabila salah satu kondisi tidak terpenuhi, keputusan akses adalah:

$$\text{Decision}(q) = \text{Deny}. \tag{III.29}$$

Prinsip *deny by default* diterapkan melalui fungsi tersebut. Kepemilikan token saja tidak cukup untuk memperoleh akses. Token harus valid, permintaan harus berasal dari salah satu aktor pada rantai delegasi, objek harus berada dalam cakupan token, token tidak boleh kedaluwarsa atau direvokasi, dan operasi tulis harus sesuai dengan *subrole* tenaga kesehatan.

III.3.3.7 Pemetaan Model *Policy* ke Komponen DecMed

Pemetaan elemen model *policy* terhadap komponen implementasi ditunjukkan pada Tabel III.12.

Berdasarkan rancangan tersebut, model CapBAC yang telah digunakan oleh DecMed tidak digantikan oleh model PBAC. Macaroon tetap berfungsi sebagai token kapabilitas yang dibawa oleh pengguna, sedangkan elemen dan kondisi yang harus diperiksa untuk menafsirkan kapabilitas tersebut ditentukan oleh model PBAC. Dengan demikian, cara otoritas dibawa oleh token dijelaskan

Tabel III.12: Pemetaan Model *Policy* terhadap Komponen DecMed

Elemen	Representasi DecMed	Sumber atau Mekanisme Implementasi
U	Pengguna berdasarkan <i>wallet address</i>	<i>wallet address</i> dan tanda tangan <i>wallet</i> .
$U_{A_{role}}$	<i>Role</i> dan <i>subrole</i> pengguna	<i>Registry Personnel</i> pada IOTA.
$U_{A_{capability}}$	Kapabilitas efektif pengguna	Token Macaroon dan rantai delegasi.
O	Segmen RME terenkripsi	Objek data pada IPFS.
OA	Rumah sakit, pasien, RME, dataset, dan fungsi	Metadata segmen pada IOTA.
PC	Kelas <i>policy</i> DecMed	Aturan kontrol akses yang diberlakukan pada sistem DecMed.
AR	Operasi Read dan Update	<i>purpose</i> dan <i>caveats</i> baca atau tulis pada Macaroon.
$ASSIGN$	Penugasan pengguna ke peran dan segmen ke kategori	Registri personel serta struktur metadata segmen.
$ASSOCIATION$	Hubungan kapabilitas dengan hak dan cakupan objek	<i>Effective capability</i> hasil evaluasi <i>caveat</i> .
$\mathcal{C}$	Masa berlaku, delegasi, revokasi, dan bukti identitas	Macaroon, <i>wallet proof</i> , Redis, IOTA, dan fungsi verifikasi PRE.

melalui CapBAC, sedangkan *policy* yang menentukan validitas penggunaan otoritas tersebut dijelaskan melalui PBAC.

Rincian representasi *policy* dalam bentuk *caveat* dijelaskan pada Subbab III.3.4. Mekanisme evaluasi dan penegakannya pada *Server* PRE dijelaskan pada Subbab III.3.5.

III.3.4 Rancangan Representasi *Policy* pada Token Macaroons

Model PBAC pada Subbab III.3.3 mendefinisikan *policy* akses pada tingkat konseptual, termasuk kondisi pada Tabel III.11 dan pemetaan elemen terhadap komponen DecMed pada Tabel III.12. Pada subbab ini, Macaroon digunakan sebagai representasi kapabilitas dari *policy* tersebut agar dapat dibawa oleh pengguna dan diverifikasi saat permintaan akses.

Representasi kondisi identitas pasien, rumah sakit, episode RME, subjek rantai delegasi, masa berlaku, kedalaman delegasi, dan hubungan token mengikuti Tabel III.11. Hak akses AR direpresentasikan melalui *caveat purpose* bernilai

Tabel III.13: Penempatan *Caveat* menurut Jenis Token

<i>Caveat</i>	Token
purpose, patient_address, hospital_cid, root_subject, expires_before, max_delegation_depth	Keduanya
read_dataset_in, read_function_in	Read
write_dataset_in, write_function_in, related_rme_id	Update
delegated_by, delegated_to, parent_token_hash	Turunan

Read atau Update. Nama *caveat* tersebut dipertahankan untuk kompatibilitas dengan implementasi DecMed sebelumnya. Cakupan objek direpresentasikan melalui `read_dataset_in`, `write_dataset_in`, `read_function_in`, dan `write_function_in`, sesuai asosiasi kapabilitas pada Subbab III.3.3.

Tidak seluruh elemen *policy* disimpan sebagai *caveat*. Atribut kelembagaan (*role* atau *subrole*), metadata objek aktual, bukti kepemilikan *wallet*, dan status revokasi diverifikasi di luar token sebagaimana dipetakan pada Tabel III.12, agar token tidak menjadi satu-satunya sumber kebenaran mengenai kondisi pengguna dan objek.

Penempatan *caveat* menurut jenis token ditunjukkan pada Tabel III.13.

Implementasi DecMed sebelumnya menggunakan dua token terpisah untuk operasi baca dan perubahan data. Pola tersebut dipertahankan untuk menjaga kompatibilitas dengan *smart contract*, *client*, penyimpanan metadata akses, dan *Server PRE*. Token baca memiliki $AR_{\text{eff}}(\tau_{\text{read}}) = \text{Read}$ dan memakai `read_dataset_in` serta `read_function_in`. Token perubahan data memiliki $AR_{\text{eff}}(\tau_{\text{update}}) = \text{Update}$ dan memakai `write_dataset_in` serta `write_function_in`. Pemisahan tersebut mencegah token baca digunakan sebagai dasar operasi tulis meskipun kategori dataset atau kategori fungsi yang diminta sama.

Cakupan objek untuk kedua jenis token mengikuti $\text{Scope}(\tau)$ pada Subbab III.3.3: token Read tidak mewajibkan `related_rme_id` agar riwayat episode pasien dapat ditinjau dalam batas kategori yang diizinkan, sedangkan token Update wajib memuat `related_rme_id`. Nilai `related_rme_id` menggunakan format `RME- $\{\text{sequence\_6\_digit}\}$` , misalnya `RME-000001`, sesuai identitas episode RME pada prototipe DecMed.

III.3.4.1 Rancangan Subjek Rantai Delegasi

Caveat holder_address tidak digunakan untuk menyatakan pemegang token tunggal. Hal ini disebabkan oleh sifat *append-only* pada Macaroon. Apabila token awal memuat:

```
holder_address = 0xPETUGAS_REKAM_MEDIS
```

kemudian token turunan menambahkan:

```
holder_address = 0xDOKTER
```

maka token akan memiliki dua *caveat* identitas yang tidak dapat dipenuhi secara bersamaan. *Caveat* lama tidak dapat dihapus atau diganti ketika token diturunkan.

Sebagai gantinya, aktor berwenang ditentukan dari rantai delegasi melalui root_subject serta pasangan delegated_by dan delegated_to. Definisi Subjects(τ) dan ContainsSubject(τ, u) mengikuti Subbab III.3.3. Untuk setiap pasangan delegasi ke- i , rantai harus memenuhi:

$$\text{delegated_by}_i = \begin{cases} \text{root_subject}, & i = 1, \\ \text{delegated_to}_{i-1}, & i > 1. \end{cases} \quad (\text{III.30})$$

III.3.4.2 Penerbitan Token Awal

Pada rancangan ini, *Server* PRE bertindak sebagai penerbit token awal dan menyimpan RootKey yang digunakan untuk membentuk tanda tangan Macaroon. RootKey disimpan pada *environment variable* *Server* PRE dan tidak pernah diberikan kepada *client*.

Token awal diterbitkan setelah alur pemberian akses oleh pasien telah terpenuhi. Pasien menentukan penerima awal, rumah sakit, cakupan kategori dataset, cakupan kategori fungsi, hak akses, masa berlaku, dan batas delegasi. Informasi tersebut menjadi dasar pembentukan *caveat* pada token awal.

Alur penerbitan token awal adalah sebagai berikut:

1. Pasien memilih aktor penerima dan cakupan akses.
2. *Client* pasien membentuk permintaan pemberian akses.
3. *Server* PRE memvalidasi identitas pasien dan parameter akses.

4. *Server* PRE membentuk token Macaroon menggunakan *RootKey*.
5. Token dan metadata akses dicatat sesuai mekanisme pemberian akses DecMed.
6. Token dapat digunakan oleh aktor yang ditentukan sebagai *root_subject*.

Pemisahan antara pasien dan penerbit token tidak menghilangkan sifat *patient-centric*. Pasien tetap menjadi pihak yang menentukan pemberian akses awal, sedangkan *Server* PRE menjalankan fungsi kriptografis untuk membentuk token yang dapat diverifikasi secara konsisten.

III.3.4.3 Atenuasi Token sebagai Realisasi Delegasi

Delegasi diwujudkan melalui pembentukan token turunan dengan penambahan *caveat*. Ketentuan bahwa token turunan tidak boleh memperluas cakupan, hak akses, masa berlaku, maupun konteks pasien, rumah sakit, dan episode RME mengikuti model *policy* delegasi pada Subbab III.3.3. Pada rancangan ini, *client* delegator tidak membentuk token turunan secara mandiri. *Client* mengirimkan token induk, alamat penerima, cakupan yang diminta, masa berlaku, dan bukti identitas delegator kepada *Server* PRE.

Server PRE kemudian:

1. memverifikasi tanda tangan dan seluruh *caveat* token induk;
2. membentuk himpunan subjek rantai delegasi token induk;
3. memverifikasi bahwa permintaan berasal dari salah satu subjek pada rantai tersebut;
4. memeriksa status revokasi token induk;
5. memeriksa batas kedalaman delegasi;
6. memastikan cakupan token turunan tidak melebihi token induk;
7. menambahkan *delegated_by*, *delegated_to*, dan *parent_token_hash*;
8. menambahkan *caveats* dataset, fungsi, masa berlaku, atau kedalaman delegasi yang lebih sempit; dan
9. menghasilkan token turunan.

Sifat *append-only* Macaroon memastikan seluruh *caveat* token induk tetap terdapat pada token turunan. Penambahan *caveat* hanya dapat mempertahankan atau mempersempit kapabilitas; *caveat* induk tidak dapat dihapus untuk memperluas akses. Realisasi $D_{\text{eff}}(\tau)$ dan $F_{\text{eff}}(\tau)$ sebagai irisan *caveat* kategori data mengikuti definisi pada Subbab III.3.3.

III.3.4.4 *Caveat* Kedalaman Delegasi dan Hubungan Token

Batas kedalaman delegasi mengikuti kondisi $\text{Depth}(\tau) \leq \text{MaxDepth}(\tau)$ pada Subbab III.3.3. Pada representasi Macaroon, $\text{MaxDepth}_{\text{eff}}(\tau)$ diambil sebagai nilai minimum seluruh *caveat* `max_delegation_depth` pada token, dan token hanya dapat diturunkan lagi apabila $\text{Depth}(\tau) < \text{MaxDepth}_{\text{eff}}(\tau)$. Token turunan dapat menambahkan nilai yang lebih kecil untuk mengurangi kemampuan delegasi lebih lanjut.

Caveat `parent_token_hash` hanya ditambahkan pada token turunan. Nilainya merupakan *hash* token induk dan digunakan untuk membentuk hubungan antartoken yang mendukung pemeriksaan rantai delegasi dan mekanisme revokasi hierarkis.

III.3.4.5 Penerapan Whitelisting dan Least Privilege

Pendekatan *whitelisting* pada *caveats* kategori data merealisasikan $\text{Scope}(\tau)$: kategori yang tidak dicantumkan dianggap di luar cakupan token. Prinsip *least privilege* didukung oleh atenuasi. Sebagai contoh, petugas laboratorium dapat memperoleh hak membaca fungsi PEMERIKSAAN_PENUNJANG pada dataset RAWAT_JALAN dan hak memperbarui fungsi LABORATORIUM pada dataset LABORATORIUM, tanpa akses terhadap anamnesis, diagnosis, terapi, atau resep.

III.3.4.6 Hubungan dengan Proses Verifikasi

Evaluasi lengkap permintaan akses mengikuti $\text{Permit}(q)$ pada Persamaan III.28. Predikat $\text{TokenUsable}(\tau, q)$ merangkum pemeriksaan kapabilitas yang bersumber dari token sebelum kondisi eksternal ditegakkan pada *Server* PRE:

$$\begin{aligned}
\text{TokenUsable}(\tau, q) \iff & \text{SignatureValid}(\tau) \\
& \wedge \text{ContainsSubject}(\tau, u) \\
& \wedge \text{ObjectScopeMatch}(\tau, q) \\
& \wedge \text{AccessRightMatch}(\tau, q) \\
& \wedge \text{TimeValid}(\tau) \\
& \wedge \text{DelegationValid}(\tau) \\
& \wedge \neg \text{Revoked}(\tau) \\
& \wedge \text{ExternalAttributesValid}(q).
\end{aligned} \tag{III.31}$$

$\text{ExternalAttributesValid}(q)$ mencakup pemeriksaan *role* atau *subrole*, metadata segmen, dan bukti kepemilikan dompet sesuai pemetaan pada Tabel III.12. Rincian penegakan dijelaskan pada Subbab III.3.5.

Contoh token awal untuk petugas rekam medis disajikan pada Kode H.1 dan Kode H.2.

III.3.5 Rancangan Penegakan Otoritas

Fungsi $\text{Permit}(q)$ pada Persamaan III.28 dan predikat $\text{TokenUsable}(\tau, q)$ pada Persamaan III.31 direalisasikan melalui penegakan pada *Server PRE*. Model *policy* ditetapkan pada Subbab III.3.3, sedangkan representasi kapabilitas melalui token Macaroon dijelaskan pada Subbab III.3.4. Subbab ini menguraikan bagaimana *Server PRE* mengevaluasi permintaan akses q dan menegakkan kondisi eksternal yang tidak sepenuhnya tercakup pada token. Penerapan pada alur penerbitan, delegasi, dan penggunaan token dijelaskan pada Subbab III.3.6.

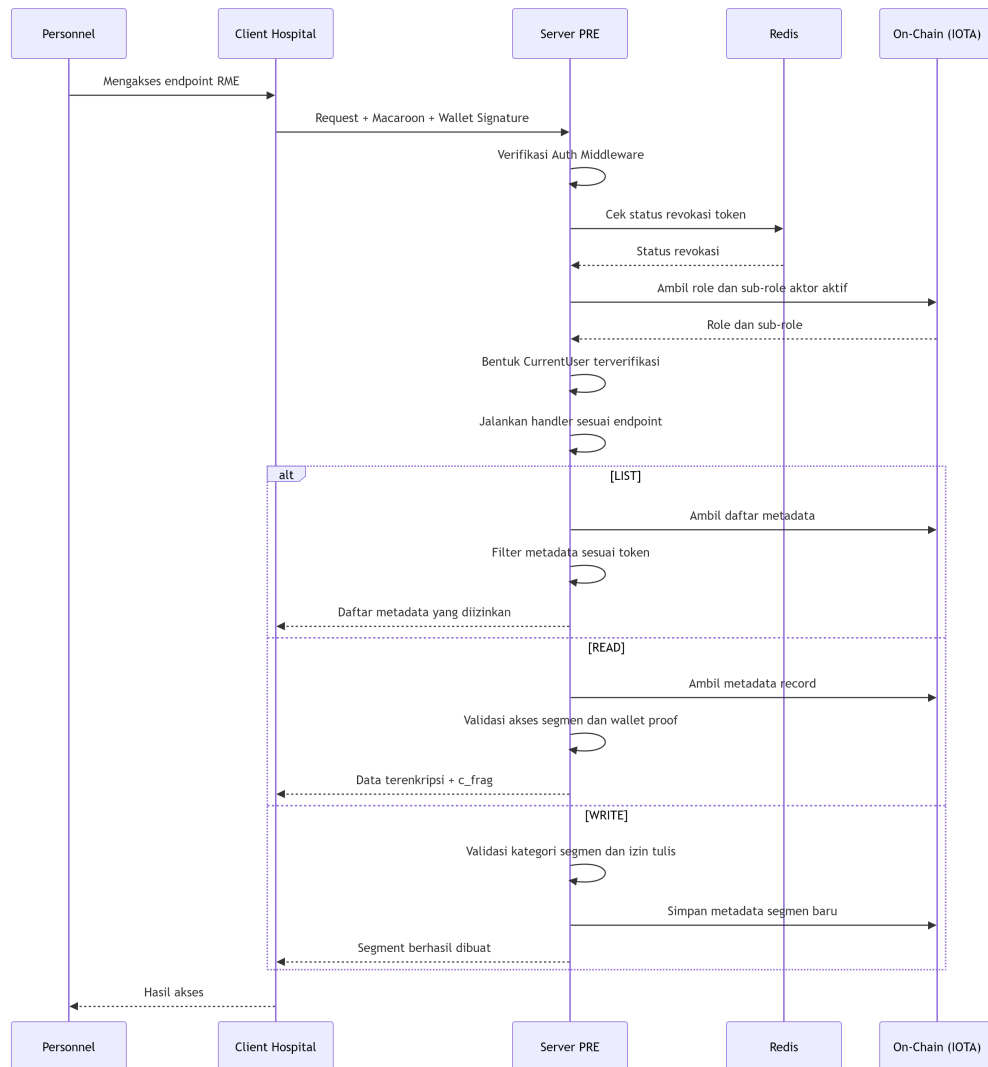
Tiga aspek penegakan diuraikan berikut. Evaluasi keseluruhan pada *Server PRE* dijelaskan pada Subbab III.3.5.1. Realisasi $\text{RoleScopeValid}(u, d, f)$ diuraikan pada Subbab III.3.5.2. Mekanisme yang mendukung $\neg \text{Revoked}(\tau)$ dijelaskan pada Subbab III.3.5.4.

Gambar III.3 menunjukkan alur penegakan tersebut. Aktor mengirimkan permintaan melalui *client* ke *Server PRE*. *Server PRE* mengevaluasi Persamaan III.28; bila terpenuhi, proses dilanjutkan ke pengambilan daftar RME,

pembacaan dengan *re-encryption*, atau penulisan data. Bila gagal, keputusan mengikuti Persamaan III.29.

III.3.5.1 Penegakan *Policy*

Server PRE merupakan titik penegakan yang mengevaluasi $\text{Permit}(q)$. Pemeriksaan kapabilitas yang bersumber dari token mengikuti $\text{TokenUsable}(\tau, q)$ pada Subbab III.3.4. Kondisi eksternal $\text{WalletProofValid}(\pi, q, u)$, $\text{RoleScopeValid}(u, d, f)$, dan $\neg \text{Revoked}(\tau)$ ditegakkan melalui atribut dan status di luar token, sesuai pemetaan pada Tabel III.12, dan diuraikan pada subbab berikutnya.



Gambar III.3: Alur penegakan otoritas pada *Server PRE*

Tabel III.14: Pemetaan Hak Akses Update Berdasarkan subrole Tenaga Medis

<i>subrole</i>	<i>Dataset Category</i>	<i>Function Category</i>
Perawat	Rawat Jalan/Rawat Inap	Anamnesis, Pemeriksaan Fisik, Pemeriksaan Psikologis
Dokter	Rawat Jalan/Rawat Inap	Seluruh <i>function category</i>
Lab	Laboratorium	Laboratorium
Apoteker	Apotek	Peresepan dan Dispensing

III.3.5.2 Verifikasi *Role* dan *Subrole* untuk Akses *Dataset*

Kondisi $\text{RoleScopeValid}(u, d, f)$ pada Persamaan III.28 memastikan operasi Update hanya dilakukan pada kategori data yang sesuai kewenangan kelembagaan aktor, sebagaimana dianalisis pada Subbab III.2.5.1. Sistem eksisting menggunakan peran teknis *MedicalPersonnel* untuk tenaga kesehatan klinis. Pada rancangan ini terdapat empat *subrole* turunan—dokter, perawat, petugas laboratorium, dan apoteker—dengan pemetaan hak tulis pada Tabel III.14.

Alur validasi ditunjukkan pada Gambar III.4. *Server PRE* mengambil informasi *subrole* aktor melalui *smart contract*, kemudian memvalidasi kesesuaiannya terhadap kategori *dataset* yang coba ditulis. Apabila tidak sesuai, permintaan ditolak. Bagian berlatar merah pada gambar menunjukkan alur yang ditambahkan dibanding implementasi DecMed sebelumnya: pengambilan *subrole* dari *smart contract* serta validasi kesesuaian *role*, *subrole*, dan kategori *dataset* sebelum akses tulis diberikan. Pemeriksaan ini dilakukan setelah $\text{WalletProofValid}(\pi, q, u)$ berhasil, dengan sumber atribut kelembagaan pada *Registry Personnel* sebagaimana dipetakan pada Tabel III.12.

III.3.5.3 Verifikasi *Wallet* Aktor pada Rantai Delegasi

Kondisi $\text{ContainsSubject}(\tau, u)$ dan $\text{WalletProofValid}(\pi, q, u)$ pada Persamaan III.28 mewajibkan bukti kepemilikan *wallet* terhadap salah satu aktor pada rantai delegasi, sesuai analisis pada Subbab III.2.5.2 dan definisi subjek pada Subbab III.3.3.

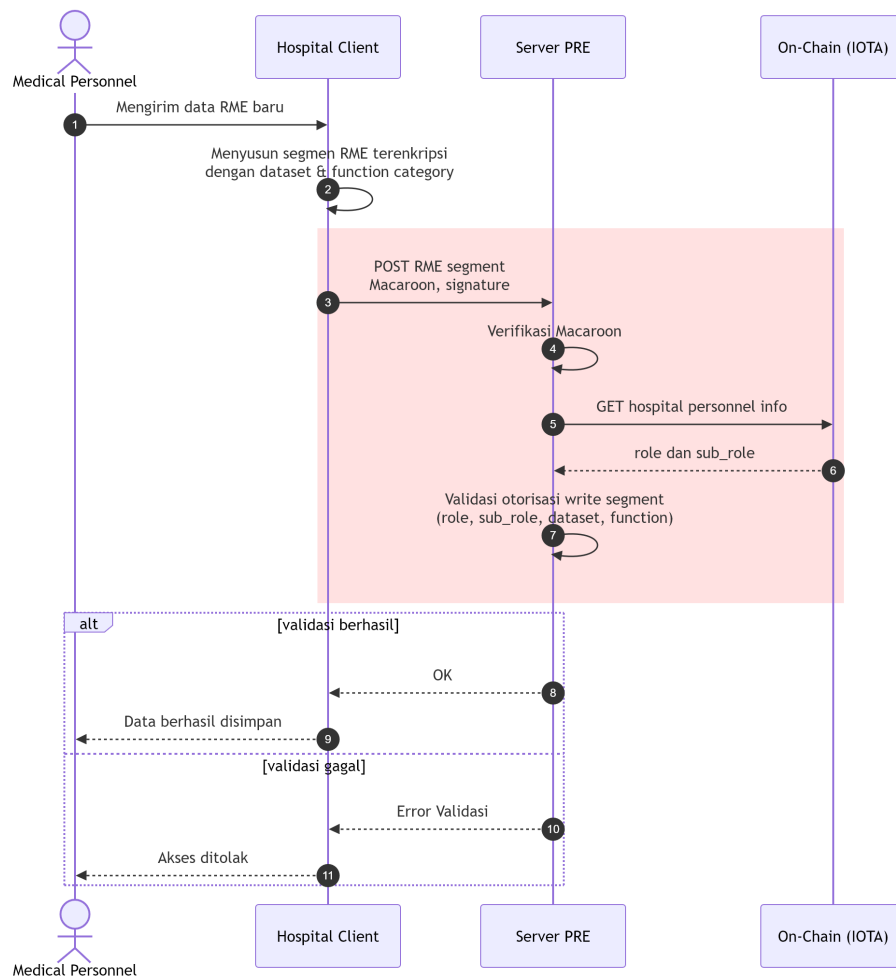
Proses verifikasi memakai mekanisme *presigned request*. Ketika *client* mengirimkan permintaan ke *Server PRE*, *client* menambahkan header berisi konteks permintaan yang ditandatangani dengan kunci privat *wallet* pengguna. Konteks tersebut memuat `token_id`, `patient_address`, `related_rme_id`, `operation`, `segment_id`, `dataset_category`, `function_category`, dan

timestamp. *Server PRE* mencocokkan tanda tangan terhadap seluruh subjek pada $\text{Subjects}(\tau)$. Apabila cocok dengan salah satu subjek, permintaan dilanjutkan dengan identitas tersebut untuk pemeriksaan *role* atau *subrole*. Apabila tidak cocok atau berasal dari aktor di luar rantai, permintaan ditolak. *Timestamp* pada konteks yang ditandatangani membatasi masa berlaku tanda tangan.

III.3.5.4 Pencabutan Hak Akses Macaroon Delegasi

Pemeriksaan $\neg \text{Revoked}(\tau)$ pada Persamaan III.28 membutuhkan mekanisme revokasi yang berdampak pada token turunan, sesuai analisis pada Subbab III.2.5.3. Pasien tetap menjadi *resource owner* yang berwenang mencabut akses. Hubungan token turunan dengan induknya melalui *parent_token_hash* mengikuti rancangan pada Subbab III.3.4.

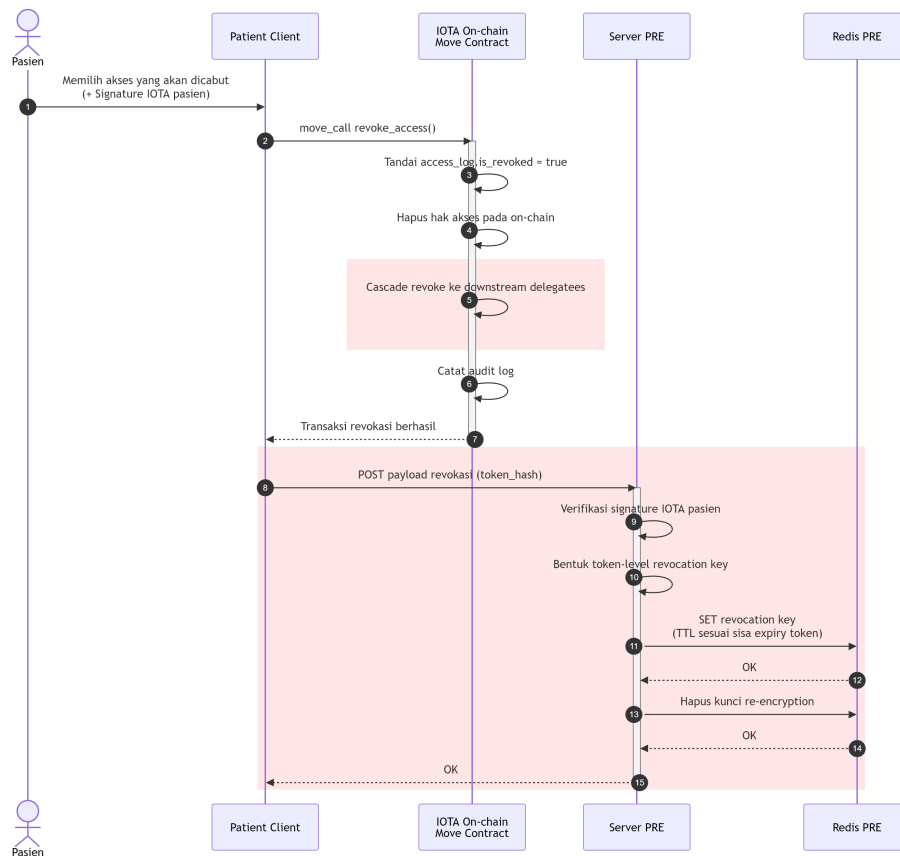
Revokasi diwujudkan melalui pencatatan status di *IOTA on-chain* dan *Redis PRE*.



Gambar III.4: *Sequence Diagram* Rancangan Validasi *subrole* Tenaga Medis terhadap *Dataset Category*

Lapisan *on-chain* mencatat perubahan status akses dan *audit trail*, sedangkan Redis menyimpan *hash* token yang telah dicabut. Alur pencabutan ditunjukkan pada Gambar III.5. Pasien memilih akses melalui *Patient Client*, yang mengeksekusi `revoke_access()` pada *smart contract* Move untuk menandai akses sebagai dicabut, menghapus hak akses *on-chain*, melakukan pencabutan berantai terhadap penerima delegasi turunan, serta mencatat kejadian ke *audit log*. Setelah transaksi berhasil, *Patient Client* mengirimkan *payload* revokasi ke *Server PRE* agar menyimpan *hash* token pada Redis dan menghapus *re-encryption key* terkait.

Bagian berlatar merah pada Gambar III.5 menunjukkan alur baru pada Tugas Akhir ini: pencabutan berantai terhadap *downstream delegates*, pengiriman *payload* ke *Server PRE*, pembentukan *revocation key*, penyimpanan status pada Redis dengan TTL sesuai masa berlaku token, serta penghapusan kunci *re-encryption*. Pada saat verifikasi, *Server PRE* memeriksa *hash* token yang digunakan dan setiap *parent_token_hash* terhadap *revocation key* pada Redis, serta status hak akses pada penyimpanan *on-chain*. Apabila akses pada delegator awal dicabut, token turunan dari akses tersebut juga dianggap tidak valid.



Gambar III.5: *Sequence Diagram* Rancangan Alur Pencabutan Hak Akses Macaroon Delegasi

III.3.6 Rancangan Alur Akses dan Delegasi Macaroon

Setelah arsitektur, segmentasi, model PBAC, representasi Macaroon, dan penegakan pada *Server* PRE dirancang, subbab ini menyatukan komponen tersebut pada alur pelayanan. Sesuai analisis pada Subbab III.2.4 dan skenario pada Subbab III.1.1.3, kebutuhan delegasi akses antartanaga kesehatan tanpa penerbitan ulang token oleh pasien dijawab melalui alur penerbitan, delegasi, dan penggunaan token. Model *policy* pada Subbab III.3.3, representasi kapabilitas pada Subbab III.3.4, serta penegakan otoritas pada Subbab III.3.5 menjadi dasar evaluasi setiap permintaan.

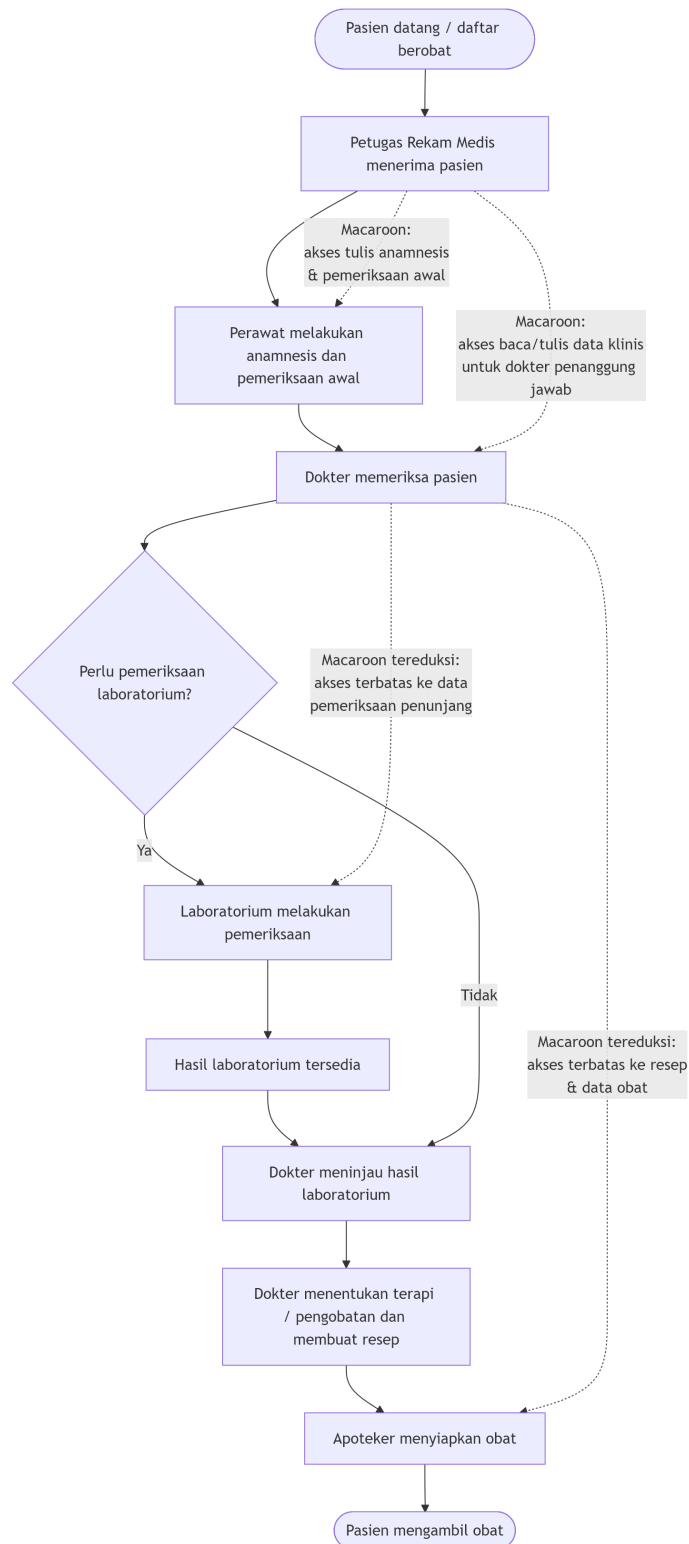
Alur akses dan delegasi pada rancangan ini mengikuti alur pelayanan kesehatan yang umum terjadi pada proses rawat jalan dan rawat inap. Alur ini diuraikan pada Subbab III.1.1.3. Pasien terlebih dahulu diterima oleh petugas rekam medis. Setelah itu, petugas rekam medis memberikan akses kepada perawat untuk melakukan pemeriksaan awal. Petugas rekam medis juga memberikan akses kepada dokter terkait agar dokter dapat memeriksa pasien dan menentukan tindakan medis berikutnya. Apabila dokter membutuhkan pemeriksaan penunjang, dokter dapat mendelegasikan akses kepada petugas laboratorium. Setelah hasil pemeriksaan tersedia dan dokter menentukan terapi atau pengobatan, dokter dapat mendelegasikan akses kepada apoteker untuk memproses resep dan penyerahan obat. Rancangan alur tersebut ditunjukkan pada Gambar III.6.

Delegasi akses pada rancangan ini terdiri atas tiga tahap utama. Tahap pertama adalah penerbitan token awal kepada petugas rekam medis sebagai aktor yang menerima pasien dan mengoordinasikan akses awal dalam proses pelayanan. Tahap kedua adalah delegasi dari petugas rekam medis kepada perawat dan dokter. Tahap ketiga adalah delegasi lanjutan dari dokter kepada petugas laboratorium dan apoteker, sesuai kebutuhan tindakan medis.

Pola teknis proses pemberian token Macaroon atau proses delegasi oleh *delegator* hingga akhirnya digunakan oleh *delegatee* untuk mengakses data RME diuraikan pada bagian berikutnya. Pola teknis ini dibagi menjadi dua bagian, yaitu proses pemberian token Macaroon delegasi hingga tercatat pada *on-chain* dan proses pengambilan dan penggunaan token Macaroon delegasi.

III.3.6.1 Penerbitan Token Awal oleh Pasien kepada Petugas Rekam Medis

Penerbitan token awal merupakan proses pemberian otorisasi pertama pada saat pasien memulai layanan kesehatan. Pada tahap ini, pasien tetap menjadi pihak



Gambar III.6: *Flow Diagram* Alur Akses dan Delegasi pada Proses Pelayanan Pasien

yang mengendalikan pemberian akses awal terhadap data RME miliknya. Pasien memberikan persetujuan akses melalui *Patient Client*, kemudian *Server PRE* menerbitkan token awal berdasarkan persetujuan tersebut. Pasien mengetahui identitas dari petugas rekam medis melalui QR yang dipindai, kemudian membuktikan kepemilikan *wallet* kepada PRE dengan *nonce* sebelum token awal diterbitkan.

Pada rancangan ini, petugas rekam medis berperan sebagai aktor awal yang menerima pasien dan menginisiasi proses pelayanan. Token ini tidak dimaksudkan agar petugas rekam medis dapat mengakses seluruh data klinis pasien secara bebas, melainkan sebagai token induk yang dapat digunakan untuk menurunkan akses kepada aktor layanan kesehatan yang relevan. Terdapat 2 token Macaroon yang diterbitkan pada tahapan ini, yaitu token Read dan token Update. Penggunaan langsung token tersebut tetap dibatasi oleh pemeriksaan otoritas yang dibahas pada Subbab III.3.5, sehingga cakupan token induk tidak otomatis berarti seluruh data dapat dibaca bebas oleh petugas rekam medis. Contoh *caveat* yang ditambahkan pada token awal untuk petugas rekam medis dapat dilihat pada Lampiran H.1 dan H.2.

Untuk memastikan RME tetap dapat diproses dengan mekanisme Umbral PRE, dibutuhkan sebuah *data PRE seed*. *Data PRE seed* ini digunakan untuk membangkitkan pasangan kunci PRE data yang dibutuhkan dalam proses enkripsi, dekripsi, dan *re-encryption*. *Data PRE seed* tersebut dibuat pada *patient client* ketika akses awal diberikan, lalu disimpan dalam metadata akses di *on-chain* dalam kondisi terenkripsi menggunakan kunci publik PRE penerima akses. Pada proses delegasi, *data PRE seed* yang sudah ada didekripsi oleh pemberi delegasi, kemudian dienkripsi ulang menggunakan kunci publik PRE penerima delegasi dan disimpan kembali bersama metadata delegasi di *on-chain*.

Alur penerbitan token awal kepada petugas rekam medis diawali dengan pasien bertemu dengan petugas rekam medis yang menerima permintaan pelayanan serta memperlihatkan QR untuk discan oleh pasien. Pasien memberikan persetujuan akses awal melalui *Patient Client* setelah memilih konteks pelayanan (rawat jalan atau rawat inap), masa berlaku akses, dan jenis akses yang diberikan. *Patient Client* mengirimkan permintaan penerbitan token kepada *Server PRE*. *Server PRE* memverifikasi identitas pasien, identitas petugas rekam medis, dan parameter

Tabel III.15: Pemetaan Delegasi Token dari Petugas Rekam Medis

Penerima Delegasi	Tujuan Delegasi	Cakupan Akses
Perawat	Melakukan anamnesis dan pemeriksaan awal pasien.	Menulis segmen anamnesis, pemeriksaan fisik, dan pemeriksaan psikologis pada <i>dataset</i> rawat jalan.
Dokter	Memeriksa pasien, membaca hasil pemeriksaan awal, menentukan tindakan medis, diagnosis, terapi, dan kebutuhan pemeriksaan penunjang.	Membaca dan menulis segmen klinis yang relevan pada <i>dataset</i> rawat jalan atau rawat inap, serta memiliki kemampuan delegasi lanjutan untuk apoteker dan petugas laboratorium.

akses yang diberikan. Jika lolos proses verifikasi, *Server* PRE menerbitkan token Macaroon awal dengan *caveats* yang mengikat token pada pasien, ID RME terkait, petugas rekam medis sebagai penerima awal, cakupan akses, masa berlaku, dan batas delegasi. *Server* PRE mencatat penerbitan token awal ke dalam penyimpanan *on-chain*. Token awal didistribusikan kepada petugas rekam medis melalui mekanisme yang dijelaskan pada Subbab III.3.6.4 dengan memanfaatkan penyimpanan *on-chain*.

III.3.6.2 Delegasi dari Petugas Rekam Medis kepada Perawat dan Dokter

Setelah menerima token awal, petugas rekam medis dapat mendelegasikan akses kepada perawat dan dokter terkait sesuai kebutuhan pelayanan. Pada delegasi ini, permintaan atenuasi dikirimkan kepada *server* PRE. *Server* PRE memverifikasi *request* delegasi. Apabila valid, *server* PRE mengembalikan token turunan untuk diproses lebih lanjut oleh *client delegator* untuk dicatat pada penyimpanan *on-chain*.

Delegasi kepada perawat diberikan agar perawat dapat membaca RME pasien untuk melakukan penanganan, dan menulis hasil pemeriksaan awal. Sementara itu, delegasi kepada dokter diberikan agar dokter dapat membaca data seluruh rekam medis pasien, menuliskan RME untuk episode layanan saat ini, serta melakukan delegasi lanjutan apabila diperlukan. Pemetaan delegasi dari petugas rekam medis ditunjukkan pada Tabel III.15. Contoh *caveats* yang ditambahkan pada token turunan untuk perawat dan dokter dapat dilihat pada Lampiran H.3 dan H.4.

Tabel III.16: Pemetaan Delegasi Lanjutan dari Dokter

Penerima Delegasi	Tujuan Delegasi	Cakupan Akses
Petugas Laboratorium	Melakukan pemeriksaan penunjang berdasarkan permintaan dokter dan mengunggah hasil pemeriksaan.	Membaca segmen pemeriksaan penunjang dan menulis pada <i>dataset</i> laboratorium.
Apoteker	Memproses resep, menyiapkan obat, dan mencatat penyerahan obat kepada pasien.	Membaca segmen terapi dan menulis pada <i>dataset</i> apotek.

III.3.6.3 Delegasi dari Dokter kepada Laboratorium dan Apoteker

Setelah dokter menerima token turunan dari petugas rekam medis, dokter dapat melakukan delegasi lanjutan apabila dibutuhkan dalam proses pelayanan. Delegasi lanjutan dilakukan kepada petugas laboratorium apabila dokter membutuhkan pemeriksaan penunjang. Setelah dokter menentukan terapi, dokter juga dapat mendelegasikan akses kepada apoteker untuk memproses resep dan penyerahan obat. Contoh *caveats* yang ditambahkan pada token turunan untuk laboratorium dan apoteker dapat dilihat pada Lampiran H.5 dan H.6. Pemetaan delegasi lanjutan dari dokter ditunjukkan pada Tabel III.16.

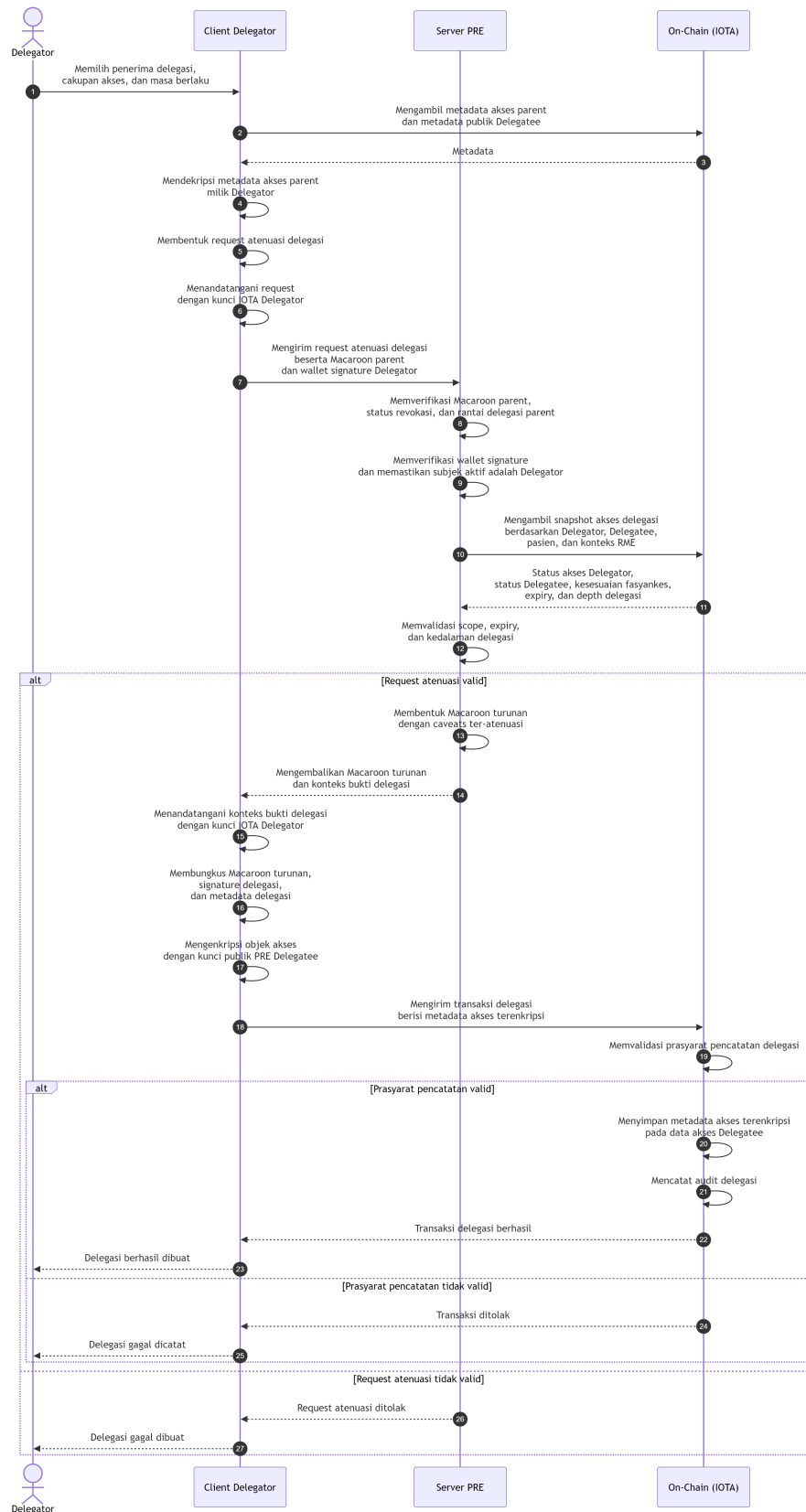
III.3.6.4 Proses Pemberian dan Penggunaan Token Macaroon Delegasi

Secara umum, proses pemberian dan penggunaan token Macaroon delegasi dibagi menjadi dua bagian. Bagian pertama adalah proses pembentukan dan pencatatan delegasi, *client* yang meminta atenuasi token ke *server* PRE. Bagian ini mencakup pembentukan token Macaroon turunan, enkripsi metadata delegasi, serta pencatatan metadata akses terenkripsi pada penyimpanan *on-chain*. Alur proses tersebut ditunjukkan pada Gambar III.7.

Berdasarkan Gambar III.7, proses delegasi diawali ketika *delegator* memilih cakupan akses yang akan diberikan kepada *delegatee*. Setelah cakupan akses ditentukan, *client delegator* mengambil token Macaroon yang dimiliki oleh *delegator* dan melakukan *request* atenuasi token ke *server* PRE.

Server PRE memverifikasi *request* delegasi. Validasi mencakup pemeriksaan apakah cakupan akses turunan lebih luas, verifikasi *signature* dari *delegator*, status akses *delegator* pada *on-chain*, serta *caveats* cakupan yang diminta. Apabila valid,

server PRE mengembalikan token turunan untuk diproses lebih lanjut oleh *client delegator* untuk dicatat pada penyimpanan *on-chain*.



Gambar III.7: Sequence diagram pembentukan dan pencatatan token Macaroon delegasi

Setelah token Macaroon turunan terbentuk, token tersebut tidak disimpan secara langsung dalam bentuk *plaintext* pada penyimpanan *on-chain*. Aplikasi *client* milik *delegator* terlebih dahulu mengambil kunci publik milik *delegatee* dari IOTA, termasuk kunci publik PRE milik *delegatee*. Kunci publik PRE kemudian digunakan untuk mengenkripsi objek akses yang berisi token Macaroon turunan dan metadata delegasi. Dengan pendekatan ini, metadata akses yang dicatat pada *on-chain* hanya tersedia dalam bentuk terenkripsi yang hanya bisa dibuka oleh *delegatee*.

Metadata akses terenkripsi kemudian disimpan pada IOTA menggunakan *smart contract*. Pada tahap ini, *smart contract* mencatat metadata terenkripsi pada data akses milik *delegatee* dan juga memvalidasi prasyarat delegasi yang dapat diperiksa dari penyimpanan *on-chain*. Prasyarat tersebut meliputi status aktif akun, kesesuaian fasyankes antara *delegator* dan *delegatee*, serta keberadaan dan masa berlaku akses *delegator* terhadap pasien terkait. Apabila prasyarat tersebut valid, metadata akses terenkripsi disimpan pada daftar akses milik *delegatee*. Apabila prasyarat tidak terpenuhi, transaksi delegasi ditolak.

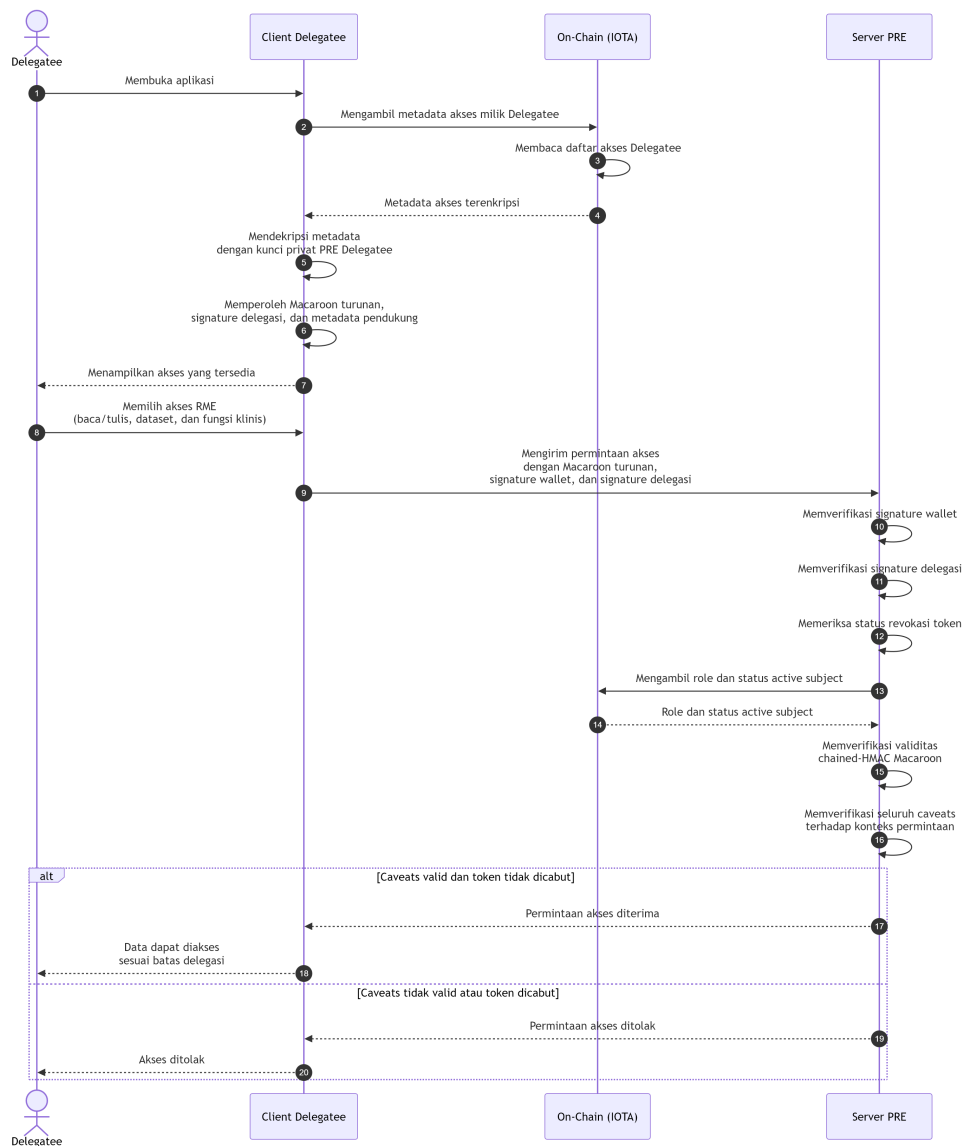
Bagian kedua dari proses ini adalah pengambilan dan penggunaan token Macaroon delegasi oleh *delegatee*. Bagian ini terjadi setelah metadata akses terenkripsi berhasil dicatat pada blockchain. Alur pengambilan dan penggunaan token Macaroon delegasi ditunjukkan pada Gambar III.8.

Berdasarkan Gambar III.8, ketika *delegatee* membuka aplikasi, *client* mengambil metadata akses terenkripsi yang tersimpan pada blockchain. Metadata tersebut kemudian didekripsi secara lokal menggunakan kunci privat PRE milik *delegatee*. Apabila proses dekripsi berhasil, aplikasi memperoleh token Macaroon turunan beserta metadata pendukungnya. Token Macaroon turunan tersebut kemudian dapat digunakan sebagai token otorisasi ketika *delegatee* mengirim permintaan akses baca atau tulis ke *Server* PRE. Selain membentuk token turunan, aplikasi *client* juga membentuk bukti delegasi yang di-*sign* menggunakan *wallet* milik *delegator*. Bukti ini digunakan agar *Server* PRE dapat memastikan bahwa token turunan memang dibuat oleh pihak yang berwenang dalam rantai delegasi.

Pada tahap penggunaan token, *Server* PRE melakukan penegakan otoritas terhadap token Macaroon yang dikirimkan oleh *delegatee* sesuai Subbab III.3.5. Evaluasi

tersebut menerapkan $\text{Permit}(q)$ pada Persamaan III.28, mencakup pemeriksaan validitas token, status revokasi, bukti kepemilikan *wallet*, rantai delegasi, serta seluruh *caveat* terhadap konteks permintaan akses. Apabila seluruh kondisi terpenuhi, permintaan akses diterima sesuai batas delegasi yang diberikan. Sebaliknya, apabila terdapat kondisi yang tidak terpenuhi, keputusan akses adalah Deny sesuai Persamaan III.29.

Dengan mekanisme ini, IOTA digunakan sebagai media pencatatan dan distribusi metadata akses yang dapat diaudit, sedangkan kerahasiaan token tetap dilindungi melalui enkripsi. Token Macaroon tidak tersedia dalam bentuk terbuka pada *state on-chain*, sehingga pihak selain *delegatee* tidak dapat langsung memanfaatkan metadata akses yang tercatat pada blockchain. Selain itu, karena kapabilitas yang



Gambar III.8: Sequence diagram pengambilan dan penggunaan token Macaroon delegasi

Tabel III.17: Pemetaan Rancangan terhadap Solusi

ID	Nama Rancangan	Merealisasikan Solusi
R-TA-01	Rancangan arsitektur solusi DecMed dengan PBAC, Macaroons, segmentasi, dan PRE sebagai <i>policy enforcement point</i> .	S-TA-01, S-TA-02, S-TA-03, S-TA-04
R-TA-02	Rancangan segmentasi data RME berdasarkan <i>dataset</i> dan <i>function category</i> .	S-TA-02
R-TA-03	Rancangan model PBAC pada DecMed.	S-TA-01
R-TA-04	Rancangan representasi kapabilitas pada <i>caveats</i> Macaroons dan rantai delegasi.	S-TA-03
R-TA-05	Rancangan penegakan <i>policy</i> akses berdasarkan kapabilitas efektif token Macaroon dan bukti kepemilikan <i>wallet</i> pada <i>Server</i> PRE.	S-TA-01, S-TA-04
R-TA-06	Rancangan validasi <i>subrole</i> tenaga kesehatan terhadap <i>dataset category</i> .	S-TA-05
R-TA-07	Rancangan revokasi berantai dan pencatatan audit akses/delegasi token Macaroons.	S-TA-06
R-TA-08	Rancangan alur akses dan delegasi pada skenario layanan kesehatan kolaboratif.	S-TA-03, S-TA-04, S-TA-05

diturunkan dari *policy* akses dibawa melalui *caveats* pada Macaroon, *server* PRE tetap dapat menegakkan batas delegasi pada saat token digunakan.

Untuk mengurangi risiko *delegator* melakukan delegasi akses berlebihan, jumlah delegasi yang dapat dilakukan oleh seorang pemegang hak akses dapat dibatasi dengan mencatat jumlah delegasi yang telah dilakukan oleh *delegator* pada penyimpanan *on-chain*. Jumlah delegasi ini dapat diperiksa oleh *server* PRE saat memverifikasi *request* delegasi. Apabila jumlah delegasi melebihi batas yang ditentukan, *server* PRE menolak *request* delegasi. Jumlah delegasi ini dapat dibatasi dengan aturan bahwa seorang *delegator* hanya dapat melakukan delegasi sebanyak 1 kali untuk setiap *role*.

III.3.7 Pemetaan Rancangan terhadap Solusi

Setelah rancangan solusi diuraikan, setiap rancangan dipetakan kembali terhadap solusi yang telah dianalisis pada Subbab III.2.6. Melalui pemetaan ini, keterkaitan langsung setiap rancangan R-TA dengan solusi S-TA yang diusulkan ditunjukkan. Hasil pemetaan rancangan terhadap solusi ditunjukkan pada Tabel III.17.

BAB IV

IMPLEMENTASI DAN PENGUJIAN

IV.1 Lingkungan Implementasi

Implementasi sistem dilakukan pada lingkungan prototipe yang merepresentasikan komponen utama DecMed, yaitu *patient client*, *hospital client*, *ministry client*, *Server PRE*, penyimpanan *off-chain* IPFS, Redis, IOTA *Gas Station*, dan *smart contract* IOTA Move pada jaringan IOTA Localnet. Lingkungan ini dipilih agar rancangan pada Bab III dapat diuji tanpa bergantung pada integrasi langsung dengan sistem informasi rumah sakit yang sesungguhnya.

Pada implementasi DecMed sebelumnya, semua komponen dijalankan pada lingkungan lokal. Semua *client*, *Server PRE*, Redis PRE, kluster IPFS, IOTA *Gas Station*, dan jaringan IOTA jenis Localnet dijalankan langsung di komputer lokal. Perangkat lokal yang digunakan tidak cukup kuat untuk menjalankan semua komponen secara bersamaan. Oleh karena itu, dilakukan pembagian komponen implementasi tersebut ke dalam lingkungan lokal dan dua buah *Virtual Private Server* (VPS).

Komponen *client* dan *Server PRE* dijalankan pada lingkungan lokal. Lingkungan lokal digunakan untuk memudahkan pengembangan fitur, pengujian alur akses, dan pengamatan sistem. Komponen pendukung yang membutuhkan ketersediaan jaringan, yaitu kluster IPFS dan IOTA *Gas Station*, dijalankan pada VPS. *Smart contract* IOTA Move di-deploy pada jaringan IOTA Localnet yang juga berjalan di VPS. IOTA Localnet digunakan karena sudah memadai untuk menyimulasikan interaksi dengan jaringan IOTA. VPS digunakan untuk menjalankan komponen pendukung karena komponen tersebut tidak banyak berubah selama implementasi, tetapi tetap dibutuhkan selama pengembangan. Beban perangkat lokal juga dikurangi melalui pemanfaatan VPS karena perangkat lokal tidak perlu menjalankan seluruh komponen pendukung.

Berikut adalah spesifikasi dari perangkat lokal yang digunakan untuk implementasi:

- Sistem Operasi: Ubuntu 24.04.4, berjalan di lingkungan WSL2
- CPU: Intel Core i5-11400H (3 core fisik dan 6 *logical thread* dialokasikan untuk WSL2)
- Memori RAM: 16 GB (8 GB teralokasi untuk WSL2)
- *Tools*:
 - Rust (rustc 1.93.0, cargo 1.93.0)
 - Node.js v24.13.0
 - Docker 29.5.3

Sementara itu, spesifikasi kedua VPS yang digunakan adalah sebagai berikut:

- Sistem Operasi: Ubuntu 24.04.4 LTS
- Jumlah vCPU: 8 vCPU
- Memori RAM: 8 GB
- *Tools*:
 - Docker: Docker 29.4.2

IV.2 Implementasi Sistem

Bagian ini menjabarkan realisasi teknis dari rancangan pada Bab III. Narasi konsep dan alur yang sudah ditetapkan di Bab III dirujuk ulang; fokus di sini adalah komponen kode, antarmuka, dan perilaku konkret sistem.

Daftar komponen dan keterkaitannya dengan rancangan ditunjukkan pada Tabel IV.1. ID I-TA dipakai sebagai rujukan. R-TA-01 (arsitektur) mencakup keseluruhan sistem sehingga tidak muncul sebagai baris tersendiri.

IV.2.1 Batasan Implementasi

Implementasi mempertahankan arsitektur kerangka kerja DecMed sebagaimana dijelaskan pada Subbab III.3.1. Komponen perangkat lunak mengikuti dependensi implementasi DecMed sebelumnya; daftar dependensi langsung setiap komponen

Tabel IV.1: Daftar Implementasi Sistem

ID	Komponen	Merealisasikan Rancangan
I-TA-01	<i>Crate decmed-rme-segment</i> .	R-TA-02
I-TA-02	<i>Crate decmed-macaroon-auth</i> dan <i>Crate macaroon</i> .	R-TA-04, R-TA-05
I-TA-03	Implementasi penegakan otoritas pada <i>Server PRE</i> .	R-TA-05, R-TA-06, R-TA-07
I-TA-04	Implementasi <i>smart contract</i> IOTA Move untuk metadata segmen, akses, dan audit.	R-TA-02, R-TA-04, R-TA-07
I-TA-05	Implementasi <i>Patient Client</i> untuk pemberian akses awal, pencabutan, dan audit.	R-TA-07, R-TA-08
I-TA-06	Implementasi <i>Hospital Client</i> untuk akses baca dan tulis segmen RME dan delegasi antartanaga kesehatan.	R-TA-02, R-TA-04, R-TA-08

disajikan pada Lampiran J. Batasan lingkungan eksekusi, konfigurasi IPFS, tingkat segmentasi data, dan nilai `max_delegation_depth` diuraikan pada Subbab IV.4.2.

IV.2.2 Implementasi Arsitektur Sistem

Implementasi mengikuti rancangan pada Subbab III.3.1 (Gambar III.2). Selain perubahan komponen pada Subbab III.3, kode bersama yang sebelumnya terduplikasi antarmodul dipisahkan menjadi *crate* Rust agar lebih mudah dipelihara.

Crate yang diimplementasikan dan digunakan adalah *decmed-rme-segment* dan *decmed-macaroon-auth*. *decmed-rme-segment* berisi definisi struktur segmentasi RME, definisi *dataset category* dan *function category*, serta fungsi pendukungnya. Sementara itu, *decmed-macaroon-auth* berisi implementasi token otorisasi berbasis Macaroons di DecMed, termasuk pembuatan token, atenuasi token, dan proses verifikasi. *crate decmed-macaroon-auth* memiliki dependensi utama yaitu *crate macaroon* yang merupakan *crate open source* implementasi Macaroons dengan pembaruan *dependency*. *decmed-rme-segment* digunakan oleh *Patient Client*, *Hospital Client*, dan *Server PRE*, sedangkan *decmed-macaroon-auth* digunakan oleh *Hospital Client* dan *Server PRE*. *Ministry Client* tidak memiliki dependensi langsung terhadap kedua *crate* tersebut karena perannya tetap terbatas pada kebutuhan registrasi dan aktivasi rumah sakit. Hubungan antarkomponen implementasi dan dependensi *crate* bersama ditunjukkan pada *package diagram* pada Gambar IV.1 dengan legenda dari *package diagram*

tersebut dapat dilihat pada Lampiran K.

Dengan pemisahan tersebut, implementasi segmentasi data dan otorisasi tidak tersebar sebagai kode duplikatif pada setiap komponen.

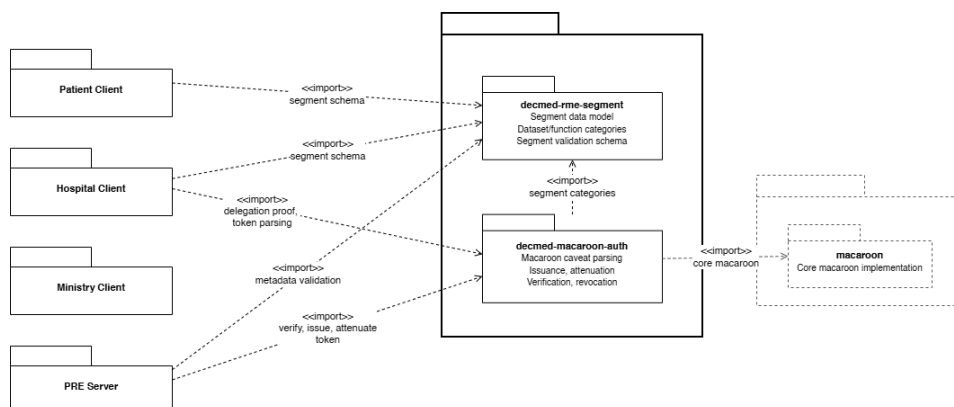
IV.2.3 Implementasi Segmentasi Data RME

Segmentasi mengikuti rancangan pada Subbab III.3.2 dan diwujudkan pada *crate* *decmed-rme-segment*. *Crate* ini mendefinisikan *DatasetCategory* dan *FunctionCategory* sebagai atribut objek untuk penegakan *policy*. Rincian modul ada pada Lampiran L. Implementasi enum ditunjukkan pada Kode IV.1 dan IV.2.

```
1      pub enum DatasetCategory {  
2          RAWAT_JALAN,  
3          RAWAT_INAP,  
4          LABORATORIUM,  
5          APOTEK,  
6      }
```

Kode IV.1: Implementasi *DatasetCategory* pada *crate* *decmed-rme-segment*

```
1      pub enum FunctionCategory {  
2          // ADMINISTRATIVE  
3          ADMINISTRATIVE_GENERAL,  
4  
5          // RAWAT_JALAN & RAWAT_INAP  
6          ANAMNESIS,
```



Gambar IV.1: Package Diagram Implementasi

```

7      PEMERIKSAAN_FISIK,
8      PEMERIKSAAN_PSIKOLOGIS,
9      RIWAYAT_PENGUNAAN_OBAT,
10     RENCANA_RAWAT,
11     INSTRUKSI_MEDIK_DAN_KEPERAWATAN,
12     PEMERIKSAAN_PENUNJANG,
13     DIAGNOSIS,
14     INFORMED_CONSENT,
15     TERAPI,
16
17     // RAWAT_INAP
18     PERENCANAAN_PEMULANGAN,
19
20     // LABORATORIUM
21     LABORATORIUM,
22
23     // APOTEK
24     PERESEPAN,
25     DISPENSING,
26 }

```

Kode IV.2: Implementasi FunctionCategory pada *crate* decmed-rme-segment

IV.2.3.1 Implementasi Segmentasi Metadata RME pada Penyimpanan *On-Chain*

RmeSegmentMetadata merepresentasikan metadata segmen sebelum diserialisasi menjadi JSON base64 dan disimpan pada *field* metadata milik PatientMedicalMetadata (Kode III.2). Struktur mengikuti skema Lampiran Tabel G.1; implementasinya pada Kode IV.3.

```

1 pub struct RmeSegmentMetadata {
2     pub segment_id: String,
3     pub related_rme_id: String,
4     pub patient_address: String,
5     pub author_address: String,

```

```

6     pub hospital_cid: String,
7     pub dataset_category: DatasetCategory,
8     pub function_category: FunctionCategory,
9     pub ipfs_cid: String,
10    pub integrity_hash: String,
11    pub capsule: String,
12    pub enc_key_and_nonce: String,
13    pub created_at: String,
14 }

```

Kode IV.3: Implementasi struktur RmeSegmentMetadata pada *crate* *decmed-rme-segment*

Sebelum disimpan ke IOTA, metadata divalidasi: setiap *field* wajib terisi, kombinasi *dataset_category* dan *function_category* sah, serta *integrity_hash* sesuai data terenkripsi.

IV.2.3.2 Implementasi Segmentasi Data RME pada Penyimpanan *Off-Chain*

RmeSegmentData merepresentasikan segmen sebelum enkripsi di sisi *client*, sesuai skema Lampiran Tabel G.2. Implementasinya pada Kode IV.4. Pada implementasi ini, *payload* bertipe *Value* dan berisi data berbentuk *text*; *payload_hash* adalah hash integritas dari konten *payload*.

```

1  pub struct RmeSegmentData {
2      pub segment_id: String,
3      pub related_rme_id: String,
4      pub dataset_category: DatasetCategory,
5      pub function_category: FunctionCategory,
6      pub patient_address: String,
7      pub service_date: String,
8      pub author_address: String,
9      pub payload: Value,
10     pub payload_hash: String,
11 }

```

Kode IV.4: Implementasi struktur `RmeSegmentData` pada *crate* `decmed-rme-segment`

Saat penyimpanan, *Hospital Client* membentuk objek per segmen, mengenkripsinya, mengunggah ke IPFS, lalu menyimpan CID bersama metadata pada IOTA sebagai JSON base64 di *field* metadata milik `PatientMedicalMetadata`. Pendekatan ini menjaga kompatibilitas dengan daftar metadata *flat* DecMed, sambil memungkinkan PRE membaca kategori segmentasi dari isi metadata.

IV.2.4 Implementasi Token Otorisasi Berbasis Macaroons

IV.2.4.1 Komponen Implementasi Macaroons

Seperti yang sudah dijelaskan pada subbab IV.2.2, terdapat dua *crate* yang berkaitan dengan implementasi Macaroons pada implementasi Tugas Akhir ini, yaitu `macaroon` dan `decmed-macaroon-auth`.

Crate `macaroon` merupakan hasil penyesuaian dari implementasi Macaroons berbasis Rust yang tersedia secara *open source* pada URL <https://github.com/macaroon-rs/macaroon>. Penyesuaian dilakukan karena *crate* asli memerlukan beberapa penyesuaian agar lebih sesuai dengan kebutuhan implementasi sistem DecMed, terutama dari sisi kompatibilitas *toolchain* dan pengelolaan *dependency*. Perubahan utama pada *crate* `macaroon` adalah penggantian *dependency* kriptografi berbasis `sodiumoxide` dengan *crate* pure Rust, yaitu `hmac`, `sha2`, `chacha20poly1305`, dan `rand`.

Setelah perubahan tersebut diterapkan, *unit testing* pada *crate* dijalankan untuk memastikan bahwa fungsi utama Macaroons tetap berjalan dengan benar. Pengujian tersebut mencakup pembuatan Macaroon, penambahan *caveat*, serialisasi, deserialisasi, dan verifikasi token. Dengan demikian, *crate* `macaroon` digunakan sebagai fondasi implementasi Macaroons pada sistem DecMed.

`decmed-macaroon-auth` merupakan *wrapper* yang dibangun untuk mempermudah penggunaan *crate* `macaroon` pada implementasi sistem DecMed. *Wrapper* ini menyediakan fungsi-fungsi utilitas untuk kebutuhan otorisasi

Tabel IV.2: *Caveats* yang Diimplementasikan pada Token Macaroon

<i>Caveat</i>	Tipe Data
patient_address	String (alamat IOTA format heksadesimal)
related_rme_id	String (ID episode RME)
root_subject	String (alamat IOTA format heksadesimal)
delegated_by	String (alamat IOTA format heksadesimal)
delegated_to	String (alamat IOTA format heksadesimal)
read_dataset_in	HashSet<DatasetCategory>
write_dataset_in	HashSet<DatasetCategory>
read_function_in	HashSet<FunctionCategory>
write_function_in	HashSet<FunctionCategory>
expires_before	DateTime<Utc> (YYYY-MM-DD HH:MM:SS)
max_delegation_depth	u32
hospital_cid	String (CID IPFS)
parent_token_hash	String (hash SHA-256 dari token induk)
purpose	String (nilai: Read atau Update)

DecMed, seperti proses penerbitan token Macaroon, atenuasi dengan penambahan *caveat* baru, definisi struktur *caveats* Macaroon, verifikasi Macaroon, dan fungsi pendukung lainnya. Rincian modul dan implementasi yang diimplementasikan pada *crate* decmed-macaroon-auth ditunjukkan pada Lampiran M.

IV.2.4.2 Struktur *Caveats* Macaroons

Struktur *caveats* pada token Macaroon pada implementasi ini ditunjukkan pada Tabel IV.2. *Caveats* terdefinisi pada *crate* decmed-macaroon-auth. *Hospital Client* mengirim parameter akses sesuai daftar tersebut, sedangkan *Server PRE* yang menerbitkan atau mengatenuasi token. *PRE* menolak permintaan jika terdapat *caveat* di luar daftar yang didukung.

IV.2.4.3 Penerbitan Token Macaroon

Penerbitan mengikuti rancangan pada Subbab III.3.4. *PRE* menerbitkan token setelah permintaan pasien valid, melalui fungsi `issue_admin_personnel_token` pada *crate* decmed-macaroon-auth. Token Read dan Update memakai subset *caveat* dari Tabel IV.2: token baca memakai `read_dataset_in/read_function_in` dan `purpose = Read`; token tulis memakai `related_rme_id`, `write_dataset_in/write_function_in`, dan `purpose = Update`. Detail *endpoint*, material *PRE*, dan pencatatan *on-chain* ada pada Subbab IV.2.5.

IV.2.4.4 Atenuasi Token Macaroon

Atenuasi dipicu dari *Hospital Client* dan dijalankan di PRE melalui `attenuate_macaroon` pada *crate* `decmed-macaroon-auth`: deserialisasi token induk, penambahan *caveat* (dengan *chained-HMAC* baru), lalu serialisasi ulang. Alur delegasi dan parameter permintaan dijelaskan pada Subbab IV.2.5.

IV.2.4.5 Revokasi Token Macaroon

Revokasi mengikuti rancangan pada Subbab III.3.5 dan melibatkan IOTA, Redis PRE, serta *Server* PRE. Token turunan menautkan induk lewat `parent_token_hash`. Saat permintaan akses, PRE memeriksa *hash* token dan seluruh `parent_token_hash` terhadap kunci Redis `revoked:token:<hash>`; jika ada yang cocok, permintaan ditolak. Status hak akses *on-chain* juga ditandai *revoked*.

IV.2.5 Delegasi Akses dan Atenuasi Token

Subbab ini merealisasikan rancangan alur pada Subbab III.3.6. Fokus pembahasan adalah detail implementasi—format data, *endpoint*, penyimpanan Redis, dan struktur bukti—tanpa mengulang narasi skenario pelayanan yang sudah diuraikan pada Bab III.

IV.2.5.1 Delegasi Akses dari Pasien kepada Petugas Rekam Medis

Implementasi mengikuti rancangan pada Subbab III.3.6.1. Detail teknis yang diwujudkan sebagai berikut.

QR code *AdministrativePersonnel* memuat *string* berformat `{hospitalCid}@{personnelIota}@{personnelPrePK}`, yaitu *hospital_cid*, alamat IOTA petugas, dan PRE *public key* petugas (base64). Setelah *scan*, *Patient Client* memanggil *smart contract* `get_hospital_personnel_info` untuk memuat identitas publik petugas. Pasien memilih *RAWAT_JALAN* atau *RAWAT_INAP* serta mode akses *read*, *update*, atau *read.update*. Batas waktu bawaan adalah 1 hari untuk *RAWAT_JALAN* dan 3 hari untuk *RAWAT_INAP*; nilai `expires_before` khusus tetap didukung.

Patient Client meminta *nonce* melalui *endpoint* `/nonce`. Sebelum diterbitkan,

PRE memeriksa registrasi pasien lewat `is_patient_registered`. *Nonce* ditandatangani dengan kunci IOTA pasien. Bersamaan itu, *Patient Client* membuat `data_pre_secret_key_seed`, menurunkan `data_pre_public_key`, mengenkripsi *seed* dengan `personnel_pre_public_key`, dan membentuk `k_frag` dari PRE *secret key* pasien menuju `data_pre_public_key`. Material PRE disimpan di Redis dengan TTL mengikuti waktu kedaluwarsa token.

Permintaan penerbitan dikirim ke *endpoint* `/keys` dengan *payload*: alamat IOTA pasien dan petugas, `hospital_cid`, `encounter_dataset`, mode akses, *signature* pasien, `k_frag`, `data_pre_public_key`, `enc_data_pre_secret_key_seed`, `data_pre_secret_key_seed_capsule`, `patient_pre_public_key`, dan `signer_pre_public_key`. PRE memverifikasi *signature* terhadap *nonce* dan memastikan *role* penerima adalah `AdministrativePersonnel`. Jika valid, PRE membentuk `MacaroonKey` dari `RootKey` dan menerbitkan token sesuai mode. Susunan *caveat* token Read dan Update mengikuti Tabel IV.2 dan Subbab IV.2.4.3. Pada token Update, `write_dataset_in` dibatasi pada `encounter_dataset` yang dipilih, ditambah `LABORATORIUM` dan `APOTEK`; `write_function_in` diturunkan dari kategori fungsi dalam cakupan tersebut.

`related_rme_id` hanya dibuat jika akses mencakup Update, dengan format `RME-{sequence_6_digit}` (misalnya `RME-000001`); *sequence* disimpan di Redis. Material akses PRE disimpan dengan kunci Redis `{personnel_iota_address}@{patient_iota_address}`. Respons ke *Patient Client* memuat `access_token_read`, `access_token_update`, *hash* masing-masing token, serta `related_rme_id` bila ada. Token dan metadata akses dienkripsi dengan `personnel_pre_public_key`, lalu dicatat ke IOTA melalui `create_access`.

IV.2.5.2 Delegasi Akses Antartenanaga Kesehatan

Implementasi mengikuti rancangan pada Subbab III.3.6.2 dan III.3.6.3, dengan pemetaan *subrole* pada Tabel III.14.

Delegator memilih *delegatee* melalui `get_delegatee_candidates` (alamat IOTA dan PRE *public key* penerima). *Hospital Client* memuat material kriptografis *delegator*, mendekripsi `data_pre_secret_key_seed`, lalu mengenkripsi ulang

seed dengan PRE *public key delegatee*. Permintaan atenuasi ke PRE memuat token induk, cakupan yang diminta, waktu kedaluwarsa, alamat *delegator/delegatee/pasien*, tanda tangan delegasi induk bila token induk hasil delegasi, serta *delegation_request_signature* (tanda tangan IOTA atas *DelegationRequestProofContext*).

PRE memverifikasi token induk (*chained-HMAC* dan status revokasi), memvalidasi bahwa cakupan turunan adalah subset dari *EffectiveCapability* induk (Kode IV.6), lalu memeriksa metadata akses di IOTA melalui *get_delegation_access_snapshot* (kedaluwarsa hak *delegator*, kesamaan fasyankes, kedalaman delegasi, dan absennya delegasi aktif untuk *subrole* yang sama). Jika lolos, atenuasi dilakukan lewat *attenuate_macaroon* pada *crate decmed-macaroon-auth*. Contoh *caveat* turunan sesuai *preset* ada pada Lampiran H.

Setelah token turunan diterima, *client* membentuk bukti dengan *DelegationProofContext* (Kode IV.5). Nilai *scope_fingerprint* adalah *hash* berpola *r:{ds_read}|w:{ds_write}|rf:{fn_read}|wf:{fn_write}*. Konteks tersebut diserialisasi dan ditandatangani dengan kunci IOTA *delegator*.

```
1 pub struct DelegationProofContext {
2     pub token_hash: String,
3     pub delegated_by: String,
4     pub delegated_to: String,
5     pub related_rme_id: String,
6     pub expires_before: String,
7     pub scope_fingerprint: String,
8 }
```

Kode IV.5: Definisi *DelegationProofContext*

Metadata delegasi (token turunan, *hash*, tanda tangan, metadata akses, dan *seed* yang dienkripsi ulang) dienkripsi dengan PRE *public key delegatee*, lalu dicatat melalui *create_delegated_access*. Fungsi tersebut memvalidasi status *delegatee*, kesamaan fasyankes, dan validitas akses *delegator*, kemudian menulis entri akses serta audit (alamat *delegator*, *root subject*, *delegatee*, jenis akses, *related_rme_id*, kedalaman, *hash* token turunan/induk, dan kedaluwarsa).

Tabel IV.3: Status Implementasi Penegakan Otoritas pada *Server* PRE

Bagian	Status
Validasi <i>Bearer Macaroon</i>	Terimplementasi.
Validasi <i>chained-HMAC</i> pada token Macaroon	Terimplementasi.
<i>Parsing caveats</i> pada token Macaroon	Terimplementasi.
Perhitungan <i>EffectiveCapability</i>	Terimplementasi.
Pembentukan himpunan subjek rantai melalui <i>DelegationChain</i>	Terimplementasi.
Pemeriksaan revokasi token melalui Redis	Terimplementasi.
Verifikasi <i>wallet signature</i> terhadap subjek rantai dan konteks akses segmen	Terimplementasi.
Pemeriksaan <i>role</i> dan <i>subrole</i> aktor melalui <i>Move Smart Contract</i>	Terimplementasi.
Validasi aksi baca dan tulis terhadap cakupan <i>dataset</i> dan <i>function</i>	Terimplementasi.

Pada delegasi pertama dari *AdministrativePersonnel* ke *MedicalPersonnel*, *function category* *ADMINISTRATIVE_GENERAL* ditambahkan pada setiap *dataset category* yang didelegasikan, sesuai Lampiran A. Saat akses digunakan, verifikasi mengikuti Subbab IV.2.6; material PRE di Redis dicari berdasarkan aktor pemohon, aktor pada rantai delegasi, hingga *root_subject*.

IV.2.6 Implementasi Penegakan Otoritas

Penegakan otoritas pada *Server* PRE merealisasikan $\text{Permit}(q)$ dan $\text{TokenUsable}(\tau, q)$ sesuai Subbab III.3.5 dan model PBAC pada Subbab III.3.3. Subbab ini menguraikan struktur data, *middleware*, *header*, dan status implementasi, bukan mengulang definisi predikat kebijakan.

Alur implementasi disajikan pada Lampiran N (Gambar N.2 dan N.3). Daftar *endpoint* REST API ada pada Lampiran O. Status implementasi ditunjukkan pada Tabel IV.3.

IV.2.6.1 Autentikasi Token Macaroon

Middleware PRE membaca token dari *header* *Authorization* skema *Bearer*, mendeserialisasi token, mem-*parsing caveats* *DecMed*, dan memverifikasi *chained-HMAC* dengan *RootKey*. Token yang gagal deserialisasi, bukan token *DecMed*, atau *HMAC*-nya tidak valid ditolak.

Dari *caveats* yang valid, PRE membentuk *EffectiveCapability* (Kode

IV.6): irisan untuk *caveat* bertipe himpunan, dan nilai paling awal untuk *expires_before*. *DelegationChain* (Kode IV.7) menentukan subjek berwenang melalui *subjects()* (*root_subject* plus seluruh *delegated_to*); keanggotaan diperiksa lewat *contains_subject()*, dan setiap langkah delegasi harus tersambung konsisten.

```
1 pub struct EffectiveCapability {
2     pub read_datasets: HashSet<DatasetCategory>,
3     pub write_datasets: HashSet<DatasetCategory>,
4     pub read_functions: HashSet<FunctionCategory>,
5     pub write_functions: HashSet<FunctionCategory>,
6     pub expires_before: Option<DateTime<Utc>>,
7     pub root_max_delegation_depth: Option<u32>,
8     pub remaining_max_delegation_depth: Option<u32>,
9     pub patient_address: Option<String>,
10    pub related_rme_id: Option<String>,
11    pub hospital_cid: Option<String>,
12 }
```

Kode IV.6: Definisi *EffectiveCapability*

```
1 pub struct DelegationStep {
2     pub delegated_by: String,
3     pub delegated_to: String,
4 }
5
6 pub struct DelegationChain {
7     pub root_subject: String,
8     pub steps: Vec<DelegationStep>,
9 }
```

Kode IV.7: Definisi *DelegationStep* dan *DelegationChain*

Setelah kedua struktur terbentuk, PRE menolak token jika *expires_before* sudah lewat atau jumlah *steps* pada rantai melebihi *max_delegation_depth*.

IV.2.6.2 Pemeriksaan Status Revokasi Token

Revokasi diperiksa di Redis dengan kunci `revoked:token:<token_hash>`, termasuk *hash* pada *caveat* `parent_token_hash`, sesuai Subbab III.3.5.4.

IV.2.6.3 Verifikasi Bukti Kepemilikan *Wallet*

Bukti dikirim lewat *header* `x-decmed-wallet-signature` dan `x-decmed-wallet-timestamp`, ditandatangani atas `WalletProofContext` (Kode IV.8). PRE mencocokkan tanda tangan terhadap `DelegationChain::subjects()`; jika cocok, alamat tersebut menjadi identitas pemohon untuk pemeriksaan lanjutan. Timestamp diterima dalam rentang 5 menit. *Smart contract* IOTA tidak memverifikasi `WalletProofContext`; kontrak hanya menyediakan atribut kelembagaan setelah alamat terbukti di PRE.

```
1 pub struct WalletProofContext {
2     pub token_id: String,          // ID Macaroon
3     pub patient_address: String, // Alamat pasien
4     pub related_rme_id: String, // ID episode RME
5     pub operation: AccessMode,    // Read / Update
6     pub segment_id: String,       // ID segmen yang diakses
7     pub dataset_category: DatasetCategory,
8     pub function_category: FunctionCategory,
9     pub timestamp: String,        // YYYY-MM-DD HH:MM:SS
10 }
```

Kode IV.8: Struktur `WalletProofContext` sebagai konteks verifikasi *wallet signature*

Pada jalur baca, jika tanda tangan belum disertakan, PRE mengembalikan 401 `UNAUTHORIZED` berisi `proof_context` agar *client* menandatangani dan mengirim ulang permintaan.

IV.2.6.4 Verifikasi *Role* dan *Subrole* melalui *Move Smart Contract*

Setelah *wallet proof* berhasil, PRE memanggil `get_hospital_personnel_auth_info` untuk memperoleh *role* dan *subrole* on-chain. Pemetaan hak tulis mengikuti Tabel III.14 pada Subbab III.3.5.2.

IV.2.6.5 Verifikasi Konteks Segmen

Pada *handler* baca, metadata segmen diambil dari IOTA lalu didekode dari JSON base64. Pada tulis, metadata *preview* dibentuk dari *payload*. Konteks digabung sebagai `SegmentAccessContext` (`segment_id`, `patient_address`, `related_rme_id`, `dataset_category`, `function_category`) dan dibandingkan dengan `EffectiveCapability`: baca terhadap `read_dataset_in/read_function_in`; tulis terhadap `write_dataset_in/write_function_in` beserta kesesuaian `related_rme_id` dan `hospital_cid`. Pemeriksaan *role/subrole* untuk tulis mengacu pada Tabel III.14; `AdministrativePersonnel` hanya dapat menulis `ADMINISTRATIVE_GENERAL`.

IV.2.6.6 Eksekusi Operasi *Re-encryption*, IPFS, dan IOTA

Setelah otorisasi lolos, PRE menghubungkan *ciphertext* di IPFS, metadata di IOTA, material `k_frag/c_frag` di Redis, dan respons ke *client*. Dasar PRE dan analisis perannya dijelaskan pada Subbab II.4.1 dan III.2.5. Alur baseline DecMed diilustrasikan pada Gambar IV.2–IV.5; skema metadata pada Lampiran G. Respons tulis berisi ringkasan metadata segmen. PRE hanya mengubah akses terhadap capsule; *plaintext* dan kunci AES muncul di sisi *client* setelah dekripsi valid.

IV.2.7 Implementasi *Smart Contract IOTA Move*

Smart contract IOTA Move menyimpan metadata segmentasi dan kontrol akses sesuai Subbab III.3.2 dan III.3.1. Penyimpanan metadata klinis tetap *flat* melalui `medical_metadata: TableVec<PatientMedicalMetadata>` (`index` dan `metadata`); isi segmentasi diserialisasi sebagai JSON base64 di dalam metadata agar PRE dapat membaca kategori sebelum memutuskan akses.

Fungsi kontrak mencakup pembuatan/pembaruan/pembacaan metadata RME, penyimpanan metadata akses personel, dan audit delegasi. Operasi ubah metadata hanya dijalankan oleh aktor dengan akses tulis yang sah. Rincian *module* dan *method* ada pada Lampiran P.

IV.2.8 Implementasi *Patient Client*

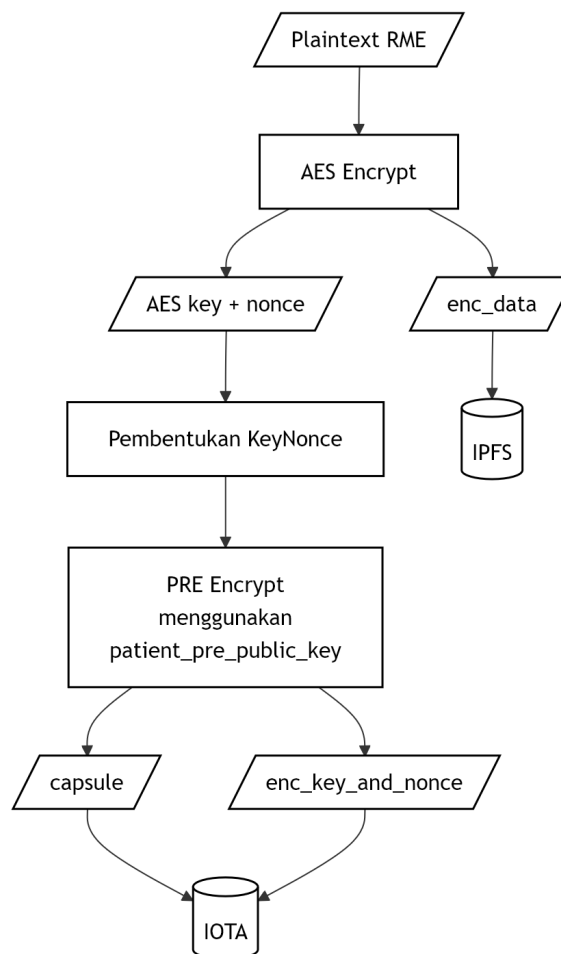
Patient Client disesuaikan untuk penerbitan token awal, pembacaan RME tersegmentasi, audit delegasi, dan pencabutan akses. Tangkapan layar ada pada Lampiran Q. Halaman lama DecMed (register, login, profil, log akses, dan sejenisnya) diadaptasi; penyesuaian utama diuraikan berikut.

IV.2.8.1 Halaman *Home* (*List RME*)

Halaman utama menampilkan daftar RME pasien sebagai *card* (tanggal dan ID), diurutkan dari yang terbaru, dengan navigasi ke halaman detail. Tampilan pada Gambar Q.1.

IV.2.8.2 Halaman Detail RME

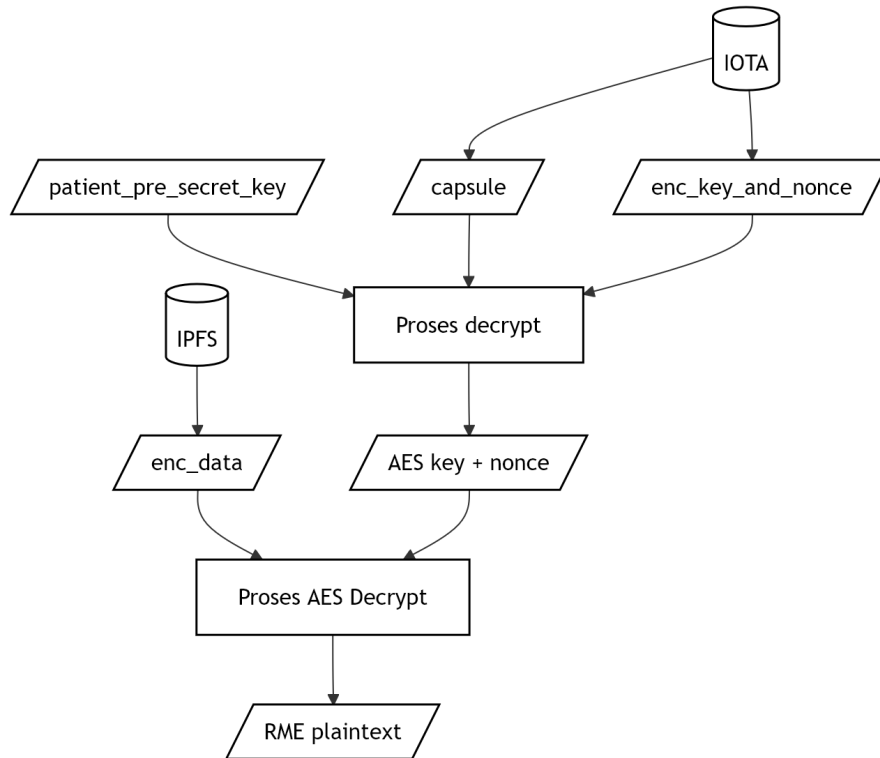
Detail RME dikelompokkan per *dataset category* melalui *tab*; setiap entri menampilkan *function category* terkait. Tampilan pada Gambar Q.2.



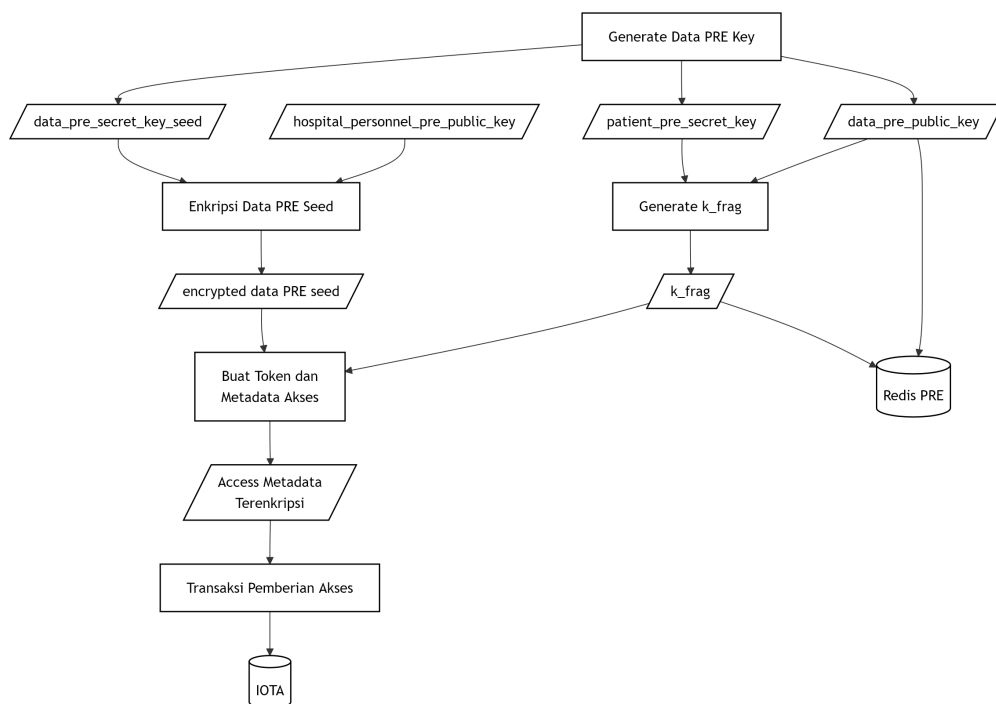
Gambar IV.2: Proses enkripsi dan penyimpanan RME

IV.2.8.3 Halaman Audit Delegasi

Halaman ini menampilkan rantai delegasi dari token yang diterbitkan pasien: penerima akses awal, jenis akses, ID RME, kedaluwarsa, dan status (*Active/Expired/Revoked*), beserta subdaftar pasangan delegasi. Tampilan pada



Gambar IV.3: Proses dekripsi RME oleh pasien



Gambar IV.4: Proses pembentukan akses PRE saat pemberian akses

Gambar Q.3.

IV.2.8.4 Halaman Detail *Scan QR*

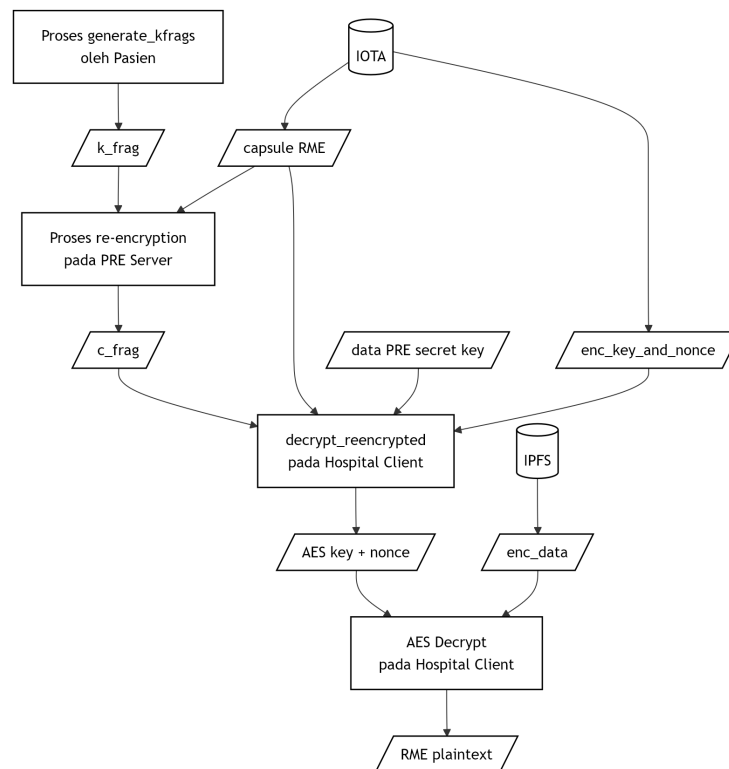
Pasien mengunggah gambar QR (PNG/JPEG) untuk memulai pemberian akses. Setelah validasi, dialog konfirmasi menampilkan identitas petugas/fasyankes serta konfigurasi layanan (RAWAT_JALAN/RAWAT_INAP), mode akses (*Read/Update*/keduanya), dan kedaluwarsa, diikuti verifikasi PIN enam digit sebelum token diterbitkan. Alur teknis penerbitan ada pada Subbab IV.2.5.1. Tampilan pada Gambar Q.4 dan Q.5.

IV.2.9 Implementasi *Hospital Client*

Hospital Client mendukung penggunaan token, atenuasi untuk delegasi, serta baca/tulis segmen RME. Tangkapan layar ada pada Lampiran R.

IV.2.9.1 Halaman *Dashboard (List RME)*

Untuk *MedicalPersonnel*, dashboard bersifat *role-based* dengan tab *Read* dan *Write* yang memuat daftar pasien sesuai kapabilitas token. Tab baca mengarah



Gambar IV.5: Proses *re-encryption* dan dekripsi oleh *Hospital Client*

ke daftar RME; tab tulis mengarah ke formulir penulisan segmen. Tampilan pada Gambar R.1.

IV.2.9.2 Halaman Delegasi Akses

Formulir delegasi memungkinkan pemilihan pasien, mode (*Read/Write*/keduanya), *preset role* penerima, kedaluwarsa (dibatasi token induk), pratinjau cakupan *dataset/function category*, dan pemilihan kandidat personel fasyankes. Alur teknis atenuasi ada pada Subbab IV.2.5.2. Tampilan pada Gambar R.2 dan R.3.

IV.2.9.3 Halaman Daftar RME Pasien

Daftar RME pasien menampilkan ID, tanggal, dan *badge dataset category* per card, dengan navigasi ke detail serta konteks token lewat *query string*. Tampilan pada Gambar R.4.

IV.2.9.4 Halaman Baca Detail RME

Detail dikelompokkan per *dataset category*; payload segmen dimuat *on-demand* (textarea hanya-baca, atau tabel untuk ADMINISTRATIVE_GENERAL), dengan metadata yang dapat ditampilkan/disembunyikan. Tampilan pada Gambar R.5.

IV.2.9.5 Halaman Tulis Segmen RME

Formulir tulis hanya menampilkan *dataset/function category* yang diizinkan token aktif; hanya entri terisi yang dikirim saat tombol *Write* ditekan. Tampilan pada Gambar R.6.

IV.3 Pengujian Sistem

Pengujian sistem dilakukan untuk memastikan implementasi memenuhi kebutuhan yang sudah didefinisikan pada Subbab III.1.3.

IV.3.1 Strategi Pengujian

Strategi pengujian disusun berdasarkan kebutuhan sistem pada Tabel III.3 dan III.4. Pengujian dibagi menjadi pengujian kebutuhan fungsional dan pengujian kebutuhan nonfungsional.

Pengujian kebutuhan fungsional diberi ID P-KF dan dijalankan melalui skenario manual untuk memeriksa perilaku sistem dari sudut pandang aktor layanan kesehatan. Pengujian kebutuhan nonfungsional diberi ID P-KNF dan dijalankan melalui pengujian unit atau integrasi terhadap komponen token, segmentasi data, validasi akses, metadata RME, dan *Server PRE*. *Unit testing* tersebut menyimulasikan skenario ancaman STRIDE yang relevan terhadap kebutuhan nonfungsional. Pengujian otomatis dijalankan dengan *cargo test* pada komponen yang relevan.

Kriteria keberhasilan pengujian ditentukan berdasarkan kesesuaian hasil skenario manual terhadap kebutuhan fungsional dan kelulusan pengujian otomatis terhadap kebutuhan nonfungsional.

IV.3.2 Pengujian Kebutuhan Fungsional

Pengujian kebutuhan fungsional dijalankan secara manual untuk memastikan perilaku sistem sesuai dengan rancangan alur akses dan delegasi pada Subbab III.3.6.

Rincian pengujian kebutuhan fungsional disajikan pada Lampiran I, Tabel I.1. Terdapat 12 skenario pengujian dengan ID P-KF-01 sampai P-KF-12 yang dijalankan untuk alur Rawat Jalan dan Rawat Inap. Perbedaan kedua alur tersebut terdapat pada keberadaan segmen data PERENCANAAN_PEMULANGAN yang hanya muncul pada alur Rawat Inap. Delegasi akses dijalankan mengikuti *preset* yang sudah terdefinisi, sehingga dihasilkan token turunan dengan *caveats* sesuai dengan Lampiran H.

IV.3.3 Pengujian Kebutuhan Nonfungsional

Pengujian kebutuhan nonfungsional dijalankan untuk mengevaluasi pemenuhan aspek keamanan dan keterlacakan pada sistem, khususnya pada komponen yang menangani token Macaroon, segmentasi data RME, validasi akses, *wallet proof*, revokasi, pencatatan delegasi, dan *Server PRE*. Setiap pengujian dikaitkan dengan kebutuhan nonfungsional yang telah didefinisikan pada Tabel III.4. Untuk memudahkan ketertelusuran evaluasi, pengujian yang terkait kebutuhan nonfungsional diberi ID P-KNF. *Unit testing* pada bagian ini menyimulasikan

skenario ancaman yang telah diidentifikasi melalui analisis STRIDE pada Subbab III.1.1.4, khususnya ancaman yang dipetakan ke kebutuhan nonfungsional.

IV.3.3.1 Pengujian KNF-TA-01

Pengujian KNF-TA-01 memastikan bahwa penerima akses hanya dapat memperoleh data RME dalam bentuk *plaintext* apabila segmen yang diminta berada dalam cakupan otorisasi token. Dengan demikian, permintaan terhadap segmen di luar cakupan harus ditolak sebelum proses *re-encryption* menghasilkan data yang dapat didekripsi oleh penerima akses. Pengujian ini menguji mitigasi terhadap skenario ancaman T05 (*information disclosure*) pada Tabel E.1.

Pengujian pertama, yaitu P-KNF-01, dijalankan melalui *unit testing* pada komponen PRE dan menyimulasikan skenario T05, yaitu upaya memperoleh segmen data di luar cakupan otorisasi. Kondisi ketika aktor memiliki token baca, tetapi token tersebut tidak mencakup akses baca terhadap segmen data laboratorium, disimulasikan pada tes ini. Kemudian fungsi yang diuji, yaitu `verify_segment_access`, dipanggil dengan parameter Macaroon tanpa akses ke laboratorium dan segmen data laboratorium. Pada tes ini, akses diharapkan ditolak. Kode pengujian dapat dilihat pada Kode IV.9.

```
1  #[test]
2  fn pre_rejects_segment_outside_caveats() {
3      let (_token, mac, verified) = verified_read_token();
4      let outside_scope = segment(
5          DatasetCategory::LABORATORIUM,
6          FunctionCategory::LABORATORIUM,
7      );
8
9      let err = verify_segment_for_token(
10         ...,
11         &outside_scope,
12         &mac,
13     )
14     .unwrap_err();
15     // assert error DatasetCategoryNotAllowed
16 }
```

Kode IV.9: Pengujian P-KNF-01 untuk KNF-TA-01

Pengujian kedua, yaitu P-KNF-02, dijalankan melalui *client hospital* dan menyimulasikan skenario T05, yaitu kebocoran data akibat akses lintas kewenangan aktor. Pengujian ini memastikan aktor apoteker tidak dapat membuka atau memperoleh segmen data laboratorium. Pada skenario ini, akun apoteker tidak memiliki caveat akses terhadap kategori laboratorium, sehingga segmen laboratorium tidak ditampilkan sebagai data yang dapat diakses.

IV.3.3.2 Pengujian KNF-TA-02

Pengujian KNF-TA-02 memastikan integritas token otorisasi dan *caveats* tetap terjaga selama proses delegasi. Secara khusus, pengujian diarahkan untuk memastikan bahwa token turunan tidak dapat memperluas cakupan akses, menaikkan kedalaman delegasi, atau memperpanjang masa berlaku melebihi token induk. Pengujian ini menguji mitigasi terhadap skenario ancaman T05 dan T08 pada Tabel E.1.

Pengujian pertama, yaitu P-KNF-03, dijalankan melalui *unit testing* pada Kode IV.10 dan menyimulasikan skenario T05 serta T08, yaitu perluasan hak tulis melalui delegasi. Pada tes ini dipastikan bahwa token delegasi tidak dapat menambahkan hak akses *write_function* yang tidak dimiliki oleh *parent token*. Ketika *child token* mencoba meminta *write_functions* di luar scope *parent token*, proses *attenuate_macaroon()* ditolak dengan error *DelegationExpandsAccess*.

```
1  #[test]
2  fn cannot_delegate_write_function_from_parent_read_only_scope() {
3      let write_functions: Vec<_> = ... // tidak mencakup PERESEPAN
4      let parent = scoped_token(
5          ...
6          &write_functions,
7          Some("Read"),
8      );
9      let params = DelegationAttenuationParams {
10         write_functions: vec![FunctionCategory::PERESEPAN],
```



```

11      ...
12  };
13  let err = attenuate_macaroon(&parent, &params).unwrap_err();
14  // assert error DelegationExpandsAccess
15  }

```

Kode IV.10: Pengujian P-KNF-03 untuk KNF-TA-02

Pengujian kedua, yaitu P-KNF-04, dijalankan melalui *unit testing* pada Kode IV.11 dan menyimulasikan skenario T08, yaitu eskalasi hak melalui penambahan kedalaman delegasi. Pada tes ini dipastikan bahwa batas kedalaman delegasi tidak dapat dinaikkan oleh token turunan. Jika *child token* mencoba menetapkan *max_delegation_depth* lebih besar dari batas *parent token*, delegasi ditolak dengan error *DelegationDepthNotMonotonic*.

```

1  #[test]
2  fn cannot_increase_max_delegation_depth_on_delegate() {
3      let mut params = DelegationAttenuationParams {
4          ...,
5          max_delegation_depth: 99
6      };
7      let err = attenuate_macaroon(
8          &doctor_token(), // max depth 1
9          &params
10     )
11     // assert error DelegationDepthNotMonotonic
12 }

```

Kode IV.11: Pengujian P-KNF-04 untuk KNF-TA-02

Pengujian ketiga, yaitu P-KNF-05, dijalankan melalui *unit testing* pada Kode IV.12 dan menyimulasikan skenario T05 serta T08, yaitu perluasan cakupan dataset melalui delegasi. Pada tes ini dipastikan bahwa delegasi dari token admin write tetap tidak dapat memperluas cakupan dataset. Ketika *child token* mencoba meminta *write_datasets* di luar cakupan *parent token*, sistem menolak dengan error *DelegationExpandsAccess*.

```

1  #[test]
2  fn admin_write_true_expansion_still_fails() {
3      let params = DelegationAttenuationParams {
4          ...,
5          write_datasets: vec![DatasetCategory::RAWAT_INAP],
6      };
7      let err = attenuate_macaroon(
8          &admin_write_token(), // write token RAWAT_JALAN
9          &params
10     )
11     // assert error DelegationExpandsAccess
12 }

```

Kode IV.12: Pengujian P-KNF-05 untuk KNF-TA-02

Pengujian terakhir, yaitu P-KNF-06, dijalankan melalui *client hospital* dan menyimulasikan skenario T08, yaitu eskalasi hak melalui perpanjangan masa berlaku token turunan. Pengujian ini memastikan sistem menolak atenuasi hak akses dengan batas waktu yang melebihi masa berlaku token induk. Pada skenario ini, notifikasi *error* ditampilkan pada halaman delegasi ketika pengguna mencoba membuat token turunan dengan waktu kedaluwarsa yang lebih panjang daripada token induk.

IV.3.3.3 Pengujian KNF-TA-03

Pengujian KNF-TA-03 memastikan permintaan akses ditolak apabila token, rantai delegasi, atau bukti kepemilikan identitas aktor pemohon tidak valid. Pengujian ini menguji mitigasi terhadap skenario ancaman T01, T02, dan T08 pada Tabel E.1.

Pengujian pertama, yaitu P-KNF-07, dijalankan melalui *unit testing* pada Kode IV.13 dan menyimulasikan skenario T01, yaitu penggunaan token akses yang tidak lagi sah. Pada tes ini dipastikan bahwa token yang sudah melewati batas waktu berlaku tidak dapat digunakan untuk mengakses segmen RME. Pada skenario ini, waktu verifikasi dibuat berada setelah waktu kedaluwarsa token. Sistem menolak permintaan akses dengan error *ExpiredToken*.

```

1  #[test]
2  fn expired_token_rejected() {
3      let mac = ... // token dokter, expired 2026-07-02
4      let future = ... // 2031-01-01T00:00:00+00:00
5      let err = verify_decmed_token(
6          ...
7          &mac,
8          &ctx({
9              ...,
10             now: future,
11         }),
12      )
13      // assert error ExpiredToken
14  }

```

Kode IV.13: Pengujian P-KNF-07 untuk KNF-TA-03

Pengujian kedua, yaitu P-KNF-08, dijalankan melalui *unit testing* pada Kode IV.14 dan menyimulasikan skenario T02, yaitu manipulasi metadata rantai delegasi pada token. Pada tes ini dipastikan bahwa rantai delegasi yang tidak valid akan ditolak. Pada pengujian ini, token dimodifikasi dengan caveat *delegated_by* yang tidak sesuai dengan rantai delegasi semestinya. Ketika token diverifikasi, sistem menolak permintaan dengan error *InvalidDelegationChain*.

```

1  #[test]
2  fn broken_delegation_chain_rejected() {
3      let mut mac = ... // token dokter
4      add_caveat_to_macaroon(&mut mac, "delegated_by", "0xAPOTEK");
5      add_caveat_to_macaroon(&mut mac, "delegated_to", LAB);
6      let err = verify_ctx(
7          &mac,
8          ...
9      )
10      // assert error InvalidDelegationChain
11  }

```

Kode IV.14: Pengujian P-KNF-08 untuk KNF-TA-03

Pengujian ketiga, yaitu P-KNF-09, dijalankan melalui *unit testing* pada Kode IV.15 dan menyimulasikan skenario T01, yaitu penggunaan token oleh pihak yang bukan subjek sah pada rantai delegasi. Pada tes ini dipastikan bahwa bukti kepemilikan *wallet* harus cocok dengan salah satu subjek pada rantai delegasi. Pada skenario ini, token memuat rantai yang mencakup aktor LAB, tetapi permintaan pertama menggunakan tanda tangan dari aktor di luar rantai. Sistem menolak permintaan dengan error `InvalidWalletSignature`.

```
1  #[test]
2  fn wallet_proof_must_match_chain_subject() {
3      let mac = ... // token dengan subjects memuat LAB
4      let verifier = ChainSubjectVerifier {
5          subjects: vec![LAB],
6          valid_sig: "lab-sig",
7      };
8      let ctx = TokenVerificationContext {
9          ...,
10         wallet_signature: Some("outsider-sig"),
11     };
12     let err = verify_decmed_token(
13         &mac,
14         &ctx,
15         Some(&verifier),
16     )
17     // assert error InvalidWalletSignature
18 }
```

Kode IV.15: Pengujian P-KNF-09 untuk KNF-TA-03 dan KNF-TA-06

IV.3.3.4 Pengujian KNF-TA-04

Pengujian KNF-TA-04 memastikan sistem menyediakan keterlacakan akses dan delegasi melalui pencatatan metadata yang dapat ditinjau kembali oleh pasien. Pengujian ini menguji mitigasi terhadap skenario ancaman T04 pada Tabel E.1.

Pengujian P-KNF-10 dijalankan melalui *client* pasien dan menyimulasikan skenario T04, yaitu kebutuhan jejak audit agar pemberian atau penggunaan akses tidak

dapat disangkal. Skenario dimulai dari pemberian akses awal oleh pasien kepada petugas rekam medis, kemudian dilanjutkan dengan delegasi dari petugas rekam medis kepada dokter. Setelah proses tersebut dijalankan, pasien membuka halaman riwayat delegasi untuk memastikan informasi delegator, delegatee, status, waktu, dan relasi delegasi dapat ditelusuri. Tangkapan layar halaman ini dapat dilihat pada Gambar Q.3.

IV.3.3.5 Pengujian KNF-TA-05

Pengujian KNF-TA-05 memastikan sistem menolak akses untuk hak akses yang sudah dicabut. Pengujian ini menguji mitigasi terhadap skenario ancaman T08 pada Tabel E.1.

Pengujian pertama, yaitu P-KNF-11, dijalankan melalui tes pada Kode IV.16 dan menyimulasikan skenario T08, yaitu upaya menggunakan kembali token yang telah dicabut. Pada tes ini dipastikan bahwa token yang sudah masuk daftar revokasi tidak dapat digunakan kembali. Pada skenario ini, token yang belum dicabut diverifikasi terlebih dahulu dan hasilnya berhasil. Setelah itu, revocation key token dibuat bernilai cocok dengan token yang sedang diverifikasi. Sistem kemudian menolak akses dengan status UNAUTHORIZED.

```
1  #[test]
2  fn revocation_key_rejects_revoked_token() {
3      let token = verified_read_token(); // token valid
4      let revoked_key = ... // hash token valid
5
6      ensure_token_not_revoked(
7          ...,
8          &token,
9          |_| Ok(false), // simulasi Redis kosong
10     ) // success
11
12     let err = ensure_token_not_revoked(
13         ...,
14         &token,
15         |key| Ok(key == revoked_key), // simulasi revoked key
16         // terdapat pada Redis
```

```

17     ) // error UNAUTHORIZED
18
19     // assert status UNAUTHORIZED
20 }

```

Kode IV.16: Pengujian P-KNF-11 untuk KNF-TA-05

Pengujian kedua, yaitu P-KNF-12, dijalankan melalui *client* pasien dan *client* *hospital* serta menyimulasikan skenario T08 pada rantai delegasi, yaitu penggunaan akses turunan setelah akses induk dicabut. Pengujian dimulai dengan pasien mencabut hak akses yang sebelumnya diberikan kepada petugas rekam medis. Setelah revokasi dijalankan, akses dicoba kembali dari akun petugas rekam medis dan dokter yang memperoleh delegasi. Sistem dinyatakan memenuhi kebutuhan apabila hak akses yang telah dicabut tidak lagi dapat digunakan dan tidak lagi muncul sebagai akses aktif pada halaman *Home* maupun halaman delegasi.

IV.3.3.6 Pengujian KNF-TA-06

Pengujian KNF-TA-06 memastikan bukti kepemilikan identitas terikat terhadap aktor pada rantai delegasi, token akses, dan konteks permintaan akses. Pengujian ini menguji mitigasi terhadap skenario ancaman T01 pada Tabel E.1.

Pengujian pertama, yaitu P-KNF-13, dijalankan melalui *unit testing* pada Kode IV.17 dan menyimulasikan skenario T01, yaitu penggunaan token sebagai *bearer token* tanpa bukti kepemilikan identitas. Pada tes ini dipastikan bahwa setiap permintaan akses menggunakan token DecMed harus menyertakan bukti kepemilikan identitas berupa tanda tangan wallet. Jika *wallet_signature* tidak diberikan, sistem menolak permintaan dengan error *WalletSignatureRequired*. Hal ini menunjukkan bahwa token akses saja tidak cukup untuk memperoleh akses tanpa bukti identitas dari aktor yang tercatat pada rantai.

```

1  #[test]
2  fn wallet_signature_required_for_every_decmed_token() {
3      let mac = ... // token dokter
4      let err = verify_decmed_token(
5          &mac,
6          ...,

```

```

7      &TokenVerificationContext {
8          ...,
9          wallet_signature: None, // tidak ada
10     },
11 )
12 // assert error WalletSignatureRequired
13 }

```

Kode IV.17: Pengujian P-KNF-13 untuk KNF-TA-06

Pengujian kedua dijalankan melalui P-KNF-09 pada Kode IV.15, sama dengan yang digunakan sebelumnya untuk menguji KNF-TA-03, dan kembali menyimulasikan skenario T01. Pada tes ini dipastikan bahwa bukti identitas harus cocok dengan salah satu subjek pada rantai delegasi. Token pada skenario ini memuat subjek LAB. Ketika permintaan menggunakan tanda tangan dari aktor di luar rantai, sistem menolak permintaan dengan error `InvalidWalletSignature`. Setelah tanda tangan diganti menjadi lab-sig, verifikasi token berhasil.

Pada implementasinya, fungsi `verify_decmed_token()` membentuk `WalletProofContext` dari token dan konteks akses yang sedang diminta. Konteks tersebut memuat `token_id`, alamat pasien, `related_rme_id`, mode operasi, `segment_id`, kategori dataset, kategori fungsi, dan timestamp. Konteks ini kemudian diverifikasi terhadap seluruh subjek pada `DelegationChain::subjects()`, sehingga bukti kepemilikan identitas terikat pada aktor yang tercatat dalam rantai delegasi.

IV.3.3.7 Pengujian KNF-TA-07

Pengujian KNF-TA-07 memastikan bahwa data RME terenkripsi yang disimpan di *off-chain* ditolak apabila *hash* integritas *ciphertext* tidak sesuai dengan nilai `integrity_hash` pada metadata segmen. Pengujian ini merupakan mitigasi terhadap skenario ancaman T03 pada Tabel E.1, khususnya manipulasi isi *blob* terenkripsi.

Pengujian pertama, yaitu P-KNF-14, dilakukan melalui *unit testing* terhadap fungsi validasi *hash* integritas, sebagaimana ditunjukkan pada Kode IV.18. Metadata dibuat menggunakan *hash* dari *ciphertext* asli, sedangkan proses

validasi diberikan *ciphertext* yang telah diubah. Sistem diharapkan menghasilkan `SegmentValidationError::InvalidIntegrityHash`.

```
1  #[test]
2  fn metadata_rejects_mismatched_ipfs_ciphertext_integrity_hash() {
3      let metadata =
4          sample_metadata(b"original encrypted segment");
5
6      assert_eq!(
7          metadata
8              .validate_integrity_hash(
9                  &STANDARD.encode(
10                     b"tampered encrypted segment"
11                 )
12             )
13          .unwrap_err(),
14          SegmentValidationError::InvalidIntegrityHash
15      );
16  }
```

Kode IV.18: Pengujian P-KNF-14 untuk KNF-TA-07

Pengujian kedua, yaitu P-KNF-15, dilakukan pada fungsi validasi integritas yang digunakan dalam jalur pembacaan data medis pada *Server PRE*, sebagaimana ditunjukkan pada Kode IV.19. Pengujian ini memastikan bahwa pemeriksaan integritas tidak hanya tersedia pada tipe metadata, tetapi juga diterapkan pada proses pembacaan data yang berasal dari penyimpanan IPFS.

```
1  #[test]
2  fn rejects_ipfs_ciphertext_with_mismatched_integrity_hash() {
3      let metadata =
4          stored_rme_metadata(b"original ciphertext");
5      let err = validate_stored_medical_data_integrity(
6          &metadata,
7          &STANDARD.encode(b"tampered ciphertext"),
8      )
9      .unwrap_err();
```



```

10     match err {
11         ProxyError::Anyhow { source, code } => {
12             assert_eq!(code, StatusCode::BAD_REQUEST);
13             assert_eq!(
14                 source.to_string(),
15                 "integrity_hash does not match encrypted segment"
16             );
17         }
18         other => panic!(
19             "expected integrity hash error, got {other:?}"
20         ),
21     }
22 }

```

Kode IV.19: Pengujian P-KNF-15 untuk KNF-TA-07

Berdasarkan kedua pengujian tersebut, KNF-TA-07 telah memitigasi manipulasi isi *blob* terenkripsi melalui pemeriksaan hash integritas. Akan tetapi, kontrol ini belum membuktikan keamanan terhadap seluruh variasi T03, terutama substitusi CID antarobjek, CID yang tidak valid, dan respons gateway IPFS yang tidak sesuai dengan CID yang diminta.

IV.3.3.8 Pengujian KNF-TA-08

Pengujian KNF-TA-08 memastikan bahwa representasi metadata segmen RME yang ditujukan untuk disimpan secara *on-chain* tidak memuat *payload* klinis dalam bentuk *plaintext*. Pengujian ini berkaitan dengan skenario ancaman T06 pada Tabel E.1, tetapi hanya mencakup pencegahan penyimpanan isi klinis secara langsung pada metadata.

Pengujian P-KNF-16 dilakukan melalui *unit testing*, sebagaimana ditunjukkan pada Kode IV.20. Struktur *RmeSegmentMetadata* diserialisasi menjadi objek JSON. Pengujian kemudian memastikan bahwa objek tersebut tidak memiliki *field* *payload* dan tidak memuat nama *field* medis *plaintext* yang dilarang, seperti *diagnose*, *diagnosis*, *hasil_lab*, dan *resep*.

```

1  #[test]

```

```

2 fn on_chain_metadata_does_not_contain_payload() {
3     let metadata = sample_metadata(b"encrypted segment");
4     metadata.validate().unwrap();
5     let value = serde_json::to_value(metadata).unwrap();
6     assert!(value.get("payload").is_none());
7     assert!(value.get("patient_address").is_some());
8     assert!(
9         assert_no_plaintext_medical_fields(&value).is_ok()
10    );
11 }

```

Kode IV.20: Pengujian P-KNF-16 untuk KNF-TA-08

Selain `patient_address`, struktur metadata masih dapat memuat `related_rme_id`, `hospital_cid`, kategori dataset, kategori fungsi, `ipfs_cid`, `author_address`, dan waktu pembuatan. Oleh karena itu, keberhasilan P-KNF-16 tidak membuktikan bahwa metadata telah melindungi privasi identitas dan relasi pasien secara keseluruhan. Pengujian ini juga belum membaca transaksi atau objek aktual dari jaringan IOTA. Dengan demikian, KNF-TA-08 hanya memverifikasi bentuk struktur metadata pada tingkat aplikasi dan belum mencakup pengujian observasi IOTA oleh pihak tanpa autentikasi, korelasi alamat pasien dengan tenaga kesehatan atau fasilitas pelayanan kesehatan, serta analisis kebocoran melalui argumen transaksi dan *event*.

Berdasarkan batasan tersebut, KNF-TA-08 merupakan mitigasi terhadap T06. Pengujian berhasil memastikan tidak adanya isi klinis *plaintext*, tetapi belum dapat digunakan untuk menyimpulkan bahwa metadata transaksi telah memenuhi perlindungan privasi secara menyeluruh.

IV.4 Evaluasi

Evaluasi dilakukan dengan membandingkan hasil implementasi dan pengujian terhadap kebutuhan sistem. Hasil evaluasi digunakan untuk menilai apakah pendekatan Macaroons, segmentasi data RME, dan penegakan akses pada *Server PRE* mampu menjawab keterbatasan kontrol akses pada DecMed awal.

Berdasarkan hasil pengujian kebutuhan fungsional dan nonfungsional, kebutuhan sistem yang diuji pada Tugas Akhir ini dinyatakan terpenuhi dalam batas skenario uji dan batasan prototipe yang ditetapkan.

IV.4.1 Evaluasi terhadap Kebutuhan Sistem

Berdasarkan kebutuhan sistem pada Subbab III.1.3, implementasi dievaluasi terhadap kebutuhan fungsional dan nonfungsional yang menjadi dasar pengembangan DecMed. Kebutuhan sistem pada Subbab III.1.3 dihubungkan dengan implementasi dan pengujian yang telah dijalankan. Setiap kebutuhan diperiksa berdasarkan komponen yang merealisasikannya dan skenario pengujian yang memverifikasi perilakunya. Pemetaan ini menunjukkan keterhubungan antara kebutuhan, implementasi, dan pengujian tanpa memisahkan ketiganya sebagai daftar yang berdiri sendiri.

Ringkasan pemetaan kebutuhan sistem terhadap implementasi dan pengujian disajikan pada Lampiran I, Tabel I.2. Hasil evaluasi menunjukkan bahwa kebutuhan fungsional dan nonfungsional yang diuji telah terpenuhi berdasarkan skenario pengujian manual serta pengujian unit atau integrasi yang dijalankan, sesuai batasan prototipe pada Subbab IV.4.2.

Implementasi Macaroons, segmentasi data RME, atenuasi delegasi yang dimediasi *Server* PRE, revokasi, audit delegasi, verifikasi bukti kepemilikan identitas aktor pada rantai delegasi, integritas *blob* terenkripsi, dan ketiadaan *payload* klinis plaintext pada metadata *on-chain* memenuhi kebutuhan yang diuji. Kebutuhan fungsional diverifikasi melalui skenario P-KF-01 sampai P-KF-12, sedangkan kebutuhan nonfungsional diverifikasi melalui pengujian P-KNF-01 sampai P-KNF-16. Keterlacakan antara masalah, kebutuhan, solusi, rancangan, implementasi, dan pengujian disajikan pada Lampiran ??.

IV.4.2 Keterbatasan Implementasi

Implementasi pada Tugas Akhir ini memiliki beberapa keterbatasan sebagai berikut:

1. Implementasi dilakukan dalam lingkungan komputer lokal, VPS, dan jaringan IOTA Localnet.

- Semua *client* dan *Server* PRE dijalankan langsung di komputer lokal.
 - VPS menjalankan kluster IPFS dan IOTA *Gas Station*.
 - *Smart contract* yang digunakan diunggah ke jaringan IOTA Localnet.
2. Kluster IPFS yang digunakan dalam implementasi hanya menggunakan konfigurasi *default* sesuai implementasi DecMed sebelumnya. Konfigurasi tersebut terdiri atas tiga buah *peers*.
 3. Segmentasi data sesuai dengan yang dibahas pada III.3.2 hanya dilakukan hingga tingkat kombinasi *dataset category* dan *function category*, kemudian disimpan sebagai *text*.
 4. `max_delegation_depth` pada token Macaroon hanya diatur sampai tingkat 2. Hal ini untuk memastikan bahwa token turunan hanya dapat diturunkan sebanyak 2 kali sesuai dengan skenario pada Subbab III.1.1.3 dan rancangan pada Subbab III.3.6.

Keterbatasan tersebut menunjukkan bahwa implementasi masih berada pada tingkat pembuktian konsep. Pengembangan berikutnya perlu memperluas cakupan pengujian keamanan, memperjelas mekanisme pencabutan akses, memperkuat verifikasi bukti delegasi dan *wallet proof*, serta menguji sistem pada lingkungan yang lebih dekat dengan operasional layanan kesehatan.

BAB V

PENUTUP

V.1 Kesimpulan

Penelitian ini menyimpulkan tiga hal berikut.

1. Kontrol akses granular pada DecMed dirancang dan diimplementasikan dengan Macaroons sebagai token otorisasi. Batasan akses direpresentasikan melalui *caveats* yang disusun berdasarkan *policy* PBAC, mencakup elemen aktor, objek RME, hak akses, dan kondisi akses. Penegakan otoritas dilakukan pada *Server PRE* sebelum data diakses.
2. Segmentasi data RME diterapkan dengan memecah data *off-chain* berdasarkan *dataset category* dan *function category*. Data RME tidak lagi diperlakukan sebagai satu *encrypted blob* besar, melainkan sebagai kumpulan segmen klinis. Metadata setiap segmen digunakan untuk menentukan segmen yang dapat diakses sesuai cakupan token.
3. Mekanisme atenuasi token diterapkan untuk mendukung pendelegasian akses antartanaga kesehatan tanpa penerbitan ulang oleh pasien pada setiap perpindahan akses. Macaroons secara konseptual mendukung atenuasi tanpa penerbit awal, sedangkan pada implementasi *Hospital Client* mengajukan permintaan atenuasi dan *Server PRE* membentuk token turunan dengan *caveats* yang mempersempit cakupan token induk. Pencatatan delegasi, *caveat* kedalaman delegasi, validasi agar token turunan tidak memperluas hak akses token induk, serta revokasi berantai juga dicakup dalam implementasi.

V.2 Saran

Berdasarkan batasan dan hasil evaluasi Tugas Akhir ini, beberapa saran untuk pengembangan berikutnya adalah sebagai berikut:

1. Cakupan skenario layanan klinis diperluas hingga pelayanan antarfasyankes,

termasuk rujukan antarfasyankes.

2. Skenario gawat darurat ditambahkan. Data IGD dan mekanisme akses ketika pasien tidak sadar perlu diimplementasikan agar pelayanan gawat darurat dapat didukung.
3. Integrasi dengan standar interoperabilitas data kesehatan dapat diteliti lebih lanjut. Segmentasi RME dapat dikembangkan untuk integrasi dengan SATUSEHAT atau pemetaan ke standar FHIR.
4. Integrasi dan pengujian dengan sistem rumah sakit dikembangkan untuk mendukung penggunaan sistem dalam konteks nyata, disesuaikan dengan tata laksana atau dokumen Pedoman Nasional Pelayanan Kesehatan.
5. Pengujian keamanan lebih lanjut dapat dijadikan penelitian lanjutan, misalnya pengujian penetrasi.

DAFTAR REFERENSI

- Amaracitra, D. S., & Alamsyah, A. (2025). Decentralized Medical Record Model Using Composable NFT: Achieving Data Security, Interoperability, and Privacy through Granular Data Access. *2025 15th International Conference on Electrical Engineering (ICEENG)*. <https://doi.org/10.1109/ICEENG64546.2025.11031352>
- Anagnostopoulou, A., Kehrioti, E., Mavridis, I., & Gritzalis, D. (2025). Bolstering IIoT Resilience: The Synergy of Blockchain and CapBAC. *Proceedings of the 22nd International Conference on Security and Cryptography (SECRYPT 2025)*, 120–131. <https://doi.org/10.5220/0013513800003979>
- Arciszewski, S., & Haussmann, S. (2022, Mei). PASETO: Platform-Agnostic Security Tokens [Work in Progress, expired Internet-Draft]. <https://datatracker.ietf.org/doc/html/draft-paragon-paseto-rfc-01>
- Benet, J. (2014, Juli). *IPFS — Content Addressed, Versioned, P2P File System*. arXiv: 1407.3561 [cs.NI]. <https://doi.org/10.48550/arXiv.1407.3561>
- Birgisson, A., Politz, J. G., Erlingsson, Ú., Taly, A., Vrabie, M., & Lentzner, M. (2014). Macaroons: Cookies with Contextual Caveats for Decentralized Authorization in the Cloud. *Proceedings of the 2014 Network and Distributed System Security Symposium (NDSS)*. <https://doi.org/10.14722/ndss.2014.23251>
- Blaze, M., Bleumer, G., & Strauss, M. (1998). Divertible Protocols and Atomic Proxy Cryptography. *Advances in Cryptology — EUROCRYPT '98*, 1403, 127–144. <https://doi.org/10.1007/BFb0054122>
- dCache. (nodate). *Chapter 1. Understanding Macaroons: dCache UserGuide 8.2*. dCache. Diakses pada Juni 16, 2026, dari <https://dcache.org/manuals/UserGuide-8.2/macaroons.shtml>
- Eclipse Biscuit Project. (nodate). *Biscuit Tokens*. Diakses pada Juni 4, 2026, dari <https://www.biscuitsec.org/>
- Ferraiolo, D. F., Gavrila, S., & Kemp, R. P. (2015, Oktober). *Policy Machine: Features, Architecture, and Specification* (NIST IR 7987 Revision 1) (Available from

<https://nvlpubs.nist.gov/nistpubs/ir/2015/nist.ir.7987r1.pdf>).

National Institute of Standards dan Technology (NIST).
<https://doi.org/10.6028/NIST.IR.7987r1>

for Standardization, I. O. (2014, Oktober). *Health informatics — Privilege management and access control — Part 2: Formal models* (techreport Nomor ISO 22600-2:2014) (Accessed: 2026-07-02). ISO. Geneva, Switzerland. Diakses pada Juli 2, 2026, dari <https://www.iso.org/standard/62654.html>

Hu, V. C., Ferraiolo, D. F., Kuhn, R. D., Schnitzer, A., Sandlin, K., Miller, R., & Scarfone, K. (2014). *Guide to Attribute Based Access Control (ABAC) Definition and Considerations* (NIST Special Publication Nomor 800-162) (Accessed: 2026-06-03). National Institute of Standards dan Technology. Gaithersburg, MD. <https://doi.org/10.6028/NIST.SP.800-162>

Peraturan Menteri Kesehatan Republik Indonesia Nomor 73 Tahun 2016 tentang Standar Pelayanan Kefarmasian di Apotek, Jakarta (2016, Desember 23). Diakses pada Juni 16, 2026, dari <https://farmalkes.kemkes.go.id/unduh/permenkes-73-2016/>

Joint Task Force Transformation Initiative. (2020). *Security and Privacy Controls for Information Systems and Organizations* (NIST Special Publication Nomor 800-53, Revision 5). National Institute of Standards dan Technology. Gaithersburg, MD. <https://doi.org/10.6028/NIST.SP.800-53r5>

Jones, L. A., Nelder, J. R., Fryer, J. M., Alsop, P. H., Geary, M. R., Prince, M., & Cardinal, R. N. (2022). Public opinion on sharing data from health services for clinical and research purposes without explicit consent: an anonymous online survey in the UK. *BMJ Open*, 12, Artikel jurnal e057579. <https://doi.org/10.1136/bmjopen-2021-057579>

Jones, M. B., Bradley, J., & Sakimura, N. (2015, Mei). *JSON Web Token (JWT)* (RFC Nomor 7519). Internet Engineering Task Force. <https://doi.org/10.17487/RFC7519>

Kementerian Kesehatan Republik Indonesia. (2022a, April). Keputusan Menteri Kesehatan Republik Indonesia Nomor HK.01.07/MENKES/1128/2022 tentang Standar Akreditasi Rumah Sakit [Ditetapkan di Jakarta]. Diakses pada Juli 1, 2026, dari https://keslan.kemkes.go.id/unduh/fileunduhan_1654499045_682777.pdf

- Kementerian Kesehatan Republik Indonesia. (2022b, Agustus). Peraturan Menteri Kesehatan Republik Indonesia Nomor 24 Tahun 2022 tentang Rekam Medis.
- Leffew, K. (2019, Desember 4). *Secure Access Control in the Decentralized Cloud*. Storj. Diakses pada Juni 16, 2026, dari <https://www.storj.io/blog/secure-access-control-in-the-decentralized-cloud>
- Li, A. S., Safavi-Naini, R., & Fong, P. W. L. (2022). A Capability-based Distributed Authorization System to Enforce Context-aware Permission Sequences. *Proceedings of the 27th ACM Symposium on Access Control Models and Technologies*, 195–206. <https://doi.org/10.1145/3532105.3535014>
- Liu, R., & Chen, P. (2025). Research on Access Control Model of Electronic Medical Records Based on Blockchain Technology. *2025 5th Asia-Pacific Conference on Communications Technology and Computer Science (ACCTCS)*, 662–665. <https://doi.org/10.1109/ACCTCS66275.2025.00066>
- Keputusan Menteri Kesehatan Republik Indonesia Nomor HK.01.07/Menkes/1423/2022 tentang Pedoman Variabel dan Metadata Rekam Medis, Jakarta (2022).
- Microsoft. (2006). *Uncover Security Design Flaws Using the STRIDE Approach*. Diakses pada April 1, 2026, dari <https://learn.microsoft.com/en-us/archive/msdn-magazine/2006/november/uncover-security-design-flaws-using-the-stride-approach>
- NHS England. (2025, Maret 14). *Consent to using and sharing patient information* (1.1). Diakses pada April 29, 2026, dari <https://www.england.nhs.uk/long-read/consent-to-using-and-sharing-patient-information/>
- Núñez, D. (2017). Umbral: A Threshold Proxy Re-Encryption Scheme [Available at <https://github.com/nucypher/umbral-doc/blob/master/umbral-doc.pdf>].
- Odugu, N. K., & Rajesh, A. (2021). A Fine-Grained Access Control Survey For The Secure Big Data Access [Accessed: 2026-06-03]. *Turkish Journal of Computer and Mathematics Education (TURCOMAT)*, 12(10), 4180–4186. <http://www.turcomat.org/index.php/turkbilmater/article/view/5141>
- of Health, U. D., & Services, H. (2009). *Minimum Necessary: guidance for covered entities* (techreport) (Accessed: 2026-07-02). Washington, D.C. Diakses pada Juli 2, 2026, dari <https://www.hhs.gov/sites/default/files/o%09cr/privacy/hipaa/understanding/coveredentities/minimumnecessary.pdf>

- Patil, S. P. (2024, Desember). *Blockchain Technology for Secure Healthcare Data Management with Patient Empowerment* [MSc Research Project]. National College of Ireland [MSc Cyber Security. Supervisor: Prof Liam McCabe. Word count: 6744]. <https://norma.ncirl.ie/8241/1/sidhantprakashpatil.pdf>
- Peng, G., Zhang, A., & Lin, X. (2023). Patient-Centric Fine-Grained Access Control for Electronic Medical Record Sharing With Security via Dual-Blockchain. *IEEE Transactions on Network Science and Engineering*, 10(6), 3908–3921. <https://doi.org/10.1109/TNSE.2023.3276166>
- Republik Indonesia. (2004, Oktober). Undang-Undang Nomor 29 Tahun 2004 tentang Praktik Kedokteran [LN. 2004/ No.116, TLN NO. 4431]. Diakses pada November 11, 2025, dari <https://peraturan.bpk.go.id/Details/40752/uu-no-29-tahun-2004>
- Sadewa, B. (2025). *Pengembangan Kontrol Akses dalam Kerangka Kerja Sistem Manajemen Rekam Medis Elektronik Berbasis IOTA* [Tugas Akhir]. Institut Teknologi Bandung. Diakses pada Maret 11, 2026, dari https://digilib.itb.ac.id/gdl/view_data/pengembangan-kontrol-akses-dalam-kerangka-kerja-sistem-manajemen-rekam-medis-elektronik-berbasis-iota/Bakta-Sadewa
- Sandhu, R., & Samarati, P. (1994). Access control: principle and practice. *IEEE Communications Magazine*, 32(9), 40–48. <https://doi.org/10.1109/35.312842>
- SATUSEHAT Platform. (nodate). *Rawat Inap*. Diakses pada Juni 30, 2026, dari <https://satusehat.kemkes.go.id/platform/docs/id/interoperability/rawat-inap-new/>
- SATUSEHAT Platform. (2023, Agustus 22). *Resume Medis - Rawat Jalan*. Diakses pada Juni 30, 2026, dari <https://satusehat.kemkes.go.id/platform/docs/id/interoperability/rme-rawat-jalan/>
- Savadatti, S. G., Krishnamoorthy, S., & Delhibabu, R. (2025). Survey of Distributed Ledger Technology (DLT) for Secure and Scalable Computing. *IEEE Access*, 13, 8393–8415. <https://doi.org/10.1109/ACCESS.2025.3528211>
- Sedi Nzakuna, P., Paciello, V., Lay-Ekuakille, A., Kuti Lusala, A., Dello Iacono, S., & Pietrosanto, A. (2025). From IOTA Tangle 2.0 to Rebased: A Comparative Analysis of Decentralization, Scalability, and Suitability for IoT Applications. *Sensors*, 25(11), 3408. <https://doi.org/10.3390/s25113408>
- Shostack, A. (2014). *Threat Modeling: Designing for Security*. Wiley.

- Singh, Y., Jaiswal, S., & Kumar, V. (2025). Granular Level Privacy Aware Access Control in Block Chain Based EHR Systems. *2025 12th International Conference on Reliability, Infocom Technologies and Optimization (Trends and Future Directions) (ICRITO)*. <https://doi.org/10.1109/ICRITO66076.2025.11241459>
- Srinivas, V., Choubey, U., Motwani, J., Anamika, F., Chennupati, C., Garg, N., Gupta, V., & Jain, R. (2023). Synergistic strategies: Optimizing outcomes through a multidisciplinary approach to clinical rounds. *Proceedings (Bayl Univ Med Cent)*, 37(1), 144–150. <https://doi.org/10.1080/08998280.2023.2274230>
- Undang-Undang Republik Indonesia Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi, Jakarta (2022, Oktober 17). Diakses pada Desember 20, 2025, dari <https://peraturan.bpk.go.id/Details/229798/uu-no-27-tahun-2022>
- World Health Organization. (2010, September 1). *Framework for Action on Interprofessional Education and Collaborative Practice*. World Health Organization. Geneva. Diakses pada Juni 16, 2026, dari <https://www.who.int/publications/i/item/framework-for-action-on-interprofessional-education-collaborative-practice>

Lampiran A. Metadata Rekam Medis Elektronik

Tabel berikut menjabarkan metadata variabel RME yang diadopsi dari KMK No. HK.01.07/MENKES/1423/2022 untuk dataset Rawat Jalan, Rawat Inap, Laboratorium, dan Apotek (Menteri Kesehatan Republik Indonesia, 2022). Klasifikasi dokumentasi pada tabel berikut diperoleh melalui interpretasi terhadap definisi operasional metadata yang tercantum pada dokumen KMK tersebut. Dokumentasi administratif tidak dibagi ke dalam segmentasi yang lebih rinci karena tidak menjadi fokus utama pada rancangan segmentasi data dalam Tugas Akhir ini.

Tabel A.1: Metadata Variabel RME Rawat Jalan

Kelompok Data	Subkelompok Metadata	Klasifikasi Dokumentasi
Lembar Identitas	Identitas pasien dan data dasar rekam medis	Administratif
Cara Pembayaran	Metode atau skema pembayaran pelayanan	Administratif
General Consent / Persetujuan Umum	Persetujuan umum pasien terhadap pelayanan	Administratif
Formulir Umum / Asesmen Awal Rawat Jalan	Anamnesis	Klinis
	Pemeriksaan Fisik	Klinis
	Pemeriksaan Psikologis, Sosial Ekonomi, Spiritual	Klinis
Pemeriksaan Spesialistik	Riwayat Penggunaan Obat	Klinis
	Rencana Rawat	Klinis
	Instruksi Medik dan Keperawatan	Klinis
	Pemeriksaan Penunjang	Klinis
	Diagnosis	Klinis
	Persetujuan Tindakan / Penolakan Tindakan (<i>Informed Consent</i>)	Klinis

Kelompok Data	Subkelompok Metadata	Klasifikasi Dokumentasi
	Terapi: Tindakan dan Obat / Peresepan	Klinis

Tabel A.2: Metadata Variabel RME Rawat Inap

Kelompok Data	Subkelompok Metadata	Klasifikasi Dokumentasi
Lembar Identitas	Identitas pasien dan data dasar rekam medis	Administratif
Cara Pembayaran	Metode atau skema pembayaran pelayanan	Administratif
General Consent / Persetujuan Umum	Persetujuan umum pasien terhadap pelayanan	Administratif
Formulir Rawat Inap	Anamnesis	Klinis
	Pemeriksaan Fisik	Klinis
	Pemeriksaan Psikologis, Sosial Ekonomi, Spiritual	Klinis
Pemeriksaan Spesialistik	Riwayat Penggunaan Obat	Klinis
	Perencanaan Pemulangan Pasien	Klinis
	Rencana Rawat	Klinis
	Instruksi Medik dan Keperawatan	Klinis
	Pemeriksaan Penunjang	Klinis
	Diagnosis	Klinis
	Persetujuan Tindakan / Penolakan Tindakan (<i>Informed Consent</i>)	Klinis
	Terapi	Klinis

Tabel A.3: Metadata Variabel RME Laboratorium

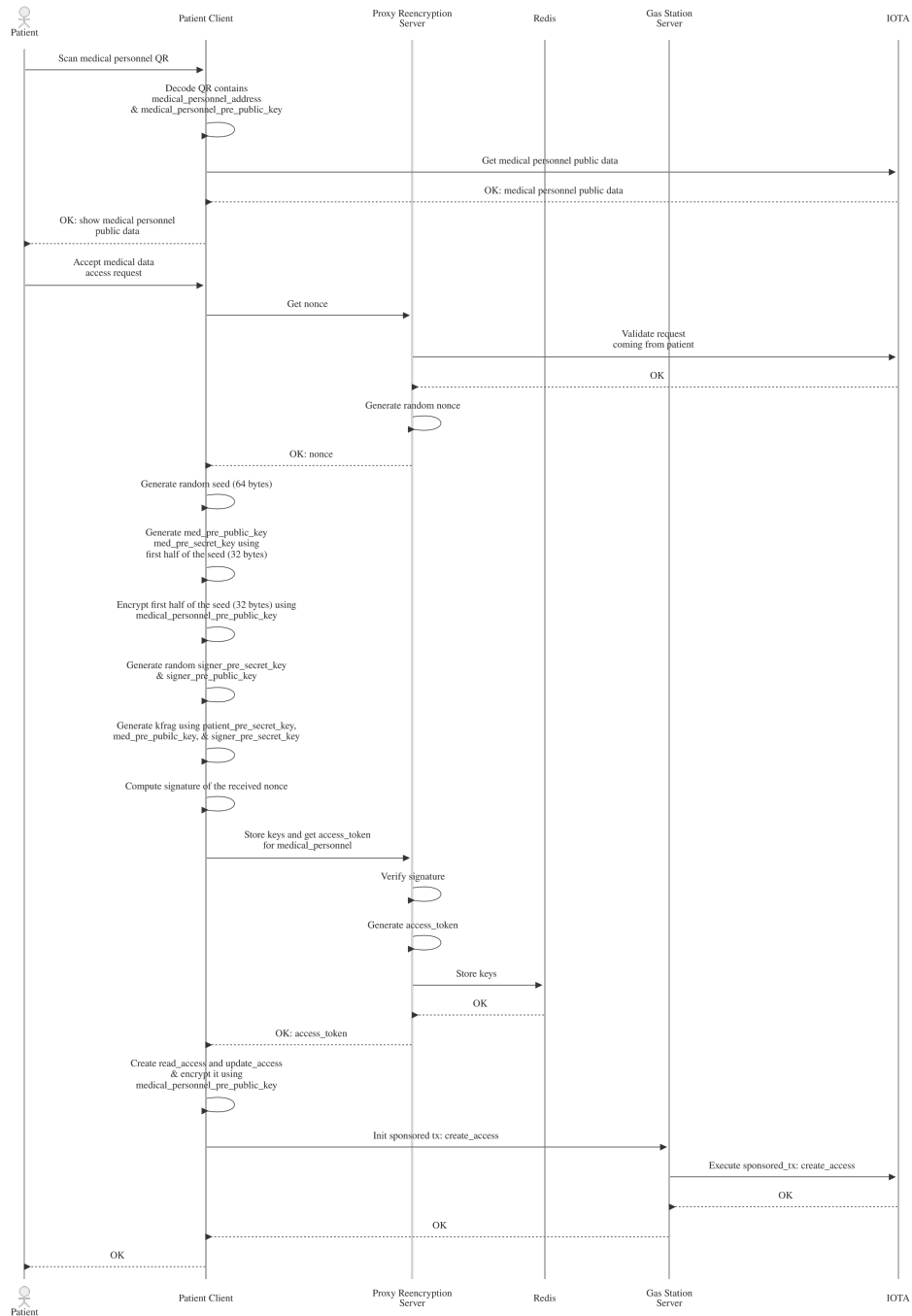
Kelompok Data	Subkelompok Metadata	Klasifikasi Dokumentasi
Laboratorium	Identitas Laboratorium dan Pasien	Administratif
	Permintaan Pemeriksaan	Klinis
	Spesimen Klinis	Klinis
	Fiksasi dan Pengolahan Spesimen	Klinis
	Hasil Pemeriksaan	Klinis
	Interpretasi dan Validasi Hasil	Klinis

Tabel A.4: Metadata Variabel RME Apotek

Kelompok Data	Subkelompok Metadata	Klasifikasi Dokumentasi
Peresepan	Identitas Pasien	Administratif
	Data Resep dan Obat	Klinis
	Riwayat Penggunaan Obat	Klinis
	Riwayat Alergi	Klinis
	Asal Resep	Klinis
	Dokter Penulis Resep	Klinis
	Status dan Pengkajian Resep	Klinis
Dispensing	Status Resep	Klinis
	Waktu Penyiapan Obat	Klinis
	Waktu Penyerahan Obat	Klinis
	Nama Petugas yang Melakukan Dispensing	Klinis
	Etiket	Klinis

Lampiran B. Alur Pemberian Akses Medis pada DecMed

Alur pemberian akses medis dari pasien kepada tenaga kesehatan pada implementasi DecMed saat ini dapat dilihat pada Gambar B.1.



Gambar B.1: *Sequence Diagram* Alur Pemberian Akses Medis dari Pasien kepada Tenaga Medis (Sadewa, 2025)

Lampiran C. Kebutuhan Fungsional DecMed

Tabel C.1: Kebutuhan Fungsional DecMed (Sadewa, 2025)

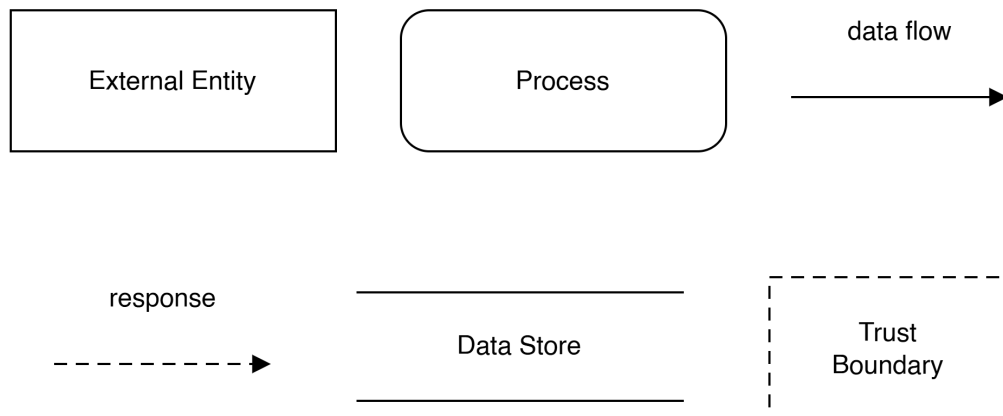
ID	Deskripsi
F01	Pasien dapat melakukan registrasi akun pada sistem
F02	Pasien dapat masuk ke akun menggunakan credentials yang dimiliki
F03	Pasien dapat keluar dari akun
F04	Pasien dapat melakukan scan kode QR yang dimiliki oleh masing-masing tenaga kesehatan dan petugas rekam medis
F05	Pasien dapat membaca seluruh RME yang ia miliki
F06	Pasien dapat memberikan akses baca bagian administratif dari data RME miliknya kepada petugas rekam medis untuk rentang waktu tertentu
F07	Pasien dapat memberikan akses baca bagian administratif dan klinis dari data RME miliknya kepada tenaga kesehatan untuk rentang waktu tertentu
F08	Pasien dapat melihat daftar log dari akses terhadap data RME yang dimiliki
F09	Pasien dapat mencabut akses yang telah diberikan. Akses tersebut berupa akses baca maupun tulis terhadap data RME.
F10	Tenaga kesehatan dapat melakukan aktivasi client
F11	Tenaga kesehatan dapat melakukan registrasi akun pada sistem
F12	Tenaga kesehatan dapat masuk ke akun menggunakan credentials yang dimiliki
F13	Tenaga kesehatan dapat keluar dari akun
F14	Tenaga kesehatan dapat membaca bagian administratif dan klinis dari data RME milik pasien setelah diberikan akses dalam waktu tertentu
F15	Tenaga kesehatan dapat menambahkan entri RME baru
F16	Tenaga kesehatan dapat mengedit bagian klinis dari entri RME baru yang dibuatnya pada rentang waktu yang telah ditentukan
F17	Petugas rekam medis dapat melakukan aktivasi client

Tabel C.1 – Lanjutan

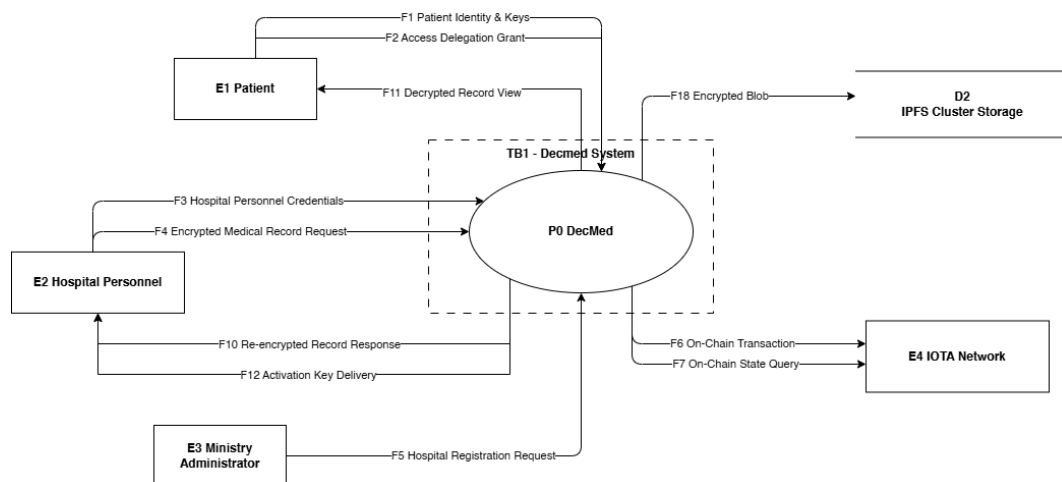
ID	Deskripsi
F18	Petugas rekam medis dapat melakukan registrasi akun pada sistem
F19	Petugas rekam medis dapat masuk ke akun menggunakan credentials yang dimiliki
F20	Petugas rekam medis dapat keluar dari akun
F21	Petugas rekam medis dapat membaca bagian administratif dari data RME milik pasien setelah diberikan akses dalam waktu tertentu
F22	Admin fasyankes dapat melakukan aktivasi client
F23	Admin fasyankes dapat melakukan registrasi akun pada sistem
F24	Admin fasyankes dapat masuk ke akun menggunakan credentials yang dimiliki
F25	Admin fasyankes dapat keluar dari akun
F26	Admin fasyankes dapat menambahkan personel fasyankes baru
F27	Admin fasyankes dapat membuat kunci aktivasi baru untuk personel fasyankes
F28	Kementerian kesehatan dapat mendaftarkan fasyankes dan admin untuk fasyankes tersebut
F29	Kementerian kesehatan dapat membuat kunci aktivasi baru untuk admin fasyankes

Lampiran D. DFD DecMed

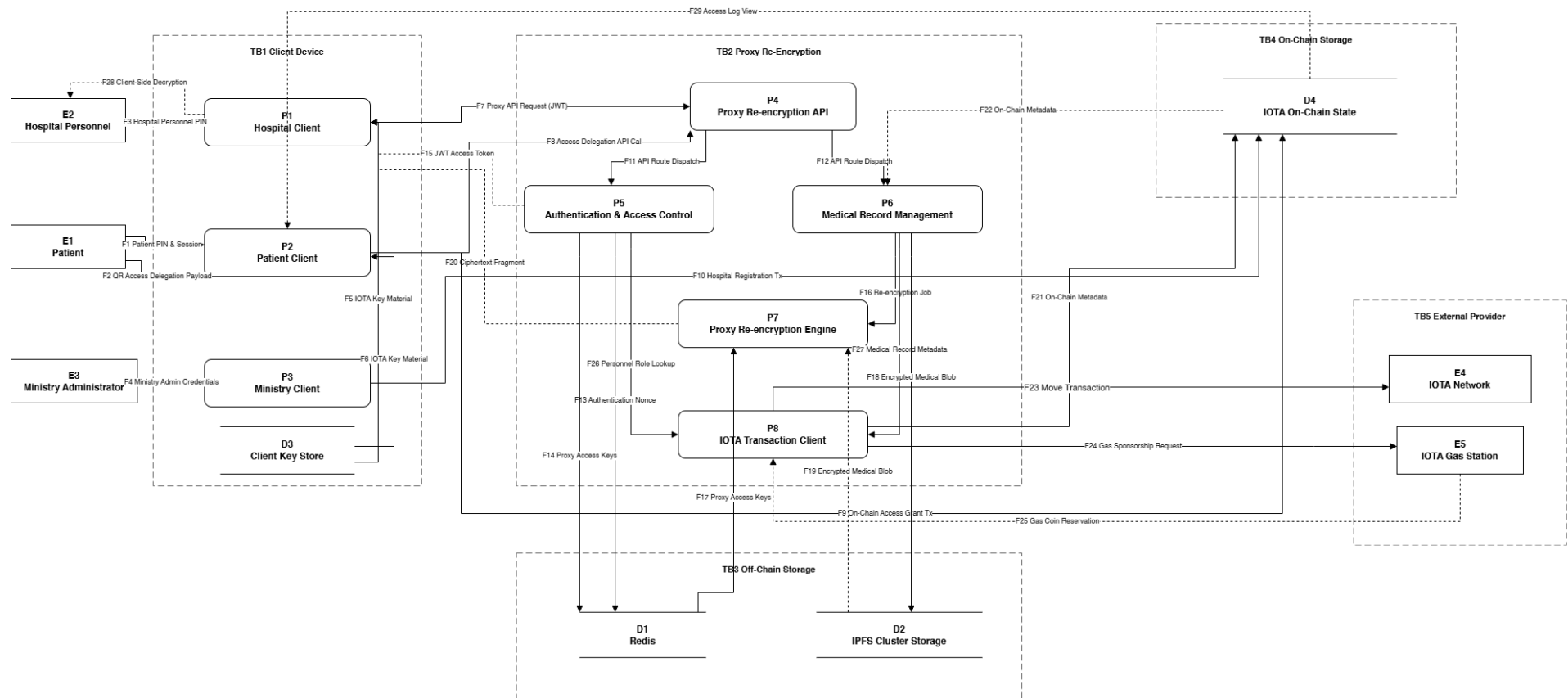
Hasil pemodelan DFD DecMed Level 0 dan Level 1 dapat dilihat pada Gambar D.2 dan D.3, sedangkan legenda pemodelan kedua DFD tersebut dapat dilihat pada Gambar D.1.



Gambar D.1: Legenda *Data Flow Diagram* (Dokumentasi Penulis)



Gambar D.2: DFD DecMed Level 0 (Dokumentasi Penulis)



Gambar D.3: DFD DecMed Level 1 (Dokumentasi Penulis)

Tabel D.1: Daftar *External Entities* pada DFD DecMed

ID	Nama	Interaksi utama
E1	Patient	PIN, QR delegasi akses, <i>revoke access</i> , lihat <i>access log</i>
E2	Hospital Personnel	PIN, baca/ <i>update</i> rekam medis, data administratif
E3	Ministry Administrator	Registrasi rumah sakit, <i>activation key</i>
E4	IOTA Network	RPC, <i>publish/execute transaction</i> , <i>read state</i>
E5	IOTA Gas Station	<i>reserve_gas</i> , <i>execute_tx</i>

Tabel D.2: Daftar *Process* DFD DecMed

ID	Nama
P0	Decmed (seluruh sistem)
P1	Hospital Client
P2	Patient Client
P3	Ministry Client
P4	Proxy Re-encryption API
P5	Authentication & Access Control
P6	Medical Record Management
P7	Proxy Re-encryption Engine
P8	IOTA Transaction Client

Tabel D.3: Daftar *Data Store* pada DFD DecMed

ID	Nama	Data sensitif
D1	Redis Cache	<i>Nonce challenge</i> , <i>AccessKeys</i> (k-frag, PRE public keys, seed terenkripsi)
D2	IPFS Cluster Storage	Blob rekam medis terenkripsi (CID direferensikan <i>on-chain</i>)
D3	Client OS Keyring	IOTA keypair, PRE keys, PIN-derived secrets, <i>activation key</i>
D4	IOTA On-Chain State	Metadata, <i>access grants</i> , <i>access log</i> , <i>hospital registry</i>

Tabel D.4: Daftar Data Flow pada DFD DecMed (Level 0)

ID	Label	Arah
F1	Patient Identity & Keys	E1 → P0
F2	Access Delegation Grant	E1 → P0
F3	Hospital Personnel Credentials	E2 → P0
F4	Encrypted Medical Record Request	E2 → P0
F5	Hospital Registration Request	E3 → P0
F6	On-Chain Transaction	P0 → E4
F7	On-Chain State Query	P0 → E4
F10	Re-encrypted Record Response	P0 → E2
F11	Decrypted Record View	P0 → E1
F12	Activation Key Delivery	P0 → E2
F18	Encrypted Blob	P0 → D2

Tabel D.5: Daftar Data Flow pada DFD DecMed (Level 1)

ID	Label	Arah Ringkas
F1	Patient PIN & Session	E1 → P2
F2	QR Access Delegation Payload	E1 → P2
F3	Hospital Personnel PIN	E2 → P1
F4	Ministry Admin Credentials	E3 → P3
F5	IOTA Key Material	D3 → P1
F6	IOTA Key Material	D3 → P2
F7	Proxy API Request (JWT)	P1 → P4
F8	Access Delegation API Call	P2 → P4
F9	On-Chain Access Grant Tx	P2 → D4
F10	Hospital Registration Tx	P3 → D4
F11	API Route Dispatch	P4 → P5
F12	API Route Dispatch	P4 → P6
F13	Authentication Nonce	P5 → D1
F14	Proxy Access Keys	P5 → D1
F15	JWT Access Token	P5 → P1
F16	Re-encryption Job	P6 → P7
F17	Proxy Access Keys	D1 → P7
F18	Encrypted Medical Blob	P6 → D2
F19	Encrypted Medical Blob	D2 → P7
F20	Ciphertext Fragment	P7 → P1
F21	On-Chain Metadata	P8 → D4
F22	On-Chain Metadata	D4 → P6
F23	Move Transaction	P8 → E4
F24	Gas Sponsorship Request	P8 → E5
F25	Gas Coin Reservation	E5 → P8
F26	Personnel Role Lookup	P5 → P8
F27	Medical Record Metadata	P6 → P8
F28	Client-Side Decryption	P1 → E2
F29	Access Log View	D4 → P2

Lampiran E. Analisis STRIDE pada Sistem DecMed

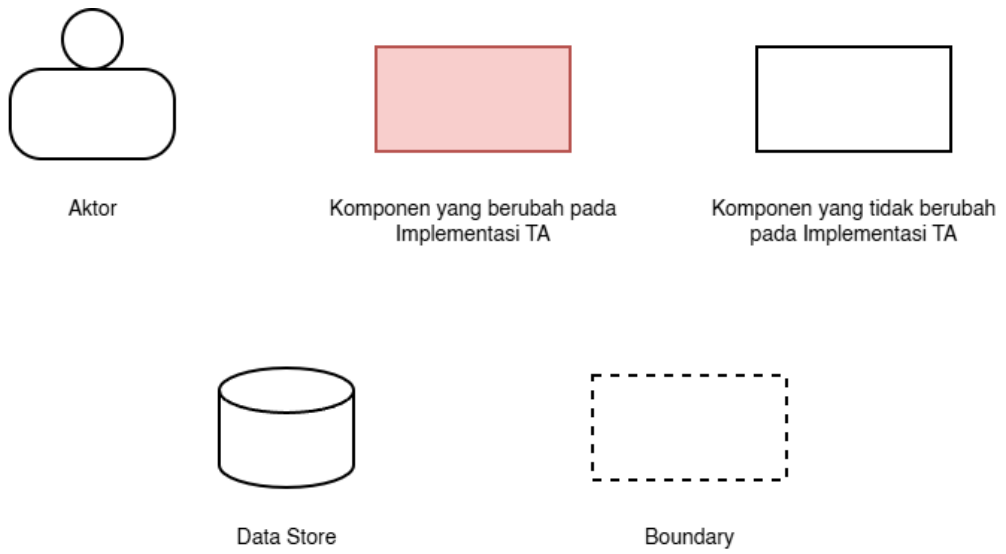
Tabel E.1: Analisis STRIDE pada Sistem DecMed

ID	Komponen / Flow	Kategori	Skenario Ancaman	Dampak
T01	P5, F7	<i>Spoofing</i>	Penyerang menggunakan token akses yang dicuri atau dipalsukan untuk data RME.	Akses tidak sah terhadap data rekam medis pasien.
T02	P8, D4, E4, dan F9	<i>Tampering</i>	Pengguna mengirim transaksi pemberian akses yang valid secara kriptografis, tetapi cakupan akses tidak dibatasi secara tepat oleh logika otorisasi <i>smart contract</i> .	Metadata akses atau metadata RME dapat menunjuk pada cakupan data yang tidak semestinya, sehingga integritas terganggu.
T03	P6, D2, dan F19	<i>Tampering</i>	Referensi CID yang mengarah ke objek <i>off-chain</i> dimanipulasi sehingga sistem mengambil <i>blob</i> terenkripsi yang tidak sesuai.	Data RME yang diambil tidak valid, tidak konsisten, atau gagal diverifikasi.
T04	P2, P5, P8, D4, F8, F9, F21, dan F29	<i>Repudiation</i>	Pihak tertentu menyangkal pernah memberikan atau menggunakan akses.	Kesulitan dalam audit dan investigasi penyalahgunaan akses.
T05	P5, P8, D4, F16, F19, F20, F21, dan F29	<i>Information Disclosure</i>	Delegasi akses membuka cakupan data pasien yang lebih luas dari kebutuhan.	Kebocoran data RME pasien.

Tabel E.1: Analisis STRIDE pada Sistem DecMed (lanjutan)

ID	Komponen / Flow	Kategori	Skenario Ancaman	Dampak
T06	P8, D4, dan F22	<i>Information Disclosure</i>	Metadata transaksi mengungkapkan relasi pasien, fasyankes, atau data pasien.	Privasi pasien dan informasi layanan klinis jadi terekspos.
T07	P4, P5, P6, P7, P8, D1, E4, dan F7	<i>Denial of Service</i>	Layanan PRE atau penyimpanan IPFS tidak dapat diakses akibat serangan atau gangguan layanan.	Proses akses rekam medis menjadi lambat atau tidak tersedia.
T08	P2, P5, P8, dan D4, F8, F9,	<i>Elevation of Privilege</i>	Pengguna memperoleh hak akses lebih tinggi melalui delegasi yang tidak dibatasi.	Terjadi eskalasi hak akses di luar kebutuhan klinis yang sah.

Lampiran F. Legenda Diagram Arsitektur Solusi



Gambar F.1: Legenda Diagram Arsitektur Solusi (Dokumentasi Penulis)

Lampiran G. Skema Penyimpanan Data RME

Lampiran ini memuat rincian skema penyimpanan data RME yang digunakan pada rancangan segmentasi data. Skema penyimpanan dibagi menjadi metadata segmen yang disimpan pada penyimpanan *on-chain* dan isi segmen terenkripsi yang disimpan pada penyimpanan *off-chain*.

Tabel G.1: Skema Metadata Segmen RME *On-Chain*

Komponen	Key JSON	Keterangan
Identitas Segmen	segment_id	UUID unik untuk satu segmen data RME.
	related_rme_id	ID RME atau episode pelayanan yang menjadi induk segmen, dengan format RME-{6_digit}.
	patient_address	Alamat <i>wallet</i> pasien pemilik RME.
	hospital_id	ID fasilitas pelayanan kesehatan ketika menerima pelayanan.
Kategori Data	dataset_category	Kategori dataset. Sesuai dengan tabel III.9.
	function_category	Kategori fungsi klinis atau administratif. Sesuai dengan tabel III.10.
Pointer dan Integritas	ipfs_cid	CID IPFS dari segmen data terenkripsi.
	integrity_hash	Hash SHA-256 dari segmen terenkripsi.
Kapsul Kunci	capsule	Kapsul PRE yang diperlukan untuk proses <i>re-encryption</i> .

Komponen	Key JSON	Keterangan
	enc_key_and_nonce	Kunci simetris dan <i>nonce</i> yang sudah terenkripsi untuk membuka segmen data.
Audit Metadata	created_at	Waktu pembuatan metadata segmen.
	author_address	Alamat <i>wallet</i> aktor yang membuat atau memperbarui segmen.

Tabel G.2: Skema Segmen Data RME *Off-Chain*

Komponen	Key JSON	Keterangan
Header Segmen	segment_id	UUID yang sama dengan <i>segment_id</i> pada metadata <i>on-chain</i> .
	related_rme_id	ID RME atau episode pelayanan yang menjadi induk segmen, dengan format RME-{6_digit}.
	dataset_category	Kategori dataset sesuai Tabel III.9.
	function_category	Kategori fungsi sesuai dengan Tabel III.10.
Konteks Medis	patient_address	Alamat IOTA pasien pemilik RME.
	service_date	Tanggal dan waktu ketika segmen tercatat dengan format YYYY-MM-DD HH:MM:SS beserta informasi <i>timezone</i> .
	author_address	Alamat IOTA aktor yang menulis isi segmen.

Komponen	Key JSON	Keterangan
Isi Segmen	payload	Objek segmen data RME dengan tipe data Value. Pada implementasi ini, isi segmen dalam bentuk text.
	payload_hash	<i>Hash</i> isi payload.

Lampiran H. Contoh *Caveat* Token Macaroon untuk Setiap Tahapan

Lampiran ini menyajikan contoh *caveat* token Macaroon pada setiap tahapan alur pemberian akses, mulai dari penerbitan token awal oleh pasien hingga rangkaian delegasi yang dilakukan oleh tenaga kesehatan. Nilai alamat *wallet* (0xPASIEN, 0xPETUGAS_RM, 0xDOKTER, 0xPERAWAT, 0xLAB, 0xAPOTEKER), hospital-001, dan RME-001 hanya bersifat ilustratif. Pada implementasi, nilai-nilai tersebut akan berbeda tergantung pada alamat *wallet* pemegang token serta ID RME yang di-generate. Simbol titik tiga (...) adalah bentuk ilustrasi yang digunakan untuk menunjukkan bahwa token dapat memiliki lebih banyak nilai lainnya selain yang dituliskan.

Penerbitan Awal: Pasien → Petugas Rekam Medis

```
1  purpose = Read
2  patient_address = 0xPASIEN
3  root_subject = 0xPETUGAS_RM
4  hospital_cid = hospital-001
5
6  read_dataset_in = [RAWAT_JALAN, RAWAT_INAP, LABORATORIUM, APOTEK]
7
8  read_function_in = [
9      ADMINISTRATIVE_GENERAL,
10     ANAMNESIS,
11     PEMERIKSAAN_FISIK,
12     PEMERIKSAAN_PSIKOLOGIS,
13     ...
14 ] // seluruh 15 fungsi
15
16 expires_before = 2026-05-16T18:00:00
17 max_delegation_depth = 2
```

Kode H.1: Contoh *Caveat* Token Read Awal untuk Petugas Rekam Medis

```

1  purpose = Update
2  patient_address = 0xPASIEN
3  root_subject = 0xPETUGAS_RM
4  related_rme_id = RME-001
5  hospital_cid = hospital-001
6
7  write_dataset_in = [RAWAT_JALAN, LABORATORIUM, APOTEK]
8
9  write_function_in = [
10     ... // union fungsi dari ketiga dataset di atas
11 ]
12
13 expires_before = 2026-05-16T18:00:00
14 max_delegation_depth = 2

```

Kode H.2: Contoh *Caveat* Token Update Awal untuk Petugas Rekam Medis

Delegasi: Petugas Rekam Medis → Dokter

```

1  parent_token_hash = <sha256(parent)>
2  delegated_by = 0xPETUGAS_RM
3  delegated_to = 0xDOKTER
4
5  read_dataset_in = [RAWAT_JALAN, RAWAT_INAP, LABORATORIUM, APOTEK]
6  write_dataset_in = [RAWAT_JALAN, LABORATORIUM, APOTEK]
7
8  read_function_in = [
9     ... // semua 15 fungsi
10 ]
11 write_function_in = [
12     ... // 14 fungsi, ADMINISTRATIVE_GENERAL dihapus
13 ]
14
15 related_rme_id = RME-001
16 expires_before = 2026-05-16T18:00:00

```

```
17 max_delegation_depth = 1
```

Kode H.3: Contoh *Caveat* Delegasi Petugas Rekam Medis → Dokter

Delegasi: Petugas Rekam Medis → Perawat

```
1 parent_token_hash = <sha256(parent)>
2 delegated_by = 0xPETUGAS_RM
3 delegated_to = 0xPERAWAT
4
5 read_dataset_in = [RAWAT_JALAN]
6 write_dataset_in = [RAWAT_JALAN]
7
8 read_function_in = [
9     ADMINISTRATIVE_GENERAL,
10    ANAMNESIS,
11    PEMERIKSAAN_FISIK]
12 write_function_in = [ANAMNESIS, PEMERIKSAAN_FISIK]
13
14 expires_before = 2026-05-16T18:00:00
15 max_delegation_depth = 1
```

Kode H.4: Contoh *Caveat* Delegasi Petugas Rekam Medis → Perawat

Delegasi: Dokter → Petugas Laboratorium

```
1 parent_token_hash = <sha256(token_dokter)>
2 delegated_by = 0xDOKTER
3 delegated_to = 0xLAB
4
5 read_dataset_in = [LABORATORIUM]
6 write_dataset_in = [LABORATORIUM]
7
8 read_function_in = [
9     ADMINISTRATIVE_GENERAL,
```

```

10     PEMERIKSAAN_PENUNJANG,
11     LABORATORIUM]
12 write_function_in = [LABORATORIUM]
13
14 expires_before = 2026-05-16T18:00:00
15 max_delegation_depth = 0

```

Kode H.5: Contoh *Caveat* Delegasi Dokter → Petugas Laboratorium

Delegasi: Dokter → Apoteker

```

1  parent_token_hash = <sha256(token_dokter)>
2  delegated_by = 0xDOKTER
3  delegated_to = 0xAPOTEKER
4
5  read_dataset_in = [RAWAT_JALAN, APOTEK]
6  write_dataset_in = [APOTEK]
7
8  read_function_in = [
9      ADMINISTRATIVE_GENERAL,
10     RIWAYAT_PENGUNAAN_OBAT,
11     TERAPI,
12     PERESEPAN,
13     DISPENSING
14 ]
15 write_function_in = [PERESEPAN, DISPENSING]
16
17 expires_before = 2026-05-16T18:00:00
18 max_delegation_depth = 0

```

Kode H.6: Contoh *Caveat* Delegasi Dokter → Apoteker

Lampiran I. Pengujian dan Evaluasi Kebutuhan Sistem

I.1 Pengujian Kebutuhan Fungsional

Tabel berikut menyajikan rincian pengujian kebutuhan fungsional pada alur Rawat Jalan dan Rawat Inap.

Tabel I.1: Pengujian Kebutuhan Fungsional pada Alur Rawat Jalan dan Rawat Inap

ID	Skenario	Ekspektasi	KF
P-KF-01	Pasien memberikan akses awal kepada petugas RM sesuai konteks episode pelayanan.	Token awal episode pelayanan berhasil diterbitkan.	KF-TA-01
P-KF-02	Petugas RM mendelegasikan akses pemeriksaan awal kepada perawat.	Token turunan perawat berhasil dibuat.	KF-TA-04
P-KF-03	Petugas RM mendelegasikan akses klinis kepada dokter.	Token turunan dokter berhasil dibuat.	KF-TA-04
P-KF-04	Perawat mengisi hasil pemeriksaan awal.	Data pemeriksaan awal berhasil disimpan.	KF-TA-07
P-KF-05	Dokter membaca pemeriksaan awal dan mengisi data klinis.	Data klinis berhasil dibaca dan disimpan.	KF-TA-05
P-KF-06	Dokter mendelegasikan akses laboratorium.	Token turunan laboratorium berhasil dibuat.	KF-TA-06
P-KF-07	Petugas laboratorium membaca pemeriksaan penunjang dan mengisi hasil laboratorium.	Data pemeriksaan penunjang berhasil dibaca dan hasil laboratorium disimpan.	KF-TA-08

Tabel I.1: Pengujian Kebutuhan Fungsional pada Alur Rawat Jalan dan Rawat Inap (lanjutan)

ID	Skenario	Ekspektasi	KF
P-KF-08	Dokter membaca hasil laboratorium.	Hasil laboratorium berhasil dibaca oleh dokter.	KF-TA-05
P-KF-09	Dokter mendelegasikan akses apotek.	Token turunan apoteker berhasil dibuat.	KF-TA-06
P-KF-10	Apoteker membaca resep dan mengisi status pelayanan obat.	Data resep dan pelayanan obat berhasil diproses.	KF-TA-09
P-KF-11	Pasien membuka riwayat delegasi episode pelayanan.	Riwayat delegasi episode pelayanan ditampilkan.	KF-TA-03
P-KF-12	Pasien merevokasi salah satu akses delegasi episode pelayanan.	Aktor <i>delegatee</i> tidak bisa mengakses data RME pasien lagi.	KF-TA-02

I.2 Evaluasi Kebutuhan Sistem

Tabel berikut menyajikan pemetaan kebutuhan sistem terhadap implementasi dan pengujian. Status “Terpenuhi” menyatakan pemenuhan pada cakupan skenario uji dan batasan prototipe penelitian, bukan jaminan keamanan operasional di luar ruang lingkup pengujian.

Tabel I.2: Evaluasi Kebutuhan Sistem terhadap Implementasi dan Pengujian

Kebutuhan	Implementasi Terkait	Pengujian Terkait	Status
KF-TA-01	I-TA-02, I-TA-03, I-TA-05	P-KF-01	Terpenuhi.
KF-TA-02	I-TA-03, I-TA-04, I-TA-05	P-KF-12, P-KNF-11, P-KNF-12	Terpenuhi.
KF-TA-03	I-TA-04, I-TA-05	P-KF-11	Terpenuhi.
KF-TA-04	I-TA-02, I-TA-04, I-TA-06	P-KF-02, P-KF-03	Terpenuhi.

Tabel I.2: Evaluasi Kebutuhan Sistem terhadap Implementasi dan Pengujian (lanjutan)

Kebutuhan	Implementasi Terkait	Pengujian Terkait	Status
KF-TA-05	I-TA-01, I-TA-03, I-TA-06	P-KF-05, P-KF-08	Terpenuhi.
KF-TA-06	I-TA-02, I-TA-04, I-TA-06	P-KF-06, P-KF-09	Terpenuhi.
KF-TA-07	I-TA-01, I-TA-03, I-TA-06	P-KF-04	Terpenuhi.
KF-TA-08	I-TA-01, I-TA-03, I-TA-06	P-KF-07	Terpenuhi.
KF-TA-09	I-TA-01, I-TA-03, I-TA-06	P-KF-10	Terpenuhi.
KNF-TA-01	I-TA-01, I-TA-02, I-TA-03	P-KNF-01, P-KNF-02	Terpenuhi.
KNF-TA-02	I-TA-02, I-TA-03, I-TA-06	P-KNF-03, P-KNF-04, P-KNF-05, P-KNF-06	Terpenuhi.
KNF-TA-03	I-TA-02, I-TA-03, I-TA-06	P-KNF-07, P-KNF-08, P-KNF-09	Terpenuhi.
KNF-TA-04	I-TA-04, I-TA-05, I-TA-06	P-KF-11, P-KNF-10	Terpenuhi.
KNF-TA-05	I-TA-03, I-TA-05	P-KNF-11, P-KF-12, P-KNF-12	Terpenuhi.
KNF-TA-06	I-TA-03, I-TA-06	P-KNF-09, P-KNF-13	Terpenuhi.
KNF-TA-07	I-TA-01, I-TA-03	P-KNF-14, P-KNF-15	Terpenuhi.
KNF-TA-08	I-TA-01, I-TA-04	P-KNF-16	Terpenuhi.

Lampiran J. Daftar Dependensi DecMed

Daftar ini hanya mencakup dependensi langsung yang dideklarasikan pada masing-masing komponen, bukan seluruh dependensi transitif. Dependensi internal yang ditandai dengan path merupakan *crate* lokal yang dikembangkan sebagai bagian dari sistem.

Tabel J.1: Dependensi Umum yang Digunakan pada Beberapa Komponen

<i>Crate</i>	Versi/Sumber
serde	1
serde_json	1
sha2	0.10
uuid	1
bip39	2
iota-sdk	Git rev. 3d7c588
iota-keys	Git rev. 3d7c588
iota-config	Git rev. 3d7c588
iota-types	Git rev. 3d7c588
iota-json-rpc-types	Git rev. 3d7c588
shared_crypto	Git rev. 3d7c588
move-core-types	Git rev. 3d7c588
dotenv	0.15
bcs	0.1.4
schemars	0.8
rand	0.9
bincode	2
umbral-pre	0.11
aes-gcm	0.10
argon2	0.5.3
hex	0.4.3
regex	1.11.1
generic-array	1.2.0

<i>Crate</i>	Versi/Sumber
k256	0.13.4
elliptic-curve	0.13.8
chrono	0.4
base64	0.22
strum/strum_macros	0.27
anyhow	1.0
thiserror	2.0

Tabel J.2: Dependensi PRE

<i>Crate</i>	Versi/Sumber
axum	0.8.4
axum-extra	0.10.1
tower	0.5.2
tokio	1.44.2
reqwest	0.12
redis	0.32
r2d2	0.8
dotenvy	0.15.7
decmed-rme-segment	path
decmed-macaroon-auth	path

Tabel J.3: Dependensi *Client*

<i>Crate</i>	Versi/Sumber
tauri	2
tauri-plugin-opener	2
tauri-plugin-http	2
tauri-plugin-fs	2
keyring	3
rustls-platform-verifier	0.5
rqrr	0.9
image	0.25

<i>Crate</i>	Versi/Sumber
tokio-stream	0.1.17
decmed-rme-segment	path
decmed-macaroon-auth	path
tauri-build	2

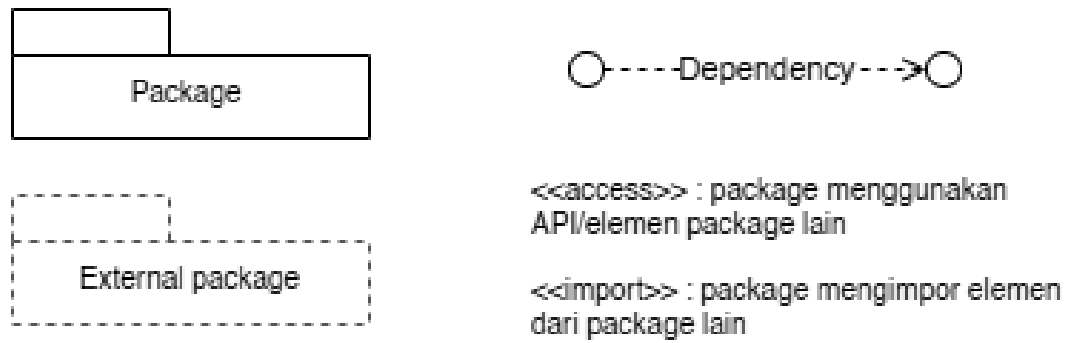
Tabel J.4: Dependensi decmed-rme-segment

<i>Crate</i>	Versi/Sumber
base64	0.22
serde	1
serde_json	1
sha2	0.10
uuid	1

Tabel J.5: Dependensi decmed-macaroon-auth

<i>Crate</i>	Versi/Sumber
chrono	0.4
serde	1
serde_json	1
thiserror	2.0
uuid	1
sha2	0.10
hex	0.4
macaroon	path
decmed-rme-segment	path

Lampiran K. Legenda Package Diagram



Gambar K.1: Legenda Package Diagram (Dokumentasi Penulis)

Lampiran L. Modul dan Implementasi *Crate* decmed-rme-segment

Tabel L.1: Daftar Modul dan Implementasi *Crate* decmed-rme-segment

Modul	Implementasi
types	CreateRmeSegmentRequest (<i>struct</i>), RmeSegmentData (<i>struct</i>) dengan new() dan validate(); ClientEncryptedRmeSegment (<i>struct</i>) dengan validate() dan into_metadata(); RmeSegmentMetadata (<i>struct</i>) dengan validate(); CreateRmeSegmentResponse (<i>struct</i>) dengan implementasi From<RmeSegmentMetadata>.
category	DatasetCategory (<i>enum</i>), FunctionCategory (<i>enum</i>), ALL_DATASET_CATEGORIES (<i>const</i>), ALL_FUNCTION_CATEGORIES (<i>const</i>).
crypto	canonical_json(), payload_hash(), sha256_hex(), ciphertext_integrity_hash_from_base64().
error	SegmentValidationError (<i>enum</i>).
administrative_payload	AdministrativeGeneralPayload (<i>struct</i>) dengan validate() dan to_payload_value(); administrative_general_payload_from_value(), administrative_general_payload_from_fields().
validation	assert_valid_correction_request(), assert_valid_correction_metadata(), get_allowed_function_categories(), is_valid_segment_category(), assert_valid_segment_category(), assert_segment_pair_consistent(), assert_no_plaintext_medical_fields().

Lampiran M. Modul dan Implementasi *Crate* decmed-macaroon-auth

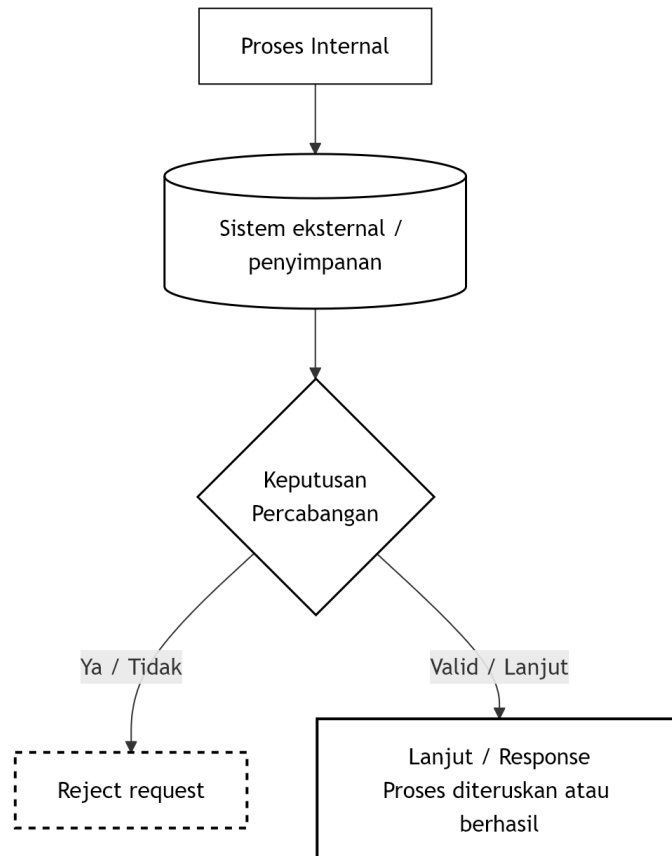
Tabel M.1: Daftar Modul dan Implementasi *Crate* decmed-macaroon-auth

Modul	Implementasi
attenuation	DelegationAttenuationParams (<i>struct</i>), attenuate_macaroon().
caveats	CaveatKey (<i>enum</i>), CaveatValue (<i>enum</i>), DecmedCaveat (<i>struct</i>), ParsedCaveats (<i>struct</i>), parse_caveat_line(), format_dataset_list(), format_function_list(), caveat_line(), add_caveat_to_macaroon().
delegation	DelegationStep (<i>struct</i>), DelegationChain (<i>struct</i>) dengan from_parsed(), delegation_depth(), subjects(), dan contains_subject().
delegation_ proof	DelegationProofContext (<i>struct</i>) dengan from_token(), from_last_delegation_step(), dan canonical_message(); hash_macaroon_token().
effective	AccessMode (<i>enum</i> : Read/Write), EffectiveCapability (<i>struct</i>) dengan from_parsed(), allows_dataset(), allows_function(), dan is_expired().
errors	CaveatVerificationError (<i>enum</i>).
issuance	AdminTokenKind (<i>enum</i> : Read/Update), InitialAdminPersonnelTokenParams (<i>struct</i>), admin_all_datasets(), admin_all_functions(), admin_write_datasets(), admin_write_functions(), issue_admin_personnel_token().
revocation	hash_token(), token_revocation_key(), compute_revocation_keys().
rme_id	format_related_rme_id().
verify	SegmentAccessContext (<i>struct</i>), TokenVerificationContext (<i>struct</i>), VerifiedDecmedToken (<i>struct</i>), verify_macaroon_signature(), verify_decmed_token(), verify_segment_access().

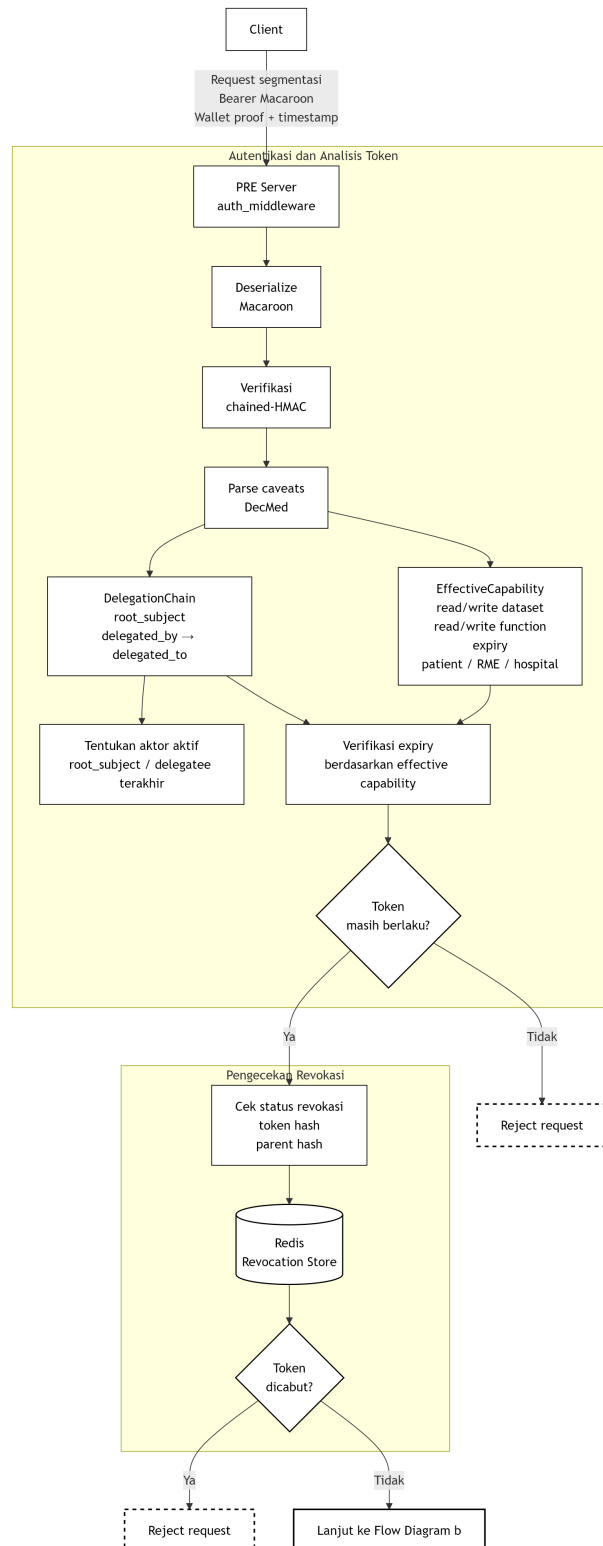
Modul	Implementasi
wallet_proof	WalletProofContext (<i>struct</i>) dengan canonical_message(), WalletSignatureVerifier (<i>trait</i>).

Lampiran N. Alur Implementasi Penegakan Otoritas pada Server PRE

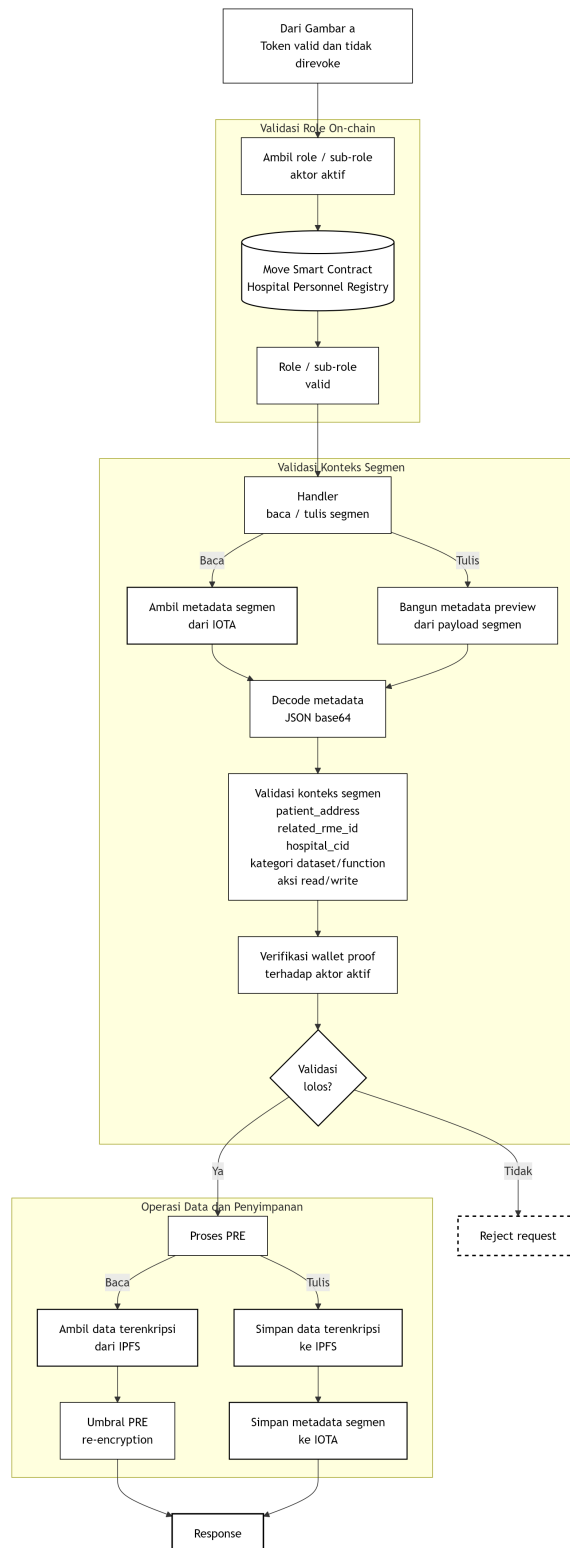
Alur penegakan otoritas pada *Server PRE* diilustrasikan dalam dua buah flow diagram yang saling berkelanjutan, sebagaimana ditunjukkan pada Gambar N.2 dan N.3. Gambar N.1 memuat legenda bentuk pada *Flow Diagram*.



Gambar N.1: Legenda bentuk pada *Flow Diagram*



Gambar N.2: Alur implementasi penegakan otoritas pada *Server PRE* bagian autentikasi token, *effective capability*, *delegation chain*, dan revokasi



Gambar N.3: Alur implementasi penegakan otoritas pada *Server PRE* bagian *wallet proof*, validasi *role* dan *subrole*, validasi segmen, serta eksekusi PRE, IPFS, dan IOTA

Lampiran O. Implementasi REST API Server PRE

Tabel O.1: Daftar Endpoint REST API pada Server PRE

Method	Endpoint	Fungsi	Status
GET	/	<i>Health check.</i>	Eksisting
GET	/medical-records	Mengambil daftar rekam medis.	Dimodifikasi
GET	/medical-record	Mengambil detail rekam medis.	Eksisting
POST	/medical-record	Membuat rekam medis.	Eksisting
PUT	/medical-record	Memperbarui rekam medis.	Eksisting
POST	/medical-record-segment	Membuat segmen rekam medis.	Baru
GET	/administrative	Mengambil data administratif pasien.	Eksisting
GET	/gen/macaroon-key	Menghasilkan RootKey Macaroon.	Baru
GET	/gen/sig	Menghasilkan <i>signature</i> .	Eksisting
GET	/gen/proxy-address	Menghasilkan dan mendaftarkan alamat proxy.	Eksisting
POST	/nonce	Mengambil nonce.	Eksisting
POST	/keys	Menyimpan kunci.	Eksisting
POST	/revocations/patient	Mencabut hak akses dan turunannya.	Baru
POST	/delegations/attenuate	Melakukan atenuasi token Macaroon sesuai <i>request</i> .	Baru

Lampiran P. Implementasi Smart Contract Sistem DecMed

Tabel P.1: Daftar Module Smart Contract Sistem DecMed

Nama Module	Deskripsi
<code>decmed::admin</code>	Modul global admin untuk registrasi rumah sakit, aktivasi admin fasyankes, dan daftar rumah sakit.
<code>decmed::hospital_personnel</code>	Modul akun tenaga fasyankes, aktivasi, akses baca/tulis, <i>delegation</i> , dan <i>audit delegation</i> .
<code>decmed::patient</code>	Modul akun pasien, <i>grant</i> akses ke <code>AdministrativePersonnel</code> , log akses, <i>audit delegation</i> , dan pembacaan metadata RME milik pasien.
<code>decmed::proxy</code>	Modul yang dipakai <i>server</i> PRE untuk baca/tulis metadata RME.
<code>decmed::shared</code>	Modul penyedia <code>GlobalAdminCap</code> dan <code>ProxyCap</code>

Tabel P.2: Daftar Method pada Module `decmed::admin`

Nama Method	Deskripsi
<code>create_activation_key</code>	Membuat data rumah sakit dan activation key pertama untuk admin rumah sakit.
<code>update_activation_key</code>	Memperbarui activation key dan metadata admin rumah sakit.
<code>get_hospitals</code>	Mengambil daftar rumah sakit untuk client kementerian/global admin.

Tabel P.3: Daftar Method pada Module `decmed::hospital_personnel`

Nama Method	Deskripsi
<code>create_activation_key</code>	Admin fasyankes membuat activation key untuk tenaga administratif atau medis.
<code>use_activation_key</code>	Menandai activation key tenaga fasyankes sebagai sudah digunakan.
<code>signup</code>	Registrasi akun tenaga fasyankes ke address IOTA dan menyimpan metadata administratif.
<code>is_account_registered</code>	Mengecek apakah akun tenaga fasyankes sudah aktif/terdaftar.
<code>get_account_state</code>	Menentukan status <i>onboarding</i> tenaga fasyankes.
<code>get_account_info</code>	Mengambil metadata akun, <i>role</i> , <i>subrole</i> , dan metadata rumah sakit.
<code>update_account_activation_key</code>	Admin fasyankes mengganti activation key personel.
<code>update_administrative_metadata</code>	Memperbarui profil administratif tenaga fasyankes.
<code>get_hospital_personnels</code>	Mengambil daftar personel di bawah admin fasyankes.
<code>get_delegatee_candidates</code>	Mengambil kandidat personel yang bisa menerima delegasi akses.
<code>cleanup_read_access</code>	Membersihkan akses baca yang sudah kedaluwarsa.
<code>cleanup_update_access</code>	Membersihkan akses <i>update</i> yang sudah kedaluwarsa.
<code>get_read_access</code>	Mengambil daftar <i>capability</i> baca milik tenaga fasyankes.
<code>get_update_access</code>	Mengambil daftar <i>capability</i> update milik tenaga fasyankes.

Nama Method	Deskripsi
<code>create_delegated_access</code>	Membuat <i>delegated access</i> untuk personel lain.
<code>create_medical_record</code>	Membuat entri RME blob besar. (<i>legacy</i>)

Tabel P.4: Daftar Method pada Module `decmed::patient`

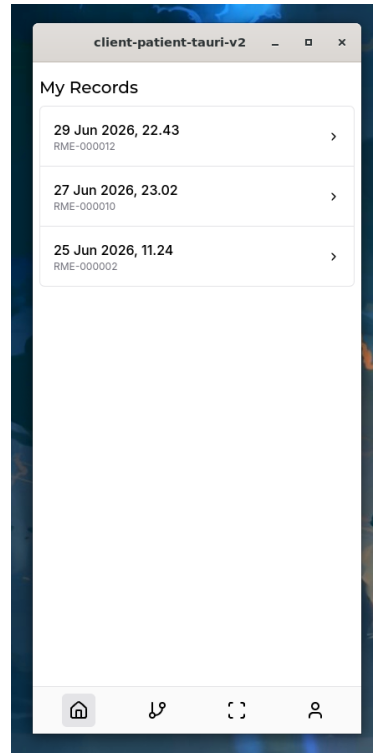
Nama Method	Deskripsi
<code>signup</code>	Registrasi akun pasien dan metadata administratif terenkripsi.
<code>is_account_registered</code>	Mengecek apakah <i>address</i> pasien terdaftar.
<code>get_account_state</code>	Menentukan status <i>onboarding</i> pasien.
<code>get_account_info</code>	Mengambil metadata administratif pasien.
<code>update_administrative_metadata</code>	Memperbarui metadata administratif pasien.
<code>get_hospital_personnel_info</code>	Mengambil info publik tenaga fasyankes saat pasien memproses QR.
<code>create_access</code>	Memberi akses baca/tulis kepada tenaga fasyankes.
<code>get_access_log</code>	Mengambil log <i>grant</i> akses pasien.
<code>get_delegation_audit_log</code>	Mengambil log <i>audit trail delegation</i> pasien.
<code>get_medical_records</code>	Mengambil daftar metadata RME pasien.
<code>get_medical_record</code>	Mengambil satu metadata RME berdasarkan indeks.
<code>revoke_access</code>	Mencabut akses tenaga fasyankes dan memicu <i>cascade revoke delegation</i> .

Tabel P.5: Daftar Method pada Module decmed : :proxy

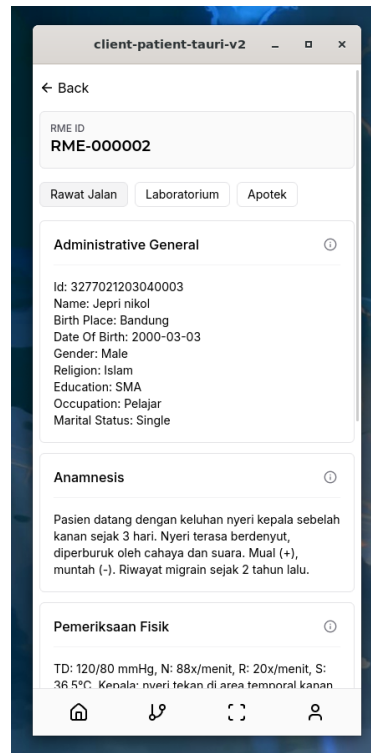
Nama Method	Deskripsi
create_capability	Membuat ProxyCap untuk address service proxy.
create_medical_record_segment	Menambahkan metadata RME tersegmentasi ke daftar medical metadata pasien.
get_administrative_data	Mengambil metadata administratif pasien untuk kebutuhan akses/dekripsi.
get_hospital_personnel_role	Mengecek role tenaga fasyankes saat setup token/key access.
get_hospital_personnel_auth_info	Mengecek <i>role</i> dan <i>subrole</i> .
get_medical_records	Mengambil daftar metadata RME pasien dan menyaringnya sebagai segmen berdasarkan cakupan akses.
get_medical_record	Mengambil satu metadata segmen dan data pendukung untuk pembacaan <i>payload</i> .
is_patient_registered	Memvalidasi bahwa pasien terdaftar
create_medical_record	Membuat entri RME blob besar. (<i>legacy</i>)
update_medical_record	Melakukan edit entri RME blob besar. (<i>legacy</i>)
get_medical_record_update	Mengambil data RME untuk proses edit entri blob besar. (<i>legacy</i>)
get_delegation_access_snapshot	Mengambil <i>snapshot</i> metadata akses delegasi.

Lampiran Q. Tangkapan Layar Implementasi *Patient Client*

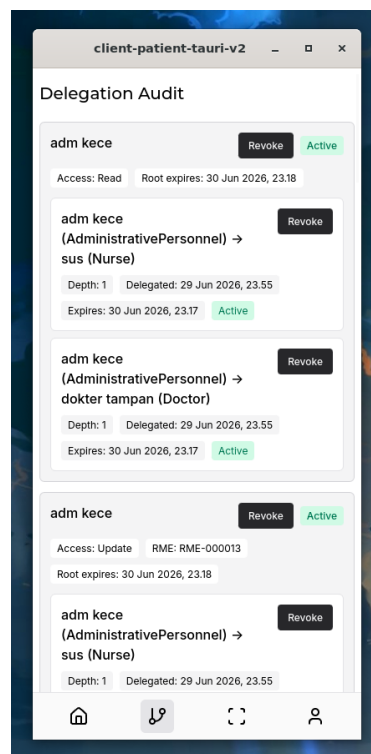
Semua tangkapan layar berikut merupakan dokumentasi penulis.



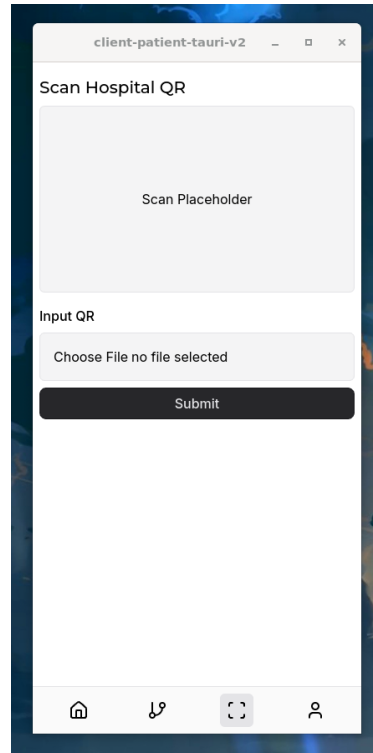
Gambar Q.1: Halaman *Home* daftar RME.



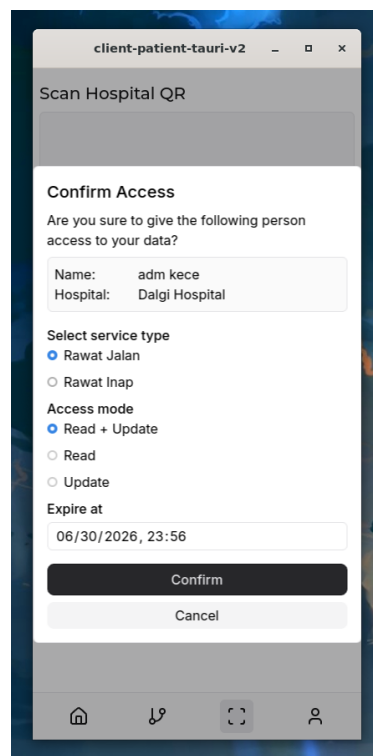
Gambar Q.2: Halaman detail RME.



Gambar Q.3: Halaman audit delegasi RME.



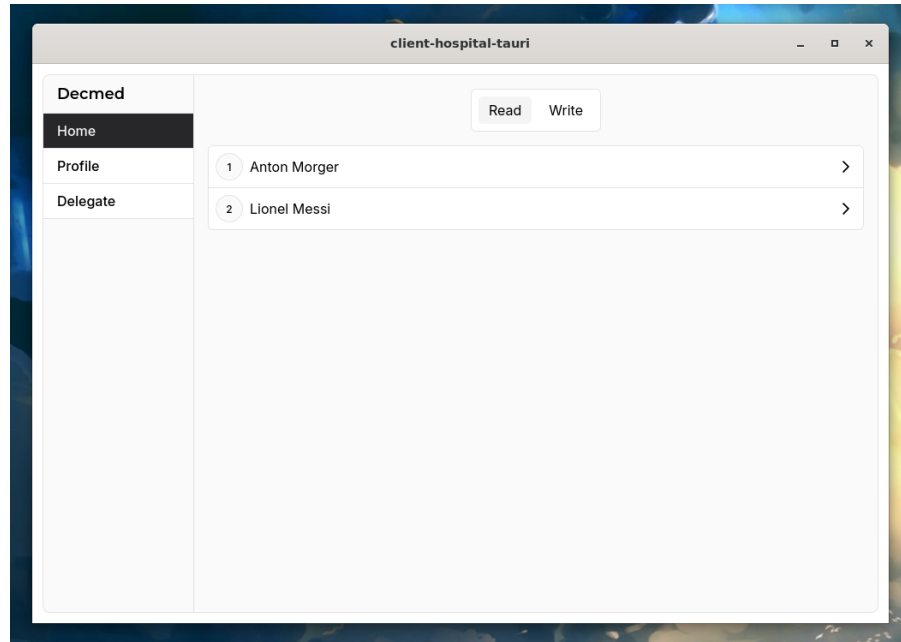
Gambar Q.4: Halaman *scan* QR.



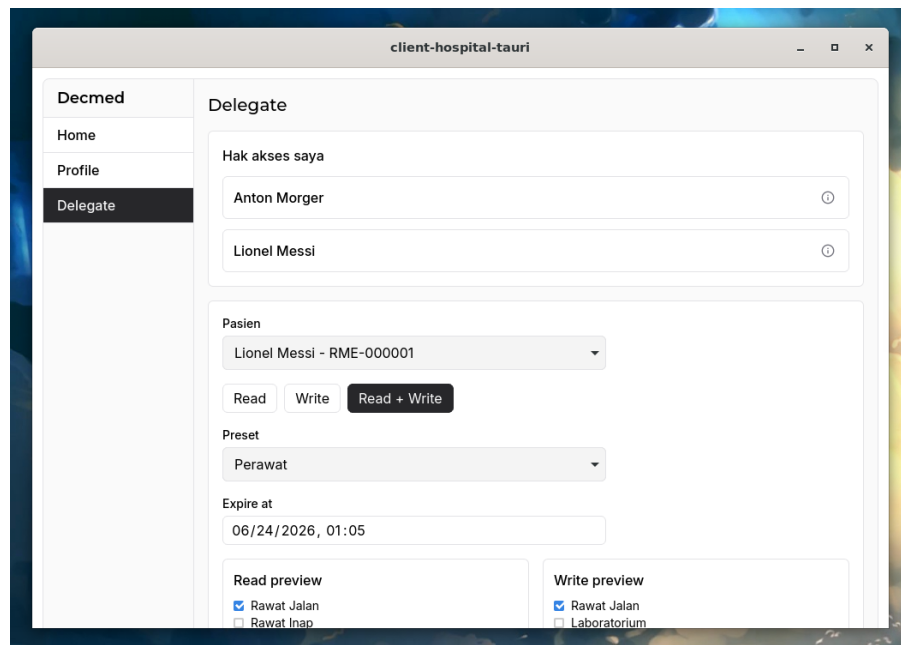
Gambar Q.5: Halaman konfirmasi pemberian akses awal.

Lampiran R. Tangkapan Layar Implementasi *Hospital Client*

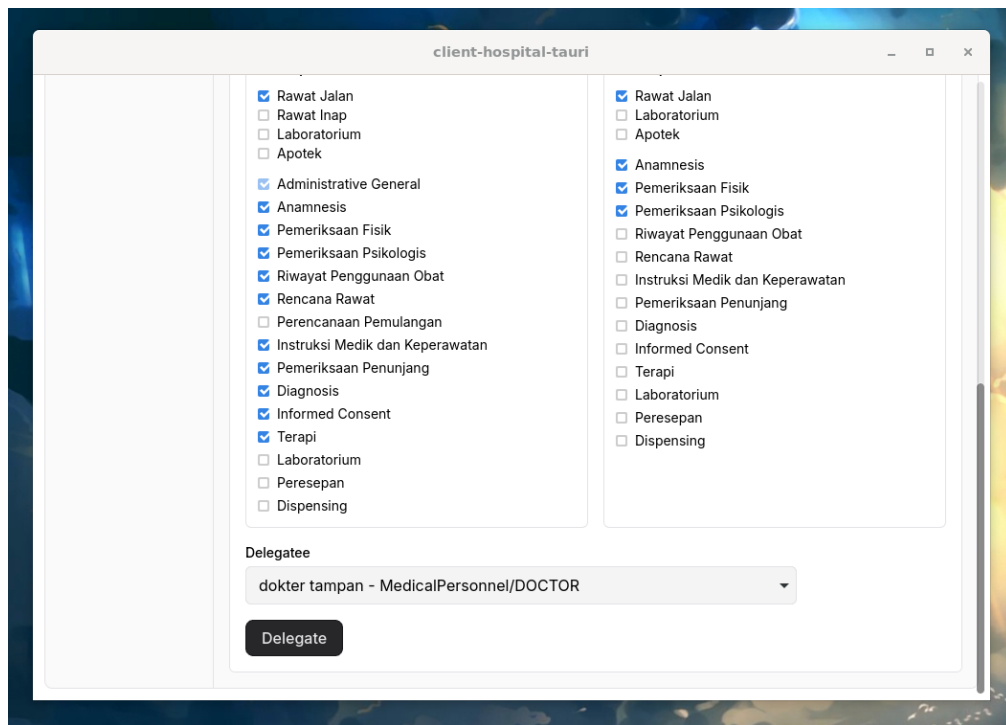
Semua tangkapan layar berikut merupakan dokumentasi penulis.



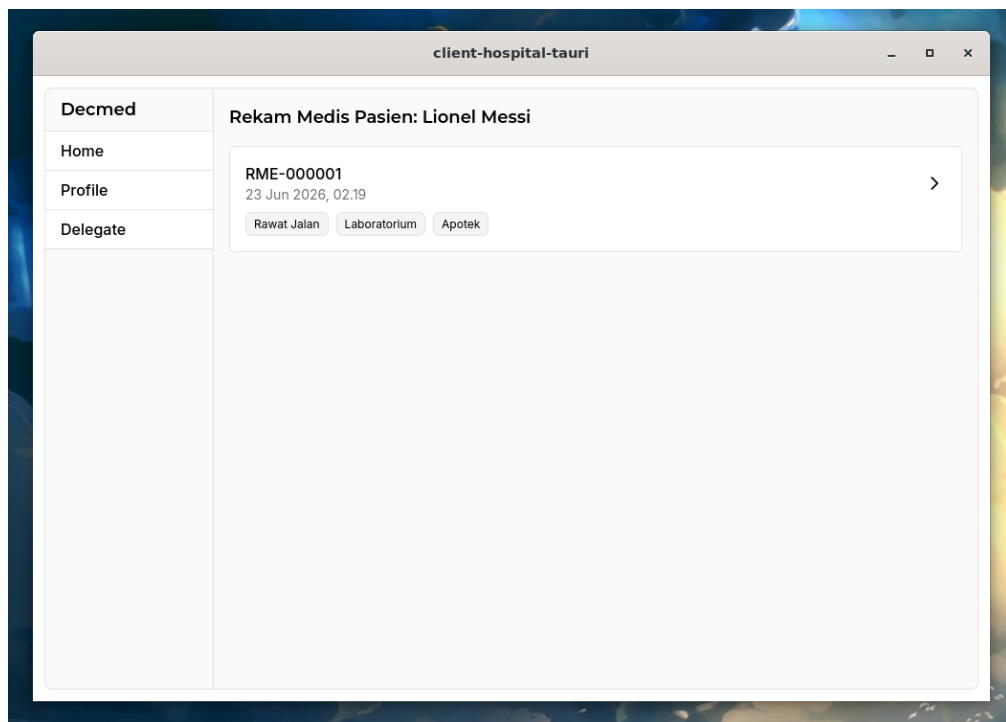
Gambar R.1: Halaman *dashboard MedicalPersonnel*.



Gambar R.2: Halaman delegasi akses bagian 1.



Gambar R.3: Halaman delegasi akses bagian 2.



Gambar R.4: Halaman daftar RME pasien pada *Hospital Client*.

client-hospital-tauri

← Back

Detail RME
RME-000001

Rawat Jalan Laboratorium Apotek

Fungsi **Administrative General**

Administrative Data

NIK	3277021203040002
Name	Lionel Messi
Birth Place	Cimahi
Date of Birth	2000-03-03
Gender	Male
Religion	Katolik
Education	SMA
Occupation	Pemain
Marital Status	Married

Gambar R.5: Halaman detail RME pada *Hospital Client*.

client-hospital-tauri

Write RME

Lionel Messi
0x4858a58fb137a1a84336f6cd2cc42079a8216d9aee1f852f830e4d18185ce95c

Dataset
Rawat Jalan

Anamnesis
Pasien mengeluh demam tinggi sejak 3 hari, disertai nyeri kepala dan lemas. Nafsu makan menurun. Tidak batuk, tidak pilek. Pernah tifoid 2 tahun lalu.

Pemeriksaan Fisik

Pemeriksaan Psikologis

Gambar R.6: Halaman alur akses tulis pada *Hospital Client*.